

生成式人工智能行业网络数据安全风险评估 工作手册

二〇二五年九月

前 言

为贯彻落实《网络安全法》《数据安全法》《个人信息保护法》《上海市数据条例》等法律法规，明确生成式人工智能行业网络数据安全风险评估实施细则，现将生成式人工智能行业各单位开展网络数据安全风险评估工作流程、步骤、方法等总结形成本工作手册。

本工作手册参与编制单位为星环信息科技（上海）股份有限公司，由上海市委网信办、徐汇区委网信办提供指导，上海市信息安全测评认证中心提供技术支持。

目 录

目 录..... II

一、 总体概述..... 1

二、 行业特点与评估目标 1

 （一） 生成式人工智能业务特点 1

 （二） 评估核心目标 2

 （三） 工作手册依据 2

 （四） 行业指标分析 4

三、 生成式人工智能行业网络数据安全风险评估流程 8

 （一） 评估准备..... 8

 1、 明确评估范围 8

 2、 组建评估团队 10

 3、 制定评估方案 12

 （二） 信息调研..... 13

 1、 生成式人工智能企业基本情况调研 13

 2、 生成式人工智能全业务链条及技术架构调研 14

3、生成式人工智能数据资产调研	14
4、数据全生命周期处理活动调研	15
5、安全防护措施调研	16
(三) 风险识别	17
1、风险识别内容	17
2、风险识别方法	18
(四) 综合分析	19
1、风险分析	19
2、风险评价	20
(五) 评估总结	21
1、编制评估报告	21
2、制定整改方案	22
附录 1 信息调研表	23
附录 1.1 生成式人工智能企业基本情况调研表	23
附录 1.2 生成式人工智能全业务链条及技术架构调研表	25
附录 1.3 生成式人工智能数据资产调研表	27

附录 1.4 数据全生命周期处理活动调研表	30
附录 1.5 安全防护措施调研表	43
附录 2 风险识别表.....	47
附录 2.1 生成式人工智能服务基础风险识别表	47
附录 2.1.1 数据安全评估表	47
附录 2.1.2 数据安全技术评估表	71
附录 2.1.3 个人信息保护评估表	83
附录 2.2 预训练数据和优化训练数据风险识别表	106
附录 2.2.1 数据安全评估表	106
附录 2.2.2 数据处理活动评估表	108
附录 2.2.3 数据安全技术评估表	120
附录 2.3 生成内容风险识别表	122
附录 2.3.1 数据处理活动评估表	122
附录 2.3.2 数据安全技术评估表	128
附录 2.4 用户交互数据风险识别表	131
附录 2.4.1 数据处理活动评估表	131

附录 2.4.2 数据安全技术评估表	137
附录 3 综合分析方法	145
附录 3.1 典型数据安全风险类型	145
附录 3.2 风险危害程度分析	147
附录 3.3 风险发生可能性分析	153
附录 3.4 风险评价	156
附录 4 评估总结模板	158

一、总体概述

本工作手册介绍了生成式人工智能行业各单位评估准备、信息调研、风险识别、综合分析、评估总结等网络数据安全风险评估实施流程，明确了生成式人工智能行业网络数据安全风险评估实施工作流程、步骤、方法等。生成式人工智能企业可直接根据本工作手册开展评估；第三方评估机构可依据本工作手册出具具有生成式人工智能行业特色的评估报告；也可供生成式人工智能行业主管监管部门实施检查评估时参考。

二、行业特点与评估目标

（一）生成式人工智能业务特点

生成式人工智能行业具备数据依赖性高、模型与生成内容的不可控性、合规与伦理挑战及动态演进的威胁场景等显著特征。首先是**数据依赖性高**，海量训练数据依赖互联网公开数据、用户生成内容（UGC）、企业私有数据等，可能涉及敏感信息（如个人隐私、商业秘密）。数据来源复杂，多源数据聚合易引入未清洗的恶意内容或偏见数据，增加数据泄露和滥用的风险。其次是**模型与生成内容的不可控性**，可能生成虚假信息、有害内容（暴力、歧视性文本）、版权侵权内容（模仿受版权保护的风格）。模型易受提示词注入或后门攻击，导致恶意输出或数据泄露。最后是**合规与伦理挑战**，训练数据可能涉及不同的隐私法规。生成内容可能被用于诈骗、舆论操纵等非法用途，企业需承担连带责

任。

（二）评估核心目标

基于上述生成式人工智能业务特点，生成式人工智能行业网络数据安全风险评估的核心目标聚焦于“三类核心资产”。

1、三类核心资产

（1）训练数据集：涵盖原始数据、标注数据及清洗后的训练样本，其泄露可能导致隐私侵权、商业秘密曝光或模型被逆向复现。

（2）生成内容输出：涉及文本、图像、代码等 AI 生成成果，若含敏感信息或侵权内容，可能引发法律纠纷。

（3）用户交互数据：存储用户输入提示词（Prompt）、反馈数据及会话日志，需防范滥用导致的隐私泄露。

生成式人工智能行业网络数据安全风险评估需在数据依赖性高、模型与生成内容的不可控性、合规与伦理挑战的复杂环境中，以“三类核心资产”为基准构建系统化、场景化、合规化的网络数据安全风险评估框架。

（三）工作手册依据

开展生成式人工智能行业网络数据安全风险评估工作依据包括但不限于：

- 《中华人民共和国网络安全法》
- 《中华人民共和国数据安全法》
- 《中华人民共和国个人信息保护法》
- 《网络数据安全管理条例》
- 《生成式人工智能服务管理暂行办法》
- 《人工智能生成合成内容标识办法》
- 《上海市数据条例》
- 《数据安全技术 数据安全风险评估方法》 GB/T 45577-2025
- 《数据安全技术 数据分类分级规则》 GB/T 43697-2024
- 《数据安全技术 敏感个人信息处理安全要求》 GB/T 45574-2025
- 《信息安全技术 个人信息安全规范》 GB/T 35273-2020
- 《数据安全技术 数据安全评估机构能力要求》 GB/T 45389-2025
- 《网络安全技术 人工智能生成合成内容标识方法》 GB/T 45438-2025
- 《网络安全技术 生成式人工智能预训练和优化训练数据安全规范》 GB/T 45652-2025

➤ 《网络安全标准实践指南——个人信息保护合规审计要求》 TC260-PG-20255A

➤ 《生成式人工智能服务安全基本要求》 GB/T 45654-2025

（四）行业指标分析

《生成式人工智能行业网络数据安全风险评估工作手册》在《数据安全技术 数据安全风险评估方法》提供的通用风险评估框架基础上，进行行业化适配，删减了与生成式人工智能核心业务关联度不高的部分（如政务数据、大型平台），使评估更聚焦。其最主要的变化体现在风险识别模块的重构——将原本通用评估表，依据生成式人工智能服务特有的数据处理环节与核心资产类型，拆解为“基础风险识别表”与三大“专项风险识别表”，形成“行业基础+场景特点”的多层次风险评估体系。

通过“生成式人工智能服务基础风险识别表”继承通用识别表的全面性，确保在数据安全治理、数据处理活动、数据安全技术及个人信息保护等方面的基础合规要求得到全面覆盖。本手册引入三大专项识别表，实现对不同场景的特殊风险的识别：

1. 预训练数据和优化训练数据风险识别表：本表对应模型训练前期的数据准备环节，保障模型基础安全性与合法性。聚焦数据采集源头合规性（如开源协议遵循、版权审核、多源比例）、预处理过程中的安全与伦理风险（如数据投毒检测、偏见过滤、

知识产权侵权识别）、以及数据使用阶段的管控（如跨境传输、批次管理）。

2. 生成内容风险识别表：本表对应模型推理生成环节，是评估模型输出内容对社会、个人造成直接影响的关键。针对模型“产出物”的安全性与合规性，重点关注生成内容本身的有害性（如虚假信息、深度伪造、不当内容）、知识产权侵权风险（模仿受版权保护的风格或内容）、以及内容滥用带来的社会危害（如诈骗、舆论操纵）。

3. 用户交互数据风险识别表：本表对应模型服务交互环节，确保了用户隐私和数据在交互过程中的安全性，聚焦模型与用户“交互过程”中的安全。重点评估用户输入（Prompt）的敏感性与风险（如恶意指令注入）、会话日志的留存与保护、以及用户反馈数据的使用合规性。这种拆分基于实际数据处理流程的内在逻辑，引导评估者沿着“数据输入（训练数据）→模型处理→内容输出（生成内容）”以及用户持续的“交互反馈（用户数据）”这一完整闭环，进行贯穿式的风险识别。

表1 风险识别变化内容一览表

评估维度	国标《数据安全风险评估方法》	《生成式人工智能行业网络数据安全风险评估工作手册》(生成式人工智能行业)	变化说明	参考标准
1. 整体结构	通用性的数据安全 安全管理、处理 活动、安全技术、个人信息保护四大框架。	在通用框架基础上，新增“预训练与优化训练数据”、“生成内容”、“用户交互数据”三大专属风险识别板块。	结构重组与扩展，凸显行业特性。	GB/T 45652-2025 核心目标
2. 数据收集	关注合法性、正当性、数据质量、收集方式与设备安全。	特别强调数据来源记录（URL、数据集名称、授权文件）、开源协议合规、多数数据源比例（单一来源≥1%）、跨境收集合规。	对数据来源的追溯性和多样性提出量化要求，适应 AI 训练数据来源复杂的特点。	GB/T 45652-2025 5.1 c), d), e), h)
3. 数据预处理	通用性数据清洗、转换、加载的安全要求。	新增“数据预处理安全性”与“知识产权风险”专项评估。要求对文本、图像、音视频等不同模态数据建立专门的过滤机制，并管理版权风	针对 AI 训练数据规模大、格式多、版权问题突出的特点，增强了预处理环节的 安全和合规控制。	GB/T 45652-2025 5.2 b), h), i)

		险。		
4. 数据使用	关注使用合法性、正当性、环境安全与安全措施。	新增“生成内容风险”评估。要求防止生成有害内容,境外数据需搭配境内数据使用,展示数据需进行安全评估。	重点关注模型输出内容的安全性和合规性,并提出了数据使用的国籍比例要求。	GB/T 45652-2025 5.3 a), b), c)
5. 数据安全技术	涵盖网络防护、访问控制、加密、脱敏、备份、审计等通用技术。	新增“训练数据安全”专项: • 批次隔离与标识 (可追溯) • 投毒数据检测与修复 • 行业数据特殊保护	针对 AI 训练过程的特点,提出了确保训练数据完整性和真实性的具体技术控制点。	GB/T 45652-2025 4. d), n), m)
6. 个人信息保护	全面涵盖个人信息处理全生命周期的合规要求。	在通用要求基础上,特别强调: • 去标识化与隔离存储 • 生物特征信息安全 (如人脸识别合规) • 自动化决策的公平透明	强化在 AI 模型训练和交互场景中,对个人信息,特别是敏感信息的增强保护要求。	GB/T 35273 4. f)
7. 数据删除与销毁	通用性的删除策略、流程和介质销毁要求。	强调删除有效性验证、多副本同步删除,并要求核心数据	要求更严格,确保数据,尤其是训练数据的彻	GB/T 35273 4. i), j)

		采用介质销毁方式。	底删除，防止残留数据导致模型逆向或泄露。	
8. 新增风险维度	无	新增“知识产权侵权风险”：要求建立管理策略、投诉渠道并在用户协议中告知风险。	首次将“知识产权”作为核心风险纳入评估体系，应对生成式 AI 面临的版权争议。	GB/T 35273 5.2 h)
		新增“价值对齐与伦理风险”：要求识别并处置不符合人类价值观和伦理道德的数据。	引入 AI 伦理层面的风险评估，确保 AI 发展与人类价值观一致。	GB/T 35273 6.2 c)
		新增“幻觉风险评估”：要求识别 AI 生成内容中的错误知识。	针对生成式 AI 的“幻觉”或“胡编乱造”问题提出的特有风险控制点。	GB/T 35273 6.3 b)

三、生成式人工智能行业网络数据安全风险评估流程

生成式人工智能行业网络数据安全风险评估流程主要包括评估准备、信息调研、风险识别、综合分析、评估总结五个阶段。

（一）评估准备

1、明确评估范围

生成式人工智能行业网络数据安全风险评估可围绕“训练数据、模型资产及生成内容”为核心展开，评估范围可覆盖企业全业务链条（如数据采集、模型训练、推理部署、用户交互等全流程），也可聚焦于某一技术环节（如数据预训练过程）、某一系统（如大模型微调平台）或某一业务场景（如 AI 客服应用）所涉及的数据与处理活动。

若面向生成式 AI 企业开展全域评估，应遵循“数据驱动、风险分层”的原则：

全景梳理：全面盘点训练数据来源（公开数据集、用户输入、第三方合作数据等）、模型开发生命周期（预训练、微调、部署、迭代）及生成内容输出场景（如文本、图像、音视频生成），明确数据流向与处理活动。

场景聚焦：重点锁定高风险数据与活动。

训练数据：含个人隐私数据（如用户对话日志）、商业秘密（如专有数据集）、受版权保护内容（如艺术风格数据集）。

模型资产：包括核心模型参数、推理 API 访问权限、第三方依赖组件（如开源库）。

生成内容：涉及虚假信息（Deepfake）、侵权输出（模仿版权作品）、敏感内容（暴力）、有害内容（涉社会主义核心价值观等）。

抽样评估一般数据：如模型调试日志、非敏感用户反馈数据等。

未分级情况下的优先级判定：若企业尚未建立数据分类分级体系，应以业务影响度与合规风险为依据，优先评估以下核心环节：

数据采集与清洗系统（如爬虫合规性、数据去标识化措施）；模型训练平台（如算力集群访问控制、训练数据泄露风险）；生成内容审核机制；用户交互接口（如 **Prompt** 注入防御、会话日志存储合规性）。

通过分层评估，确保关键数据（如训练集、模型权重）与高危场景（如数据泄露、恶意生成）风险可控，同时兼顾全业务链路的合规适配性。

2、组建评估团队

生成式人工智能企业可自主开展网络数据安全风险评估，或委托专业的第三方机构实施评估。

（1）自行开展风险评估

若企业选择自行评估，应由首席安全官（CSO）或数据保护负责人（DPO）担任评估组长，并联合技术、法务、合规及业务部门组建专项评估团队，具体分工如下：

a) 评估组长

由 CSO/DPO 担任，负责统筹评估计划、协调资源并监督进度；确定评估范围（如训练数据管理、模型安全测试、生成内容审核等）；管理项目风险，推动整改措施落地。

b) 管理评估组

由法务、合规、数据治理等部门组成，负责：审查数据采集合规性（如用户授权协议、第三方数据使用条款）；核查模型训练日志、数据清洗记录及数据出境合规流程；评估 AI 生成内容的法律风险（如版权侵权、虚假信息传播责任）。

c) 安全技术组

由 AI 研发团队、安全运维团队及外部红队专家组成，负责：
数据安全测试：训练数据存储加密、数据去标识化有效性验证；
模型安全测试：对抗样本攻击检测、Prompt 注入防御能力评估；
系统渗透测试：API 接口安全、模型推理服务防 DDoS 测试；
生成内容审核机制测试：不适宜内容过滤、知识产权检测漏洞排查。

（2）委托第三方评估

若企业选择第三方评估，需确保机构具备以下能力：

AI 安全专项经验：熟悉大模型数据流、对抗攻击手法及生成内容风险；
合规评估资质：如 ISO 27001 等框架认证；
跨境数据合规能力：能适配《生成式人工智能服务管理暂行办法》等法规要求。

通过结构化团队分工，确保评估覆盖数据、模型、生成内容三大核心领域，同时满足技术安全与合规监管双重要求。

3、制定评估方案

开展网络数据安全风险评估前期准备时，应制定评估方案，方案内容包括但不限于如下各方面：

（1）评估概述：包括评估目标、评估依据等内容；

（2）评估范围：包括评估对象选择方法、评估对象描述、评估范围等；

（3）评估内容和方法：包括评估内容、评估准则、评估方法等内容；

（4）评估人员：包括评估团队的组织结构、负责人、成员、职责分工等内容；

（5）实施计划：包括时间进度安排、人员安排等内容；

（6）工作要求：包括评估工作要求、评估工作应急保障和风险规避措施、保密纪律等内容；

（7）测试方案：如需开展技术测试，应明确测试方案，包括采用的技术工具、测试内容、测试环境、应急措施等。

评估团队可邀请行业领域相关数据安全、网络安全专家对评估方案进行评议，重点审核方案内容、风险管控、保护措施、可

操作性、技术可行性等，进一步修改完善评估方案后，组织实施风险评估工作。

（二）信息调研

1、生成式人工智能企业基本情况调研

应全面调研生成式人工智能企业的法定及行业属性信息，包括但不限于：（具体调研表详见附录 1.1）：

（1）企业全称、统一社会信用代码、注册地址、法定代表人、员工规模、数据安全负责人及联系方式等基本信息；

（2）企业性质（如国有及国有控股企业、民营企业、外商（含港澳台）投资企业等）及商业模式（B2B 模型服务、B2C 应用产品、开源社区运营等）；

（3）是否属于特定类型数据处理者，如 1000 万人以上个人信息处理者、大型网络平台运营者等；

（4）核心业务类型，如文本生成、图像生成、音视频生成、多模态生成、代码生成等专业领域；

（5）主要业务指标，如日均 API 调用量、月活用户数、企业客户数量、年营收规模等；

（6）资本构成及实际控制人情况；

（7）境外融资或上市情况，包括 VIE 架构、外资持股比例

等。

2、生成式人工智能全业务链条及技术架构调研

生成式人工智能全业务链条及技术架构调研的内容包括但不限于（具体调研表详见附录 1.2）：

（1）模型名称。

（2）业务功能描述。

（3）适用人群：面向人群、适用场景、是否适用于未成年人用户。

（4）适用场合：是否为 To B（企业端）或 To C（消费端）、是否限定特定领域。

（5）业务用户规模

（6）服务入口：网页、PC 端、APP、微信小程序、支付宝小程序、百度小程序等。

（7）训练算力资源（自研模型）：训练服务器数量及 GPU 厂商、采用第三方云平台或服务器情况

（8）是否采用已备案模型：采用的模型名称、备案单位、备案时间、备案号。

3、生成式人工智能数据资产调研

生成式人工智能数据资产调研内容包括但不限于（具体调研

表详见附录 1.3)：

(1) 数据资产清单：训练数据集（规模、类型、来源）、模型资产（参数文件、配置文件）、用户交互数据（Prompt 记录、反馈数据）、运营数据（日志、监控数据）等。

(2) 数据范围：数据处理范围、个人信息、敏感个人信息、一般数据。

(3) 数据规模：用户数据收集范围、数据标注中涉及的个人信息、用户行为数据采集情况等。

(4) 数据分类分级：数据分类维度、主要数据类型、数据分级情况、数据分类分级制度文件等。

4、数据全生命周期处理活动调研

数据全生命周期处理活动调研的内容包括但不限于（具体调研表详见附录 1.4）：

(1) 数据收集：网络爬虫采集范围与合规性、用户数据获取方式与授权、第三方数据采购协议等。

(2) 数据存储：训练数据存储加密方案、模型参数保护措施、日志数据保留策略等。

(3) 数据传输：训练数据传输情况、API 接口安全防护等。

(4) 数据使用：数据标注流程规范、模型训练数据使用日

志、生成内容审核规则等。

（5）数据共享：模型开源策略、API 服务数据输出规范、第三方数据共享协议等。

（6）数据删除：训练数据销毁流程、用户数据删除机制、模型迭代时的旧版本处置等。

注：本调研框架可根据企业具体业务形态（如专注垂直领域或提供通用大模型）进行适当调整，重点覆盖生成式 AI 特有的数据安全风险点。

5、安全防护措施调研

安全防护措施情况调研的内容包括但不限于（具体调研表详见附录 1.5）：

（1）已开展的等级保护测评、商用密码应用安全性评估、算法安全评估备案情况、生成式人工智能服务（大语言模型）上线备案或登记、安全检测、风险评估、安全认证、合规审计情况，及发现问题的整改情况；

（2）数据安全组织、人员及制度情况；

（3）防火墙、入侵检测、入侵防御等网络安全设备及策略情况；

（4）身份鉴别与访问控制情况；

(5) 网络安全漏洞管理及修复情况;

(6) VPN 等远程管理软件的用户及管理情况;

(7) 设备、系统及用户的账号口令管理情况;

(8) 加密、脱敏、去标识化等安全技术应用情况;

(9) 3 年内发生的网络和数据安全事件、攻击威胁情况。如 3 年内发生的网络和数据安全事件、攻击威胁事件名称、数据类型和数量、发生原因、级别、处置措施、整改措施等, 重大事件需提供事件调查评估报告; 实际环境中通过检测工具、监测系统、日志审计等发现的威胁; 其他可能面临的数据泄露、窃取、篡改、破坏/损毁、丢失、滥用、非法获取、非法利用、非法提供等安全威胁。

(三) 风险识别

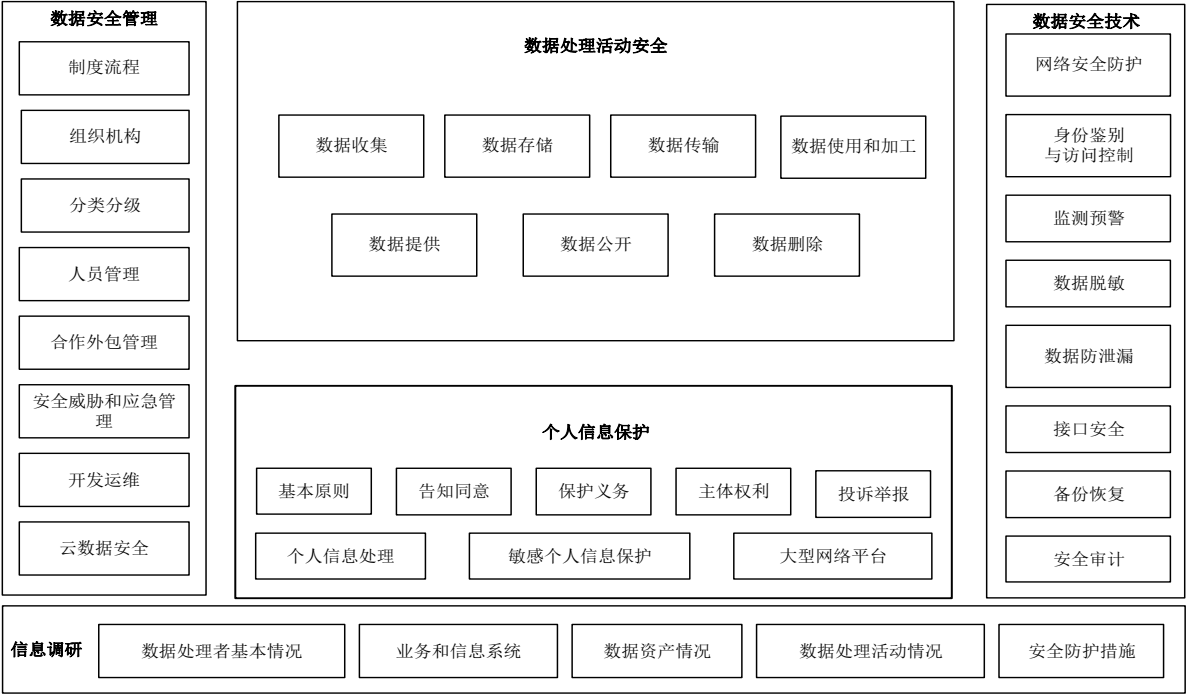
1、风险识别内容

网络数据安全风险评估内容框架如图所示, 涉及数据安全的管理、数据处理活动、数据安全技术、个人信息保护等方面。生成式人工智能企业可从数据安全的管理、数据处理活动、数据安全的技术、个人信息保护等方面进行数据安全风险识别, 发现可能存在的数据安全风险源。

根据生成式人工智能行业业务特点以及生成式人工智能行业数据处理活动情况, 生成式人工智能企业可参考附录 2 中风险

识别项开展风险识别并形成风险识别记录。

图1 网络数据安全风险评估内容框架



2、风险识别方法

开展网络数据安全风险识别使用的评估方法包括但不限于：

- （1）人员访谈：对相关人员进行访谈，核查制度规章、防护措施、安全责任落实情况；
- （2）文档查验：查验安全管理制度、风险评估报告、等保测评报告等有关材料及制度落实情况的证明材料；
- （3）安全核查：核查网络环境、数据库和大数据平台等相关系统和设备安全策略、配置、防护措施情况；
- （4）技术测试：应用技术工具、渗透测试等手段查看数据

资产情况、检测防护措施有效性。

（四）综合分析

1、风险分析

结合生成式人工智能企业数据资产和生成式人工智能企业数据全生命周期处理活动清单，针对每个评估对象的各个评估项的评估情况，梳理存在的风险隐患，形成数据安全问题清单。问题清单可包括但不限于以下内容：

（1）问题编号：对发现的数据安全风险源进行编号；

（2）问题类别：列出安全问题对应的类别，如数据安全管理工作、数据处理活动问题、数据安全技术问题、个人信息保护问题等；

（3）问题子类：列出数据安全问题的细分类别，如管理制度流程、安全组织架构、分类分级管理、人员安全管理等；

（4）问题描述：对所列数据安全问题项的具体情况展开描述，包括问题项涉及的数据资产、数据处理活动、业务、信息系统等；

（5）评估对象：该问题涉及的评估对象，如数据类型或级别、数据处理活动、业务、信息系统等；

（6）其他：结合实际情况，还可包含对应的评估项、备注说明等内容。

表2 数据安全问题清单

问题编号	问题类别	问题子类	问题描述	涉及的评估对象

基于梳理得出的数据安全问题清单，分析各项数据安全问题可能造成的安全风险（参考附录 3.1）。如多项数据安全问题可能造成同样的安全风险，可将相关问题合并成一项风险进行分析。在数据安全问题清单基础上补充风险相关信息，形成数据安全风险归类分析清单，清单格式见下表，主要补充以下内容。

（1）风险类型：填写数据安全风险归类分析的结果，如数据泄露风险。

（2）风险描述：填写可能导致的数据安全风险的具体情况，如某项、某几项或某类数据存在数据泄露风险。

表3 数据安全风险归类分析清单

问题编号	问题类别	问题子类	问题描述	风险类型	风险描述	涉及的评估对象

2、风险评价

基于梳理得出的数据安全风险归类分析清单，分析各项数据安全问题可能造成的安全风险，并进一步从风险的危害程度（参考附录 3.2）和风险发生的可能性（参考附录 3.3）两个维度，对数据安全风险进行评价（参考附录 3.4），形成数据安全风险清

单。

表4 数据安全风险清单

编号	风险类型	风险描述	风险危害程度	风险发生的可能性	风险等级	涉及的安全问题	涉及的评估对象

（五）评估总结

1、编制评估报告

根据评估情况，评估团队编制网络数据安全风险评估报告（报告主要内容样式详见附录4）并根据主管监管部门要求上报评估报告。

评估报告应准确、清晰地描述评估活动的主要内容（并附必要的证据或记录），提出可操作性的整改措施对策建议。风险评估报告的内容包括：

- （1）评估概述，包括评估目的及依据，评估对象和范围，评估结论等；
- （2）评估工作情况，包括评估人员、评估时间安排、评估工具和环境情况等；
- （3）信息调研情况，包括生成式人工智能企业基本情况、生成式人工智能全业务链条及技术架构、生成式人工智能数据资

产、生成式人工智能数据全生命周期处理活动、安全防护措施等，形成的数据资产清单、数据处理活动清单、数据流图等文件可视情放在报告正文或附件中；

（4）数据安全风险识别，包括数据安全治理、数据处理活动、数据安全技术、个人信息保护等方面识别的风险源情况；

（5）风险分析与评价，对数据安全问题可能带来的安全风险进行综合分析，视情对风险进行评价；

（6）整改建议，针对发现的数据安全问题或风险，提出整改措施或风险处置建议；

（7）数据安全风险源清单，列出完整的数据安全风险源清单，并附上关键记录和证据，若证据无法在附录中完整列出，应列出证据关键信息和序号，在提交评估报告时作为附件提交；

（8）委托第三方机构开展评估或检查评估的，评估报告应由评估组长、审核人签字，并加盖评估机构公章。

2、制定整改方案

结合实际情况，对发现的数据安全风险提出处置建议。高风险问题应立即完成整改，中低风险问题应制定风险处置方案，限期完成整改。无法及时完成整改的，应采取临时安全措施，防止数据安全事件发生。相应整改情况应保留记录，以便主管监管部门开展相关检查。

附录 1 信息调研表

附录 1.1 生成式人工智能企业基本情况调研表

表1-1 生成式人工智能企业基本情况调研表

生成式人工智能企业基本概况				
企业名称			统一社会信用代码	
办公地址			法定代表人	
数据安全负责人 和机构	姓名		职务	
	联系方式		数据安全管理机构名称	
企业性质	☐ 国有及国有控股企业 ☐ 民营企业 ☐ 外商（含港澳台）投资企业 ☐ 其他：			
商业模式	☐ B2B 模型服务 ☐ B2C 应用产品 ☐ 开源社区运营 ☐ 其他：			
是否属于特定属性数据处理者	☐ 1000 万人以上个人信息处理者 ☐ 大型网络平台运营者 ☐ 其他：			
人员规模	约 人			
经营范围	经营范围： 建议填写内容与营业执照一致。 主营业务： 建议参考营业执照的经营范围，概述主要业务。			
核心业务类型	☐ 文本生成 ☐ 图像生成 ☐ 音视频生成 ☐ 多模态生成 ☐ 代码生成 ☐ 其他：			

生成式人工智能行业网络数据安全风险评估工作手册

上级主管部门	主管部门一： 主管部门二：
业务运营地区， 开展数据处理活 动所在行政区划	☐ 全球 ☐ 全国 ☐ 省（自治区、直辖市） ☐ 地（区、市、州、盟） ☐ 县（区、市、旗） ☐ 其他：
主要业务指标	xxx 生成式人工智能企业的日均 API 调用量为 xxx、月活用户数为 xxx、企业客户数量为 xxx、年营收规模达到 xxx 等
开展数据业务的 依据文件、监管 文件、指导性文 件	《中华人民共和国网络安全法》 《中华人民共和国数据安全法》 《中华人民共和国个人信息保护法》 《上海市数据条例》
被评估单位的资 本组成和实际控 制人情况	【示例】 注册资本：80000 万 XXXXXX 公司：37.5% XXXXXX 公司：25%
是否境外上市或 计划赴境外上市	☐ 是，上市地区和交易所 ☐ 计划上市，计划上市地区和交易所 ☐ 以协议控制（VIE）架构等方式实质性境外上市 ☐ 否

附录 1.2 生成式人工智能全业务链条及技术架构调研表

表1-2 生成式人工智能全业务链条及技术架构调研表

生成式人工智能全业务链条及技术架构情况	
模型名称	
业务功能描述	
适用人群	面向 xxx 开放，适用于 xxx 场景。是/否适用未满 18 周岁的未成年人用户使用。
适用场合	具体说明： TOB: 适用于企业在xxx场景下提供xxx服务。 TOC: 面向公众开放，适用于xxx场景下提供xxx服务。 ☐未限定特定领域 ☐限定特定领域 具体说明：
业务用户规模	
推出时间	
服务入口	☐网页：_____ ☐PC：_____ ☐APP：_____【填写 APP 名称及版本】 ☐微信小程序：_____【填写小程序名称及版本】 ☐支付宝小程序：_____

	☐ 百度小程序：_____ ☐ 其他：_____ 业务访问 IP 地址：_____ 业务访问其他地址：_____
训练算力资源（自研模型）	训练服务器数量及 GPU 厂商：_____【填写 xx 张 xx 卡，xx 台服务器】 采用第三方云平台活服务器情况： ☐ 未采用 ☐ 采用，第三方单位名称：_____, 第三方单位性质： ☐ 外资 ☐ 民企 ☐ 国企 ☐ 事业单位，平台/服务器地点：_____ （境外地点说明国家/地区，境内地点详细到省，可填写多个地址。）
是否采用已备案模型	☐ 未采用 ☐ 采用，模型名称：_____, 备案单位：_____, 备案时间：_____, 备 案 号：_____, 采用方式： ☐ 商业合作 ☐ 开源免费

附录 1.3 生成式人工智能数据资产调研表

表1-3 生成式人工智能数据资产总体概况

生成式人工智能数据资产概况	
数据规模	截至 XXXX 年 XX 月 XX 日本单位处理*的数据总规模： TB，年增长量： TB（包括但不限于收集的用户数据、数据标注中涉及的个人信息以及用户行为数据） *处理包括：收集、存储、使用、加工、传输、提供、公开、删除等 核心数据总规模： TB，年增长量： TB 重要数据总规模： TB，年增长量： TB 个人信息总规模： MB、 条，年增长量： MB、 条 公共数据总规模： TB，年增长量： TB
数据范围	数据处理范围： ☐个人信息 ☐敏感个人信息 ☐一般数据 ☐其他：
数据分类分级	1.是否进行数据分类：☐是 ☐否 数据分类维度： 主要数据类型： 2.是否进行数据分级：☐是 ☐否 数据分为 级，分别为： 3.是否制定数据分类分级制度文件： ☐是，文件名称： ☐否

数据处理者应梳理结构化数据资产（如数据库表等）和非结构化数据资产（如图表文件等），摸清数据底数，输出数据资产清单。涉及范围包括但不限于生产环境、测试环境、备份存储环境、云存储环境、个人工作终端、数据采集设备终端等收集和产生的数据。涉及对象包括但不限于训练数据集（规模、类型、来源）、模型资产（参数文件、配置文件）、用户交互数据（Prompt记录、反馈数据）、运营数据（日志、监控数据）等。

表1-4 数据资产清单

数据资产清单									
序号	数据资产类型	内容描述	载体形式	数据规模	存储区域/信息系统	重要性描述			是否涉及数据出境
						用途	级别 (如涉及)	存储时效	
1									
...									

【说明】

1. “数据资产类型”：按照分类分级情况进行梳理，如个人信息、重要数据、核心数据、其他数据等类型。如涉及个人信息可按照《信息安全技术 个人信息安全规范》GB/T 35273-2020 填写。
2. “载体形式”：如音频文件、数据库表、日志文件等。
3. “数据规模”：以条目数或容量规模计算。

4. “存储区域”：数据存储的物理位置、逻辑位置、大数据中心位置、云存储位置。
5. “级别”：如已开展数据分类分级，则如实填写；若未开展则可不填。
6. “来源”：指数据如何收集或产生。
7. “用途”：指数据的收集目的和使用场景。
8. “是否涉及出境传输或访问”：指数据是否出境传输或被境外访问。

附录 1.4 数据全生命周期处理活动调研表

表1-5 数据全生命周期处理活动总体情况

数据全生命周期处理活动概况	
涉及的数据处理活动	1.涉及的个人信息处理活动 ☐数据收集 ☐数据存储 ☐数据使用 ☐数据加工 ☐数据传输 ☐数据提供 ☐数据公开 ☐数据删除 ☐数据出境 ☐不涉及，说明原因： _____ 2.涉及的敏感个人信息处理活动 ☐数据收集 ☐数据存储 ☐数据使用 ☐数据加工 ☐数据传输 ☐数据提供 ☐数据公开 ☐数据删除 ☐数据出境 ☐不涉及，说明原因： _____
数据处理活动基本情况	1.数据收集（网络爬虫采集范围与合规性、用户数据获取方式与授权、第三方数据采购协议等） 来源对象： _____ 收集目的： _____ 收集方式： _____ ☐相关系统或手段： _____ 收集渠道： _____ 收集频率： _____ ☐合同或协议： _____ ☐外部公共场所安装图像采集： _____

	2.数据存储（训练数据存储加密方案、模型参数保护措施、日志数据保留策略等） 存储位置：_____ 存储规模：____TB ____GB ____MB ☐备份位置：_____ ☐相关系统：_____ 3.数据使用（数据标注流程规范、模型训练数据使用日志、生成内容审核规则等） 使用目的：_____ 使用方式：_____ 使用场景：_____ ☐相关系统：_____ 4. 数据加工： 加工目的：_____ 加工方式：_____ 加工场景：_____ ☐相关系统：_____ 5.数据传输（物理计算节点之间，或与外部单位之间，API 接口安全防护） 传输方式：_____ ☐相关系统：_____ 6. 数据提供（模型开源策略、API 服务数据输出规范、第三方数据共享协议等）：
--	--

	提供对象: _____ 提供目的: _____ 提供方式: _____ 提供依据: _____ 提供频率: _____ ☐相关系统: _____ 7.数据公开: 公开对象与范围: _____ 公开目的: _____ 公开方式: _____ 公开依据: _____ ☐相关系统: _____ 8. 数据删除 (训练数据销毁流程、用户数据删除机制,模型迭代时的旧版本处置等) 删除目的: _____ 删除方式: _____ 删除或不删除的相关依据: _____ ☐相关系统: _____
关键数据处理 活动	1.数据存储位置 (多选): ☐自建机房 ☐外部租赁 IDC 机房 ☐租赁云存储服务, 品牌为: _____ ☐涉及数据在境外存储的情况 ☐其他: _____ 2.数据使用的目的包括:

	☐向个人/非个人用户提供服务，具体为：_____ ☐支撑机构内部生产、运营，具体为：_____ ☐实现统计、分析，具体为：_____ ☐科学研究，具体为：_____ ☐其他：_____ 3.数据加工情况（多选）： ☐机构内部自行开展数据加工 ☐委托外部机构进行数据加工，被委托方：_____ ☐未进行任何形式的数据加工 ☐其他：_____ 4.数据提供情况（多选）： ☐因为本身业务的目的是向外部单位提供数据_ ☐委托第三方进行数据处理 ☐数据交易，涉及的数据类型：☐个人信息，☐重要数据，☐其他 ☐其他：_____ 5.数据公开情况： 公开渠道：_____公开数据内容：_____ 6.数据出境情况： ☐有数据出境情况，出境数据包含重要数据 ☐有数据出境情况，出境数据不包含重要数据 ☐无数据出境情况
--	---

第三方外包服务 机构接触数据情况	☐ 个人信息 ☐ 敏感个人信息 ☐ 关键业务数据 ☐ 其他：_____
第三方外包服务 机构涉及的数据处理活动	☐ 数据收集 ☐ 数据存储 ☐ 数据使用 ☐ 数据加工 ☐ 数据传输 ☐ 数据提供 ☐ 数据公开 ☐ 数据删除 ☐ 数据出境 ☐ 不涉及，说明原因：_____

针对数据资产清单中的内容，逐项说明数据收集情况。如数据收集渠道、收集方式、数据范围、收集目的、收集频率、外部数据源、合同协议、相关系统，以及在被评估方外部公共场所安装图像采集、个人身份识别设备的情况等。

表1-6 数据收集情况

数据收集情况								
序号	数据类型	具体内容（简写关键字段）	收集渠道	收集方式	收集目的	收集频率	数据量	日增量
1								
...								

数据存储情况包括数据存储方式、数据中心、存储系统（如数据库、大数据平台、云存储、网盘、存储介质等）、外部存储机构、存储地点、存储期限、备份冗余策略等。

表1-7 数据存储情况

数据存储情况	
数据存储方式 (可多选)	☐ 集中存储 ☐ 分布式存储 ☐ 分类分级存储 ☐ 其他: _____
数据量	统计截至时间: _____ ☐ 数据总量: _____ ☐ 日均增量: _____ ☐ 用户数据量: _____ ☐ 用户数据日均增量: _____ ☐ 在线数据量: _____ ☐ 离线数据量: _____
存储所在地	【填写包括云环境、数据机房、数据中心等物理地址】
存储系统 (可多选)	☐ 数据库, 数据库类型: _____ ☐ 大数据平台: _____ ☐ 云存储, 存储产品类型: _____ ☐ 网盘, 网盘提供商: _____ ☐ 存储介质, 介质类型: _____ ☐ 外部存储机构: _____ ☐ 其他: _____
数据备份所在地	【填写包括同城备份地方、主备份地方、异地备份地方】
数据备份方式 (可多选)	☐ 全量备份 ☐ 增量备份 ☐ 差异备份 ☐ 镜像备份 ☐ 实时备份 ☐ 定期备份 ☐ 冗余备份
安全防护措施 (可多选)	☐ 采取了保密性措施, 国产密码技术, 加密算法: _____ ☐ 采取了完整性措施, 国产密码技术, 加密算法: _____ ☐ 日志审计 ☐ 访问控制 ☐ 脱敏/去标识化

	☐ 身份鉴别	☐ 数据分类分级存储	☐ 其他
--	-------------------------------	-----------------------------------	-----------------------------

数据传输情况包括数据传输途径和方式（如互联网、VPN、物理专线等在线通道情况，采用介质等离线传输情况）、传输协议、内部数据共享、数据接口等，传输包括对外传输和对内传输，均需梳理数据传输方式。

表1-8 数据传输情况

数据传输情况					
序号	传输数据类型	传输途径和方式	源传输节点	目的传输节点	传输协议
1					
...					

数据使用和加工情况包括数据使用目的、方式、范围、场景、算法规则、相关系统和部门，数据清洗、转换、标注等加工情况，应用算法推荐技术提供互联网信息服务的情况，核心数据、重要数据或个人信息委托处理、共同处理的情况等。

表1-9 数据使用情况

数据使用情况							
序号	应用场景	数据类型	数据来源	使用目的	使用方式	负责部门	是否对外发布
1							

...							
-----	--	--	--	--	--	--	--

表1-10 应用算法推荐技术情况

应用算法推荐技术情况						
序号	算法推荐类型	应用场景	用户特征使用的 数据字段	数据来源	调用更新 频率	是否上报互联网信息服务算 法备案系统
1						
...						

数据加工情况包括数据清洗、转换、标注等加工情况，是否对外委托加工等。

表1-11 数据加工情况

数据加工情况					
序号	加工数据类型	加工目的	加工方式	加工场所	是否委托加工
1					
...					

数据提供情况包括数据提供(数据共享、数据交易，因合并、分立、解散、被宣告破产等原因需要转移数据等)的目的、方式、范围、数据接收方、合同协议，对外提供的个人信息和重要数据的种类、数量、范围、敏感程度、保存期限等。

表1-12 数据提供情况

数据提供情况									
序号	数据接收方	提供方式	提供目的	提供频率	数据字段	数据量	涉及的业务	用户是否单独同意	是否签订合同协议
1									
...									

数据公开情况，如数据公开的目的、方式、对象范围、受众数量、行业、组织、地域等。

表1-13 数据公开情况

数据公开情况								
序号	公开数据类型	目的	方式	对象范围	受众数量	所属行业	公开组织	所处地域
1								
...								

数据删除情况包括数据删除情形、删除方式、数据归档、介质销毁等。

表1-14 数据删除情况

数据删除情况				
数据类型	删除情形	删除方式	能否恢复	数据归档
1				

...				
-----	--	--	--	--

数据出境情况包括是否存在个人信息或重要数据出境，如跨境业务、跨境办公、境外上市、使用境外云服务或数据中心、国际交流合作等场景的数据出境情况。数据出境方式包括但不限于使用境外云服务、员工和用户境外远程访问、企业跨境专线、境外缓存加速、境外第三方机构认证、境外机构数据合作等。

表1-15 数据出境情况

数据出境情况						
序号	出境数据类型	数据量	出境目的	出境方式	用户是否单独同意	是否通过出境评估
1						
...						

数据共同处理、委托处理情况包括是否存在涉及个人信息、重要数据等其他数据共同处理、委托处理的场景，是否约束数据处理双方数据安全责任义务、数据处理活动安全保护措施及对数据处理活动进行监督等相关合法合规情况。

表1-16 数据共同处理、委托处理情况

数据共同处理、委托处理情况	
共同处理	☐ 有涉及 ☐ 未涉及

	1.共同处理数据类型： ☐个人信息 ☐个人敏感信息 ☐企业数据 ☐公共数据 ☐重要数据 ☐行业数据： _____ ☐其他： _____ 2.共同处理场景： _____ 3.共同处理单位名称： 单位名称1： _____ (1) 共同处理单位性质： ☐国有及国有控股企业 ☐事业单位 ☐民营企业 ☐外资（含港澳台）投资企业 ☐其他： _____ (2) 共同处理职责划分： 共同处理场景： _____ 共同处理分工： _____ (3) 双方数据安全权利和义务说明： ☐合同协议 ☐合作协议 ☐数据安全协议 ☐其他： _____ (4) 个人信息保护能力： ☐设立个人信息保护责任人及岗位 ☐个人信息保护制度 ☐个人信息分类分级 ☐个人信息加密处理 ☐其他： _____ 单位名称2： _____ (1) 共同处理单位性质： ☐国有及国有控股企业 ☐事业单位 ☐民营企业
--	---

	☐外资（含港澳台）投资企业 ☐其他： (2) 共同处理职责划分： 共同处理场景：_____ 共同处理分工：_____ (3) 双方数据安全权利和义务说明： ☐合同协议 ☐合作协议 ☐数据安全协议 ☐其他：_____ (4) 个人信息保护能力： ☐设立个人信息保护责任人及岗位 ☐个人信息保护制度 ☐个人信息分类分级 ☐个人信息加密处理 ☐其他：_____
委托处理	☐有涉及 ☐未涉及 1.涉及个人信息的委托处理 ☐个人信息：_____ 【参照GB/T 35273-2020写明个人信息类型】 ☐个人敏感信息：_____ (1) 委托处理数据来源：_____ (2) 委托处理使用场景： ☐数据收集 ☐数据存储 ☐数据使用 ☐数据加工 ☐数据传输 ☐数据提供 ☐数据公开 ☐数据删除 ☐数据出境 (3) 委托处理接收方： 接收方名称1：_____ 接收方名称2：_____

	接收方名称3: _____ 其他: _____ (4) 用户告知同意方式: ☐告知同意链接 ☐告知同意纸质说明 ☐告知同意点击动作留存记录 ☐其他: _____ (5) 委托处理双方数据安全权利和义务说明: ☐合同协议 ☐合作协议 ☐数据安全协议 ☐其他: _____ (6) 受托方数据处理活动监督措施说明: _____ 2.涉及其他数据的委托处理 (1) 数据类型: ☐企业数据 ☐公共数据 ☐行业数据: _____ ☐其他: _____ (2) 委托处理使用场景: ☐数据收集 ☐数据存储 ☐数据使用 ☐数据加工 ☐数据传输 ☐数据提供 ☐数据公开 ☐数据删除 ☐数据出境 (3) 委托处理接收方: 接收方名称1: _____ 接收方名称2: _____ 接收方名称3: _____ 其他: _____
--	--

附录 1.5 安全防护措施调研表

表1-17 已开展的安全测评总体概况

已开展的安全测评概况	
测评类 (可多选)	☐网络安全等级保护测评 ☐关键信息基础设施安全检测评估 ☐商用密码应用安全性评估 ☐网络数据安全风险评估 ☐个人信息保护影响评估 ☐个人信息安全合规性评估（依据国家标准 GB/T 35273-2020） ☐移动互联网应用程序个人信息安全测评 ☐数据出境安全评估 ☐云计算服务安全评估 ☐互联网新闻信息服务新技术新应用安全评估 ☐具有舆论属性或社会动员能力的互联网信息服务安全评估 ☐互联网信息服务算法备案 ☐生成式人工智能服务备案、登记 ☐深度合成服务算法备案 ☐其他：
认证类 (可多选)	☐数据安全管理体系认证（DSM） ☐个人信息保护认证 ☐APP 安全认证 ☐其他：_____

表1-18 已开展的安全测评具体情况

已开展的安全测评具体情况				
序号	证书/报告名称	认证/测评单位	认证/测评时间	认证/测评范围
1				

已开展的安全测评具体情况				
序号	证书/报告名称	认证/测评单位	认证/测评时间	认证/测评范围
...				

表1-19 数据安全管理和人员配置情况

数据安全管理和人员配置情况				
数据安全负责人和机构	负责人姓名		负责人职务	
	负责人联系方式		数据安全管理机构名称	
	数据安全管理机构岗位及配备人员数量	岗位 1 名称: XXXXXX ; 配备人员: XXXX 人; 岗位 2 名称: XXXXXX ; 配备人员: XXXX 人; 岗位 3 名称: XXXXXX ; 配备人员: XXXX 人;		

表1-20 数据安全管理制度情况

数据安全管理制度情况		
序号	文档名称（下为示例）	主要内容
1	数据安全总体策略	
2	数据安全管理工作规划或方案	
3	数据分类分级制度	
4	数据分类分级保护制度	

数据安全管理制度情况		
序号	文档名称（下为示例）	主要内容
5	数据安全管理制度	
6	数据安全评估制度	
7	数据访问权限管理制度	
8	数据安全应急响应制度	
9	数据安全应急预案	
10	数据安全培训计划与记录	
11	数据安全考核及监督问责制度	
12	数据安全关键岗位的数据安全 操作规程	
13	关键岗位人员管理材料	
14	个人信息保护内部管理制度	
15	个人信息影响评估制度	
16	个人信息应急预案	
17	外包服务管理制度	
18	开发运维管理制度	

表1-21 网络和数据安全事件情况（3年内）

网络和数据安全事件情况（3年内）				
序号	事件名称	发生时间	事件内容简述	事件处置情况及结果
1				
...				

从网络架构、网络边界、数据处理活动生命周期等层面涉及的防护措施的描述。如 WAF，为应用系统提供网络安全防护；动态数据脱敏系统，实现了敏感信息的自动化识别和脱敏处理。

表1-22 网络和数据安全主要措施

网络和数据安全主要措施		
序号	防护措施	措施简述
1		
...		

附录 2 风险识别表

附录 2.1 生成式人工智能服务基础风险识别表

附录 2.1.1 数据安全管理制度评估表

表2-1 安全管理制度评估表

安全子类	识别要素	评估方法	判定依据
数据安全制度体系	a) 数据安全总体策略、方针、目标和原则制定情况;	人员访谈 文档查验	1) 访谈相关人员, 询问数据安全策略、方针、目标和原则的制定情况; 2) 查看数据安全策略方面的相关文档, 是否包含数据安全策略, 明确以数据为核心的数据安全制度和规程, 覆盖数据生存周期相关的业务、系统和应用, 内容包含目标、范围、岗位、责任、内外部协调机制等。
	b) 数据安全管理工作规划或工作方案制定情况;	人员访谈 文档查验	1) 访谈相关人员, 询问数据安全管理工作规划或工作方案制定情况; 2) 查看数据安全管理工作规划或工作方案, 是否明确安全工作中长期工作目标、内容和计划安排。方案是否明确安全工作中长期工作目标、内容和计划安排。
	c) 数据分类分级、数据安全评估、数据访问权限管理、数据全生命周期管理、数据安全应急响应、数据合作方管理、数据脱敏、数	人员访谈 文档查验	1) 访谈相关人员, 询问制定了哪些数据安全相关的制度; 制定了数据分类分级、数据安全评估、数据访问权限管理、数据全生命周期管理、数据安全应急响应等制度文件; 2) 查看制度文件, 制度文件是否包括数据分类分级、数据安全评估、数据访问权限管理、数据全生命周期管理、数据安全应急响应、数据合作方管理、数据脱敏、数据加密、数据安全审计、数据资产管理、大数据平台安全等方面内容。

安全子类	识别要素	评估方法	判定依据
	据加密、数据安全审计、数据资产管理、大数据平台安全等制度或要求建设情况；		
	d) 关键岗位的数据安全管理操作规程建设情况；	人员访谈 文档查验	1) 访谈相关人员，询问数据安全关键岗位设置情况，对关键岗位人员的管理情况以及是否建立关键岗位的相关制度文件，例如数据安全操作规程； 2) 查看关键岗位的数据安全操作规程，验证是否明确对数据安全关键岗位人员的相关要求。
	e) 制度内容与国家和行业数据安全法律法规和监管要求的符合情况。	人员访谈 文档查验	1) 访谈相关人员，询问相关文件制定的依据是什么，行业主管部门是否有相关指导性文件，例如分类分级、重要数据目录、数据安全保护要求等； 2) 查看所制定的制度要求，并结合后续风险识别项，判定相关制度要求是否与国家或行业数据安全法律法规和监管要求一致。例如： 涉及个人信息的，查看是否依据《中华人民共和国个人信息保护法》、GB/T 35273-2020《信息安全技术 个人信息安全规范》等个人信息保护相关法律法规和标准要求，制定组织统一的个人信息保护制度； 涉及重要数据的，查看是否依据《中华人民共和国数据安全法》等国家和行业数据安全法律法规和监管要求，建立组织统一的重要数据全生命周期保护的制度和管控措施。
数据安全	a) 网络安全责任制、数据	人员访谈 文档查验	1) 访谈相关人员，询问网络和数据安全责任制建设情况，是否明确工作责任人或责任部门，规范网络和数据

安全子类	识别要素	评估方法	判定依据
制度落实	安全责任制落实情况，网络安全和数据安全事件责任查处情况；		安全工作职责、流程和安全事件责任查处等要求； 2) 访谈相关人员，是否建立并实施网络和数据安全考核及监督问责机制； 3) 查看相关制度文件及记录文件，查验是否明确相关要求，是否按照制度执行。
	b) 数据安全制度的制定、评审、发布流程建设情况；	人员访谈 文档查验	1) 访谈相关人员，了解数据安全制度的制定、评审、发布流程建设情况；相关制度文件是否明确了数据安全制度及规程的评审、发布流程，并确定适当的频率和时机对制度和规程进行审核和更新；是否将数据安全相关策略、制度和规程等文件分发至组织相关部门、岗位和人员； 2) 查看相关制度文件、发布记录和签收记录等材料，查验是否有制度明确规定，是否按照制度执行。
	c) 数据安全制度的定期审核和更新情况；	人员访谈 文档查验	1) 访谈相关人员，询问数据安全制度的定期审核和更新情况； 2) 查看相关制度文件和评审记录等材料，查验是否明确数据安全制度和规程进行审核流程和更新频率，并遵照制度执行。
	d) 制度发布范围是否覆盖全面，发布方式是否正规、有效；	人员访谈 文档查验	1) 访谈相关人员，询问是否明确数据安全制度规程分发机制； 2) 访谈相关人员，询问发布范围是否覆盖涉及的所有组织相关部门、岗位和人员； 3) 查看相关制度文件、发布记录和签收记录等材料，查验是否有制度明确规定，是否按照制度执行。
	e) 数据安全制度落实情况，是否具备	人员访谈 文档查验	1) 结合数据安全制度体系(c)核查结果，访谈相关人员，了解这些数据安全制度的落实情况； 2) 查看记录表单等文件，查验是否按照制度执行，并

安全子类	识别要素	评估方法	判定依据
	操作规程、记录表单等制度落实证明材料；		留有相关记录。
	f) 制度落实监督检查机制；	人员访谈 文档查验	1) 访谈相关人员，询问是否建立针对数据安全的监督检查机制，定期对数据安全制度和规程的落实情况进行监督检查； 2) 查看相关文档和检查记录表，查验是否明确对数据安全制度的监督检查要求，是否定期开展了监督检查。

表2-2 安全组织机构评估表

安全子类	识别要素	评估方法	判定依据
数据安全组织架构	a) 数据安全管理机构 and 职能设置情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否建立了数据安全管理机构，相关制度中是否明确了机构内各岗位的职责； 2) 查看相关文档，验证是否建立了数据安全管理机构，并明确各岗位的职责。 3) 针对重要数据处理者，数据安全机构的岗位职责是否包括以下内容： 研究提出数据安全相关重大决策建议； 制定实施数据安全保护计划和数据安全事件应急预案； 开展数据安全风险监测，及时处置数据安全风险和事件； 定期组织开展数据安全宣传教育培训、风险评估、应急演练等活动； 受理、处置数据安全投诉、举报； 按照要求及时向网信部门和主管、监管部门报告数据安全情况。

安全子类	识别要素	评估方法	判定依据
	b) 数据安全负责人和职能设置情况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否设立了数据安全负责人, 相关制度中是否明确了该负责人的岗位职责; 2) 查看相关文档, 是否通过正式文件的形式任命数据安全负责人, 并在制度或文件中明确该负责人的岗位职责。
	c) 单位高层人员参与数据安全决策情况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否由单位高层人员(单位正职或副职)担任数据安全负责人, 并参与相关数据安全决策工作; 2) 查看相关文档, 查看组织架构和岗位职责等相关文档, 验证制度文件中是否明确了相关内容。
	d) 对组织内部的数据安全管理执行情况、数据操作行为等进行安全监督的情况;	人员访谈 文档查验	1) 访谈相关人员, 是否明确规定由特定部门或人员负责对组织内部的数据安全管理执行情况、数据操作行为等进行安全监督。 2) 查看相关文档, 查验组织架构中是否明确承担安全监督职责的部门或人员, 并按照规定定期开展安全监督工作。
	e) 数据安全人员和资源投入情况与组织数据安全保护需求适应性。	人员访谈	访谈相关人员, 了解数据安全管理机构人员配置和资源投入情况, 并查看组织数据安全总体策略文件, 判断现有人员配置及资源投入是否能满足组织发展规划和数据安全保护的需求。
数据安全岗位设置	a) 数据库管理员、操作员及安全审计人员、安全运维人员、数据备份管理人	人员访谈	访谈相关人员, 询问是否配备了数据库管理员、操作员及安全审计人员、安全运维人员、数据备份管理人员、数据恢复管理人员等数据安全关键岗位人员。

安全子类	识别要素	评估方法	判定依据
	员、数据恢复管理人员等；		
	b) 数据安全关键岗位设置情况，及职责分离、专人专岗等原则落实情况；	人员访谈 文档查验	1) 查看相关文档，制度文件中是否明确了数据安全关键岗位的职责，例如数据库管理员、操作员及安全审计人员、安全运维人员等； 2) 访谈相关人员，管理员、操作员及安全审计人员是否实现了职责分离，专人转岗。
	c) 业务部门、信息系统建设部门、信息系统运维部门数据安全人员设置情况，数据安全管理要求执行情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否在业务、信息系统建设、信息系统运维等接触数据的部门设立了数据安全岗位，了解其工作内容和工作职责。 2) 查看相关文档，这些部门的数据安全人员是否按照岗位职责，执行管理制度要求。
	d) 特权账户所有者、关键数据处理岗位等数据安全关键岗位设立双人双岗情况。	人员访谈 文档查验	1) 访谈相关人员，询问特权账户所有者、关键数据处理岗位等数据安全关键岗位是否设立了双人双岗； 2) 查看相关文档，是否明确了相关内容。

表2-3 分类分级管理评估表

安全子类	识别要素	评估方法	判定依据
数据	a) 数据资产	人员访谈	1) 访谈相关人员，询问是否对数据资产进行登记管

安全子类	识别要素	评估方法	判定依据
资产管理	台账建设、更新、维护情况；	文档查验	理，并形成数据资产台账；是否对数据资产台账的更新、维护建立相关制度，包括更新周期、维护流程、责任部门等； 2) 查看相关文档，查看是否制定了相关制度，明确了相关要求。
	b) 数据资产梳理是否全面，是否能够覆盖数据库、大数据存储组件、云上对象存储或网盘等存储工具及办公计算机、U 盘、光盘等存储介质中的数据；	人员访谈 文档查验	1) 访谈相关人员，了解数据资产梳理的方法和范围； 2) 查看数据资产台账记录，数据资产梳理是否全面，是否能够覆盖数据库、大数据存储组件、云上对象存储或网盘等存储工具及办公计算机、U 盘、光盘等存储介质中的数据。
	c) 通过数据资产管理等工具对数据资产清单及时更新、维护的情况；	人员访谈 安全核查	1) 访谈相关人员，是否通过技术工具实现对数据资产的统一管理； 2) 核查相关管理工具，查看该管理工具具备哪些功能，是否能满足对数据资产的更新、维护的需求。
	d) 采用技术手段定期对数据资产进行扫描的情况，及发现识	人员访谈 安全核查	1) 访谈相关人员，是否通过技术手段定期对数据资产进行扫描； 2) 核查相关探测/管理工具，查看该管理工具通过何种方式扫描发现数据资产(例如网络流量分析、数据库扫描等)，是否具备发现识别个人信息、重要数据的能力。

安全子类	识别要素	评估方法	判定依据
	别个人信息、重要数据的能力。		
数据分类分级制度	a) 数据分类分级保护制度建设情况，是否符合国家、行业 and 地方的数据分类分级规范要求；	人员访谈 文档查验	1) 访谈相关人员，询问是否制定了数据分类分级保护制度，制度内容包括方法、定义、相应级别保护措施等，并询问制度制定的依据有哪些，是否有国家行业主管部门发布的相关分类分级识别指南等政策文件。 2) 查看相关文档，并对照标准国家、行业 and 地方的数据分类分级规范要求，例如 GB/T 43697-2024《数据安全 数据分类分级规则》、JR/T 0197-2020《金融数据安全 数据安全分级指南》、《汽车数据安全 安全管理若干规定（试行）》等，查验分类分级规则与保护要求是否与国家规范要求能够相互衔接。
	b) 数据分类分级管理情况，及核心数据和重要数据目录建立及维护情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否按照组织内部制定的数据分类分级规则进行了识别，并定期进行维护，是否存在重要数据或核心数据，若存在，则是否建立了核心数据和重要数据目录。 2) 若存在重要数据或核心数据，查验是否对这些数据建立目录。
	c) 是否在相关制度中明确了数据分类管理、分级保护策略，数据分类分级保护措施是否落实在数据访问权限申请、保护措	文档查验	查验相关制度文件，是否在相关制度中明确数据分类管理、分级保护策略，分级保护策略是否依据数据资产和数据主体安全分级要求建立相应的标记策略、访问控制、数据加解密、数据脱敏等安全机制和管控措施。

安全子类	识别要素	评估方法	判定依据
	施部署等方面；		
	d) 数据分类分级变更和审核流程情况；	文档查验	1) 查验相关制度文件，是否明确数据分类分级变更和审核流程； 2) 查验相关记录，是否按照制度流程要求落实数据分类分级变更和审核工作。
	e) 个人信息分类分级管理情况。	人员访谈 文档查验	1) 访谈相关人员，询问是否对涉及个人信息的数据单独划分一类，明确标识出数据资产中的个人信息，并设置对应的安全级别； 2) 查验相关文档，是否对个人信息进行了分类分级管理。
数据分类分级保护	a) 是否对处理的个人信息和重要数据进行明确标识；	文档查验	若评估对象涉及个人信息或重要数据，则查看相关数据资产台账记录，是否对在处理活动中可能涉及的个人信息和重要数据进行了明确标识。
	b) 按照数据级别建设覆盖全流程数据处理活动的安全措施情况；	文档查验 安全核查	1) 查验相关数据分类分级安全管理制度，是否明确按照数据级别建设覆盖如采集、存储、传输等全流程数据处理活动的安全措施； 2) 结合数据处理活动、数据安全技术等方面核查结果，核验制度落实情况，是否与制度要求保持一致。
	c) 数据分类分级标识或数据资产管理工具建设情况，是否具有自动化标识能力，是否	安全核查	核查相关数据资产管理工具，是否具有自动化标识能力，以及是否具有数据标识结果发布、审核等功能。

安全子类	识别要素	评估方法	判定依据
	具有数据标识结果发布、审核等能力；		

表2-4 人员安全管理评估表

安全子类	识别要素	评估方法	判定依据
人员录用	a) 重要岗位员工录用前背景调查情况；	人员访谈 文档查验	1) 访谈相关人员，询问重要岗位员工录用前背景调查情况； 2) 文档查验。查看已录用重要岗位人员的背景调查记录。
	b) 数据处理关键岗位人员录用，对其数据安全意识或专业能力进行考核的情况。	人员访谈 文档查验	1) 访谈相关人员，询问是否对数据处理关键岗位人员进行安全意识和专业能力考核； 2) 核查相关制度，是否明确对数据处理关键岗位人员进行安全意识和专业能力考核的要求，并查看已录用重要岗位人员的考核记录。
保密协议	a) 员工工作纪律和工作要求中是否明确规定员工禁止的数据安全相关行为；	人员访谈 文档查验	1) 访谈相关人员，询问员工工作纪律和工作要求中是否明确规定员工禁止的数据安全相关行为； 2) 查看相关文档，相关制度文件是否明确规定员工禁止的数据安全相关行为。
	b) 是否与所有涉及数据服务的人员签订安全责	人员访谈 文档查验	1) 访谈相关人员，询问是否与所有涉及数据服务的人员签订安全责任承诺或保密协议，与数据安全关键岗位人员签订数据安全岗位责任协议； 2) 查看相关制度文件，查验是否有相关内容，并核查

安全子类	识别要素	评估方法	判定依据
	任承诺或保密协议，与数据安全关键岗位人员签订数据安全岗位责任协议；		协议记录确认制度是否落实。
	c) 在重要岗位人员调离或终止劳动合同前，是否明确并告知其继续履行有关信息的保密义务要求，并签订保密承诺书。	人员访谈 文档查验	1) 访谈相关人员，在重要岗位人员调离或终止劳动合同前，是否明确并告知其继续履行有关信息的保密义务要求，并签订保密承诺书； 2) 查看相关制度文件，查验是否有相关内容，并核查协议记录确认制度是否落实。
转岗 离岗	a) 在人员转岗或离岗时，是否及时终止或变更完成相关人员数据操作权限，并明确有关人员后续的数据保护管理权限和保密责任；	人员访谈 文档查验	1) 访谈相关人员，在人员转岗或离岗时，是否及时终止或变更完成相关人员数据操作权限，并明确有关人员后续的数据保护管理权限和保密责任； 2) 查看相关人员转岗离岗制度和人员保密协议，是否明确转岗离岗后数据保护管理权限和保密责任等相关内容。
	b) 对终止劳	人员访谈	1) 访谈相关人员，对终止劳动合同的人员，是否及时

安全子类	识别要素	评估方法	判定依据
	动合同的人员，是否及时终止并收回其系统权限及数据权限，明确告知其继续履行有关信息的保密义务要求。	文档查验	终止并收回其系统权限及数据权限，明确告知其继续履行有关信息的保密义务要求； 2) 查看相关人员离职制度和人员保密协议，是否明确离职后数据保护管理权限和保密责任等相关内容。
数据安全培训	a) 数据安全培训计划制定、更新情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否针对数据安全培训工作有相关的制度，并制定了年度培训计划； 2) 查看相关制度文件及培训计划，是否明确了培训相关内容及要求。
	b) 开展数据安全意识教育培训，并保留相关记录情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否开展了数据安全意识教育培训； 2) 查看相关培训记录，开展数据安全意识教育培训，并保留了相关培训记录。
	c) 是否对数据安全岗位人员每年至少进行1次数据安全专项培训，对关键岗位人员进行定期数据安全技能考核情况。	人员访谈 文档查验	1) 访谈相关人员，询问是否对数据安全岗位人员每年至少进行1次数据安全专项培训，是否对关键岗位人员进行定期数据安全技能考核； 2) 查看相关制度文件和培训记录，制度是否有相关规定，考核记录证实落实了相关制度要求。

表2-5 合作外包管理评估表

安全子类	识别要素	评估方法	判定依据
合作 方管 理机 制	a) 数据合作方安全管理机制建设情况, 如对合作方或外包服务机构的选 择、评价、管 理、监督机 制;	人员访谈 文档查验	1) 访谈相关人员, 询问是否建立外包服务管理制度; 2) 查看相关制度文件, 制度中是否包括对合作方或外 包服务机构的选择、评价、管理、监督机制等内容。
	b) 是否对数 据合作方或 外包服务机 构的安全能 力进行评估;	人员访谈 文档查验	1) 访谈相关人员, 询问是否对数据合作方或外包服务 机构的安全能力进行评估; 2) 查看相关制度文件, 制度中是否对数据合作方或外 包服务机构的安全能力进行评估的相关要求, 并明确 评估的内容。
	c) 对外包服 务机构、人 员履行安全 责任义务的 监督检查情 况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否在相关制度文件中合同明 确对外包服务机构、人员履行安全责任义务进行安全 检查的要求; 2) 查看相关制度文件, 制度中是否有对外包服务机 构、人员开展安全监督的要求, 并明确监督检查内容; 核验相关记录, 确认制度是否落实。
	d) 外包人员 现场服务安 全管理情 况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否在外包人员现场服务的 情况, 对其采取了哪些安全管理措施; 2) 查看相关制度文件, 制度中是否明确了对外包人 员现场服务的管理要求, 并严格落实制度要求, 管理 措施可能包括进去区域、网络访问、权限控制、操 作规范等。
	e) 对外包服 务商的技术	人员访谈	1) 访谈相关人员, 询问外包服务商负责哪些技术 性工作, 相关工作是否有本单位人员参与, 对于交 由外包服

安全子类	识别要素	评估方法	判定依据
	依赖程度，对委托处理数据的控制和管理能力。		务商处理的工作是否控制和约束力； 2) 查看相关制度文件，制度中是否明确了对外包人员现场服务的管理要求，并严格落实制度要求，管理措施可能包括进去物理区域、网络访问、数据访问、权限控制、操作规范等。
合作协议约束	a) 服务合同、承诺及安全保密协议情况，是否通过合同协议等方式对接收、使用本单位数据的合作方的数据使用行为进行约束；	人员访谈 文档查验	查验相关合同、承诺书、安全协议等文件，检查是否对接收、使用本单位数据的合作方的数据使用行为进行约束，其约束内容包括哪些。
	b) 是否在合作协议中明确了数据处理目的、方式、范围，安全保护责任、数据返还或销毁要求、保密约定及违约责任和处罚条款等；	人员访谈 文档查验	查验相关合作协议文件，检查是否明确了数据处理目的、方式、范围，安全保护责任、数据返还或销毁要求、保密约定及违约责任和处罚条款等内容。
	c) 合同、协议中，数据处理	人员访谈 文档查验	查验相关合作协议文件，检查是否明确了数据处理者与合作方、外包服务商间的数据安全责任界定，具体是

安全子类	识别要素	评估方法	判定依据
	者与合作方、外包服务商间的数据安全责任界定情况。		如何划分的。
外包人员访问权限	a) 外包人员对数据与系统的访问、修改权限是否限于最小必要范围；	人员访谈 安全核查	1) 访谈相关人员，询问外包人员对数据与系统的访问情况，了解其对数据操作的最小必要范围是哪些。 2) 核查相关系统的账户及权限设置情况，查看是否要求一致，讲外包人员对数据与系统的访问、修改权限限制到最小必要范围。
	b) 能够在测试环境下或使用测试数据完成的，是否向外包人员开放了生产环境权限或真实数据；	人员访谈 安全核查	1) 访谈相关人员，询问测试环境、测试数据的使用情况，并了解哪些人员可以接触到生产环境或真实数据。 2) 核查相关系统、网络环境等的账户及权限设置情况，查看是否要访谈要求一致，在技术曾经对外包人员访问生产环境权限或真实数据进行限制。
	c) 外包人员数据导出操作或数据外发操作的监督管理情况；	人员访谈 安全核查	1) 访谈相关人员，询问是否对外包人员数据导出操作或数据外发操作有相关监督措施，具体措施有哪些。 2) 核查相关系统、安全措施，是否能够对外包人员数据导出操作或数据外发操作进行监控，是否与访谈要求一致。
	d) 外包人员对敏感数据的访问及操作能否被实时监督或监	人员访谈 安全核查	1) 访谈相关人员，询问外包人员对敏感数据的访问及操作是否能被实时监督或监测，具体监测措施有哪些。 2) 核查相关安全措施，是否能够对外包人员对敏感数据的访问及操作能被实时监督或监测，是否与访谈要求一致。

安全子类	识别要素	评估方法	判定依据
	测；		
	e) 数据外包服务账号及访问权限管理情况；	人员访谈 安全核查	1) 访谈相关人员，询问对数据外包服务提供了哪些账户，其权限如何管理。 2) 核查相关安全措施，开通的账号、访问权限是否与访谈要求一致。
	f) 外包人员远程访问操作系统或数据的情况。	人员访谈 文档查验 安全核查	1) 访谈相关人员，询问是否存在外包人员远程访问操作系统或数据的情况，远程运维的审批流程，针对外包人员互联网远程运维行为采取了哪些安全技术措施。 2) 查看相关记录文件，是否对外包人员远程操作系统或数据情况进行审批； 3) 核查相关安全措施，开通的账号、访问权限是否与访谈要求一致。
第三方接入与数据回收	a) 是否对合作方接入的系统、使用的技术工具进行了技术检测，或合作方提供专业第三方机构评估的数据安全报告，避免引入木马、后门等；	人员访谈 文档查验	1) 访谈相关人员，询问是否对合作方接入的系统、使用的技术工具进行技术检测，或要求合作方提供专业第三方机构评估的数据安全报告，避免引入木马、后门等。 2) 查看制度文件，制度中是否明确了对接入的系统、使用的技术工具进行技术检测的要求，并查验相关记录文件，确保制度要求被严格落实。
	b) 为完成技术或服务目的的向合作方提供的数据，在合作结束	人员访谈 文档查验	1) 访谈相关人员，询问是否会向合作方提供的数据，在合作结束后是否要求进行回收，并要求合作方对数据进行删除。 2) 查看制度文件及相关合同协议，是否明确了数据回收或删除相关要求。

安全子类	识别要素	评估方法	判定依据
	后是否进行了回收,是否要求合作方对数据进行删除;		
	c) 外包服务到期后,账号注销、数据回收、数据删除销毁等管理情况;	人员访谈 文档查验	1) 访谈相关人员,询问制度及合作协议中是否明确外包服务到期后,账号注销、数据回收、数据删除销毁等相关规定。 2) 查看制度文件及相关合同协议,是否明确了相关要求。
	d) 为完成技术或服务目的向合作方提供的系统权限和接口,在合作结束后是否进行了停用或下线。	人员访谈 文档查验	1) 访谈相关人员,询问是否有在合作结束后对提供的系统权限和接口进行停用或下线的相关要求。 2) 查看制度文件,是否明确了相关要求,查验相关记录,确保制度要求被严格落实。

表2-6 安全威胁和应急管理评估表

安全子类	识别要素	评估方法	判定依据
安全威胁和事件	a) 近3年发生的网络安全或数据安全事件信息及其处置、记	人员访谈 文档查验	1) 访谈相关人员,询问近3年是否发生过网络安全或数据安全事件; 2) 查看相关记录文件,是否对网络安全或数据安全事件进行了记录和处置,记录内容是否包括事件名称、影响对象、发生时间和频次、发生原因、外部威胁、事件

安全子类	识别要素	评估方法	判定依据
	录、整改和上报情况，如事件名称、影响对象、发生时间和频次、发生原因、外部威胁、事件级别、处置措施、整改措施等，重大事件需提供事件调查评估报告；		级别、处置措施、整改措施等内容。
	b) 近 1 年通过安全工具、日志审计、安全测评、合规自查等发现的违规行为及处置情况；	人员访谈 文档查验	1) 访谈相关人员，是否具备通过安全工具、日志审计、安全测评、合规自查等方式发现违规行为的能力； 2) 如具备发现能力，则询问近 1 年内是否发生过违规行为，如何对其进行过处置； 3) 查看相关记录文件，发现的违规行为是否得到及时处置。
	c) 实际环境中通过监测系统、检测工具等发现的攻击威胁及处置情况；	人员访谈 文档查验 安全核查	1) 访谈相关人员，是否部署了监测系统、检测工具等安全监测设备对可能发生的攻击行为进行监测； 2) 核查相关安全设备，是否合理配置并能对攻击行为进行监测，并查看近期 1 年内是否有攻击威胁的记录； 3) 查看相关记录文件，对于发现的攻击行为是否得到及时处置。
	d) 近期公布或曝光的全社会、特定行	人员访谈 文档查验	1) 访谈相关人员，是否对近期公布或曝光的全社会、特定行业、同行业或类似业务模式的威胁事件、威胁预警进行了分析（例如主管部门发布的漏洞通报等）；

安全子类	识别要素	评估方法	判定依据
	业、同行业或类似业务模式的威胁事件、威胁预警、分析及处置情况。		2) 查看相关记录文件，对于对于相关情报信息，是否提前进行预防处置（例如补丁修复，关闭相关服务，减少威胁暴露面，暂停相关合作等）。
安全应急管理	a) 数据安全事件应急预案制定和修订情况，是否定义数据安全事件类型，明确不同类别级别事件的处置流程和方法；	文档查验	查看应急制度文件，制度中是否定义数据安全事件类型，明确不同类别级别事件的处置流程和方法；并查看修订记录，相关制度文件是否定期修订，确保内容有效性。
	b) 数据安全应急响应及处置机制建设情况，发生数据安全事件时是否立即采取处置措施，是否按照规定及时告知用户并向有关主管部门报告；	文档查验	查看应急制度文件，涉及个人信息的数据处理者，制度中是否关于告知用户及向有关主管部门报告的相关内容；并查验相关记录文件，已发生的数据安全事件是否得到及时处置。
	c) 数据安全	文档查验	查看应急演练相关制度文件，是否明确定期开展应急

安全子类	识别要素	评估方法	判定依据
	事件应急演练情况;		演练, 并制定应急演练计划; 并查验相关记录文件, 是否按照制度要求, 定期开展数据安全事件的应急演练。
	d) 数据处理活动安全风险监测情况, 发现数据安全缺陷、漏洞等风险时, 是否立即采取补救措施;	人员访谈 文档查验 安全核查	1) 访谈相关人员, 是否部署了监测系统能够对数据处理活动进行安全监测; 2) 核查相关安全设备, 是否合理配置并能对相关行为进行监测预警, 发现可能存在的安全缺陷和漏洞; 3) 查看相关记录文件, 对于已发现的安全缺陷和漏洞是否得到及时的补救。
	e) 安全事件对个人、其他组织造成危害的, 是否将安全事件和风险情况、危害后果、已经采取的补救措施等通知利害关系人, 无法通知的是否采取公告等其他方式告知;	文档查验	1) 查看相关制度, 制度是否明确, 当安全事件对个人、其他组织造成危害的时, 是否将安全事件和风险情况、危害后果、已经采取的补救措施等通知利害关系人, 如无法通知的, 将采取何种方式进行告知; 2) 查看相关记录文件, 是否对已发送的事件进行过告知并保留相关证据。
	f) 面向社会提供服务的数据处理者是否建立便捷的数据安	人员访谈 文档查验	1) 查看相关制度文件, 是否建立一套数据安全相关投诉举报处理机制; 2) 核查相关官方渠道, 是否明确发布了投诉举报渠道; 3) 访谈相关人员, 近3年是否发生过数据安全投诉举

安全子类	识别要素	评估方法	判定依据
	全相关投诉举报渠道,以及近3年的数据安全投诉举报处置、记录和整改情况,是否存在侵害用户个人信息合法权益的情况。		报事件,查验相关投诉举报处置、记录和整改记录,查看是否存在侵害用户个人信息合法权益的情况。

表2-7 开发运维管理评估表

安全子类	识别要素	评估方法	判定依据
开发运维管理	a) 新应用开发审核流程建设情况,进行数据处理需求安全合规审核情况;	文档查验	1) 查看相关制度文件,是否规定了新应用开发设计阶段,对数据处理需求进行安全合规审核的相关要求,并明确规定相关审核流程及记录表; 2) 核验相关记录文件,是否严格落实制度要求。
	b) 开发程序的修改、更新、发布的批准授权和版本控制流程;	文档查验	1) 查看相关制度文件,是否明确对开发程序的修改、更新、发布活动进行批准和授权,并通过技术手段进行版本控制; 2) 核验相关记录文件,是否严格落实制度要求。
	c) 工程实施、验收、交付的安全管理情况;	文档查验	1) 查看相关制度文件,是否明确规定工程实施、验收、交付的安全管理要求,例如交付清单、安全测试报告、验收报告等; 2) 核验相关项目归档文件,是否严格落实制度要求。

安全子类	识别要素	评估方法	判定依据
	d) 对开发代码、测试数据的安全管理情况;	人员访谈	访谈相关人员,了解开发代码、测试数据的管理情况,是否存在代码泄露、测试数据使用真实数据等情况。
	e) 产品或业务上线前进行安全评估的情况;	文档查验	1) 查看相关制度,是否有明确产品或业务上线前进行安全评估的相关要求; 2) 查验相关安全测试报告,是否严格落实制度要求,安全测试报告包括等保测评报告、安全测试报告、源代码测试报告、渗透测试报告等。
	f) 开发测试环境和实际运行环境的隔离情况、测试数据和测试结果的控制情况;	人员访谈 安全核查	1) 分析网络拓扑图或核查相关访问控制设备,开发测试环境和实际运行环境是否进行了隔离,是否存在开发测试环境与实际运行环境互访的情况; 2) 访谈相关人员,询问了解测试数据和测试结果的防护情况,是否存在测试数据或测试结果泄露导致系统安全的风险。
	g) 开发测试中使用真实个人信息、核心数据、重要数据情况,开发测试前对相关数据进行去标识化、脱敏处理(测试确需信息除外)情况;	人员访谈 安全核查	1) 访谈相关人员,开发测试中是否使用了真实数据,是否涉及真实个人信息、核心数据、重要数据;如涉及,开发测试前是否对相关数据进行去标识化、脱敏处理(测试确需信息除外) 2) 核查相关测试数据,是否按照要求对涉及真实个人信息、核心数据、重要数据进行去标识化或脱敏处理。
	h) 对开发和运维人员行	文档查验 安全核查	1) 查看相关制度文件,是否明确对开发和运维人员行为进行监督和审计的要求

安全子类	识别要素	评估方法	判定依据
	为的监督和审计情况;		2) 核查相关监督审计设备或核验相关记录文件, 是否通过技术手段对开发和运维人员行为进行监督和审计, 监督审计范围是否覆盖所有重要操作。
	i) 远程运维的审批、管理和安全防护措施;	文档查验 安全核查	1) 查看相关制度文件, 是否明确规定远程运维相关的审批管理制度; 2) 查验相关审批记录, 是否严格落实远程运维审批管理制度; 3) 核查相关安全防护设备, 是否通过技术手段, 对远程运维行为进行严格管理, 管理方式包括采用高强度身份鉴别、通道加密、日志审计等。
	j) 第三方 SDK 或开源软件的运行维护、二次开发等技术资料完备性。	文档查验 安全核查	1) 访谈相关人员, 系统中是否使用了第三方 SDK 或开源软件, 如何进行管理; 2) 查看相关制度文件, 是否建立相应的管理机制, 对 SDK、开源软件采集数据、访问数据、补丁更新等情况进行跟踪; 3) 查验相关记录文件, 制度要求是否被严格落实。

表2-8 云数据安全评估表 (被评估对象使用云计算服务时)

安全子类	识别要素	评估方法	判定依据
云数据安全	a) 云服务提供者、第三方厂商、云租户的安全责任划分和落实情况;	文档查验	查看相关安全服务合同或服务水平协议等文件, 是否明确了各方的安全责任。
	b) 上云数据的安全审核和管理情况;	文档查验	1) 查看相关制度文件, 是否明确对数据上云进行安全审核要求, 针对公共数据上云, 审核内容包括数据是否可公开、共享、使用加工等;

安全子类	识别要素	评估方法	判定依据
			2) 查验相关记录文件，制度要求是否被严格执行。
	c) 云安全产品服务的使用和配置情况；	人员访谈 安全核查	1) 访谈相关人员，询问云安全产品及服务部署情况，分析是否能满足当前安全防护需求； 2) 核查相关云安全产品，查看相关云安全产品部署和配置是否合理。
	d) 对云上操作行为的安全审计情况；	安全核查	核查相关设备日志，包括云管平台、云堡垒机、云服务器、云数据库、云上应用系统等，是否对重要操作行为进行了日志审计。
	e) 云用户账号和权限管理情况；	安全核查	核查相关设备日志，包括云管平台、云堡垒机、云服务器、云数据库、云上应用系统等，是否按照最小必要原则分配账户权限；
	f) 私有云远程运维安全管理情况；	人员访谈 安全核查	1) 访谈相关人员，询问私有云远程运维采取了哪些安全措施； 2) 核查相关设备，确认安全措施的落实情况。
	g) 云上承载用户个人信息、重要数据、核心数据情况，是否对核心数据、重要数据、敏感个人信息实施增强的安全防护。	人员访谈 安全核查	1) 访谈相关人员，询问用户个人信息、重要数据、核心数据是否上云，采取了哪些安全措施； 2) 核查相关设备，确认安全措施的落实情况。

附录 2.1.2 数据安全技术评估表

表2-9 网络安全防护评估表

安全子类	识别要素	评估方法	判定依据
网络安全防护	a) 网络拓扑结构、网络区域划分、IP 地址分配、网络带宽设置等网络资源管理情况;	人员访谈 文档查验 安全核查	1) 查看网络结构相关文档, 查看网络总体拓扑情况, 确认是否根据各部门的工作职能、重要性和信息的重要程度等因素划分不同网段; 2) 访谈相关人员, 询问网络各个部分的带宽是否满足业务高峰期需求。如业务应用的高峰流量是多少, 各个网络接入链路带宽是多少, 是否有过网络带宽瓶颈事件的发生。 3) 若提供网络监控平台, 应查看网络带宽占用情况、高峰期使用情况以及是否提供告警措施, 确保网络带宽满足业务高峰期需求。
	b) 网络隔离、边界防护等措施的有效性;	人员访谈 安全核查	1) 访谈网络管理员, 查验网络拓扑图, 确认实际运行情况与拓扑图保持一致; 2) 分析网络结构主要有哪些边界 (例如外部网络边界、内部运维区域边界), 并且查看边界上是否部署边界防护措施? 查看边界处的网络设备、安全设备对重要网段及区域之间采取的访问控制策略, 例如防火墙、核心交换机、网闸等配置的访问控制策略; 针对云上部署的系统, 主要查看安全组、VPC 虚拟云防火墙、互联网边界虚拟防火墙等的访问控制策略; 3) 核查边界处的访问控制设备是否指定端口进行跨边界的网络通信, 指定端口是否配置并启用了安全策略, 例如防火墙、交换机、网闸等设备上的访问控制策略是否达到端口级。
	c) 安全策略和配置核查情况;	人员访谈 安全核查	1) 核查防火墙或者核心交换机等边界设备的访问控制策略, 是否禁止指定端口外的所有通信, 如: deny any any。对云上部署的系统, 主要查看是否采购虚拟云防

安全子类	识别要素	评估方法	判定依据
			防火墙服务，云防火墙上是否配置 deny any any 策略，或者安全组是否配置该策略。 2) 核查防火墙、核心交换机等边界设备的访问控制策略，并访谈网络管理员，询问设备策略的用途，确认网络管理员是否梳理过访问控制策略的用途，是否定期清理无效过期的访问控制策略，并检查是否存在重复、冲突、可替代、过期的规则。 3) 查看网络设备、安全设备中的访问控制表，是否设定了源地址、目的地址、源端口、目的端口和协议等参数。
	d) 网络访问控制、安全审计情况；	人员访谈 安全核查	1) 询问网络管理员是否在网络边界部署了访问控制设备，是否启用了访问控制功能。 2) 访谈网络管理员，是否部署了综合安全审计系统系统或对设备日志进行统一收集，且审计内容包括重要的用户行为（如登录成功失败、重要业务操作等）和重要安全事件。 3) 对边界处配置访问控制策略的设备进行核查，核查策略规则和有效性，核查安全审计系统是否统一收集网络设备、安全设备等日志，并对日志进行分析。
	e) 安全漏洞发现及常见漏洞修复、处置情况；	人员访谈 文档查验 安全核查	1) 应访谈安全主管，当前采取何种措施发现和识别设备、应用系统的安全漏洞和隐患，多久开展一次。 2) 现场查验本次数据安全风险评估相关设备、业务应用系统资产的漏洞扫描报告、渗透测试报告，以及查看漏洞的修复记录。
	f) 异常流量、恶意代码和钓鱼邮件发现及处置情况；	人员访谈 文档查验 安全核查	1) 询问安全管理员是否在关键网络节点部署安全防护设备/组件（如 APT 攻击系统、网络回溯系统、威胁情报系统、抗 D 设备、恶意代码产品、防垃圾邮件产品等），现场安全核查相关安全防护设备的使用情况； 2) 询问安全管理员是否及时处理相关安全设备上的

安全子类	识别要素	评估方法	判定依据
			告警信息,并及时处理形成安全分析报告,现场查看告警信息,以及访谈安全管理员对告警信息的处置措施。
	g) 外部攻击、内部攻击、新型攻击的发现和处置情况;	人员访谈 安全核查	1) 询问安全管理员是否分别在内/外部边界区域部署了安全防护设备。 2) 询问安全管理员是否部署了安全防护设备对新型网络攻击进行检测和报警(如抗 APT 攻击系统、网络回溯系统、威胁情报检测系统等),进一步确认防护策略是否开启。 3) 访谈各类安全设备是实时监控和告警机制,还是开启了拦截机制,以及核查是否采用针对攻击行为的联动措施(比如封禁攻击 IP 等措施),核查联动措施的有效性,记录攻击事件告警的处置措施。
	h) 未授权连接内网、外网、无线网等情况;	人员访谈 安全核查	1) 访谈相关人员,询问网络管理员、安全管理员采取何种技术手段或管理措施对非授权设备私自联到内部网络的行为进行检查或限制。若为技术措施,则在有条件的情况下进行验证,例如采用 MAC 地址绑定,安装准入客户端软件,配置内网准入账户、密码等措施。 2) 询问网络管理员、安全管理员采取何种技术手段或管理措施对非法外联的行为进行检查或限制。 3) 询问网络管理员并结合网络拓扑图,检查无线网络是否组成一个相对独立的区域;在无线区域与内部有线网络之间是否部署边界防护设备,并启用有效的访问控制策略。
	i) 通信链路、网络设备、计算设备等关键设备的冗余情况;	人员访谈 安全核查	1) 访谈网络管理员,介绍当前的网络拓扑结构,通过针对数据安全风险评估的范围分析,查看在通信链路上是否提供冗余措施。 2) 现场查看网络结构,根据数据安全风险评估的范围及数据处理活动的数据流,分析涉及的关键网络设备、计算设备是否提供冗余措施,是否存在单点故障,影响

安全子类	识别要素	评估方法	判定依据
			数据处理系统的高可用性。
	j) 对第三方组件进行安全核查、修复、更新的情况;	人员访谈 安全核查	1) 人员访谈,访谈安全管理员是否对信息系统软件开展软件成分分析,了解使用了哪些开源组件和依赖关系,提供软件成分分析报告。 2) 通过开源漏洞平台,检查所使用的第三方组件是否存在低版本导致的安全缺陷。 3) 查看软件中第三方组件修复、更新相关记录文档。
	k) 服务器、数据库、端口、数据资源在互联网的暴露及管理情况;	人员访谈 安全核查	1) 人员访谈,了解存储数据的数据库、数据资源的管理方式,其管理系统、访问端口是否向互联网开放。 2) 技术测试,通过端口扫描或防火墙映射规则,检查是否存在管理端口暴露在互联网的情况,若应业务需要必须互联网访问,是否做好必要的安全防范措施(例如对访问地址进行设置、数据加密传输、鉴别机制采用双因素鉴别机制、对远程访问行为进行审计等安全防范措施)。

表2-10 监测预警评估表

安全子类	识别要素	评估方法	判定依据
监测预警	a) 安全监测预警和信息报告机制的建设落实情况,是否明确对组织内部各类数据访问操作的日志记录要求、安全监控要	人员访谈 文档查验 安全核查	1) 询问数据安全管理员,是否对数据生存周期各阶段建立安全监测预警和信息报告机制; 2) 文档中是否根据不同类型数据和数据处理活动,提出不同的审计要求和安全监控要求。 3) 安全核查,进一步查看安全监测预警和信息报告的落实情况,确保对各类数据访问和操作的审计,能追溯到数据访问人员或操作人员、时间以及操作行为,并且能对异常行为进行预警,并且及时上报。

安全子类	识别要素	评估方法	判定依据
	求；		
	b) 异常行为监测指标建设情况,包括IP 地址、账号、数据、使用场景等,对异常行为事件进行识别、发现、跟踪和监控等;	人员访谈 安全核查	1) 询问是否设置异常行为监测指标,核查相关监测平台,查看对异常行为事件进行识别、发现、跟踪和监控的相关记录,记录内容是否包含 IP 地址、账号、数据、使用场景等。
	c) 对批量传输、下载、导出等敏感数据操作的安全监控和分析的情况,是否实现对数据异常访问和操作进行告警;	人员访谈 安全核查	1) 访谈相关人员,针对于批量传输、下载、导出等敏感数据操作,是否有相关安全设备能提供安全监控和分析; 2) 安全核查,核查相关安全设备的配置及日志信息,是否实现对数据异常访问和操作进行告警。
	d) 对数据交换网络流量进行安全监控和分析的情况,是否具备对异常流量和行为进行告警的能	人员访谈 安全核查	1) 访谈相关人员,询问是否有相关设备能对对数据交换网络流量进行安全监控和分析; 2) 核查相关安全设备的配置及日志信息,是否具备对异常流量和行为进行告警的能力。

安全子类	识别要素	评估方法	判定依据
	力；		
	e) 风险信息的获取、分析、研判、通报、处置工作开展情况；	人员访谈 文档查验	1) 访谈相关人员,是否能够对上述数据处理场景中风险信息(监控指标)进行监测,是否后续开展分析、研判、通报、处置等流程。 2) 检查相关过程处置记录。
	f) 数据安全缺陷、漏洞等风险的监测预警能力建设情况。	人员访谈 文档查验	1) 人员访谈,了解是否建立相关检测预警系统或体系,能够检测数据安全缺陷、漏洞(如未授权访问、大量数据异常访问等)等风险。

表2-11 数据脱敏评估表

安全子类	识别要素	评估方法	判定依据
数据脱敏	a) 数据脱敏规则、脱敏方法和脱敏数据的使用限制情况；	人员访谈 文档查验	1) 人员访谈、文档查验,询问是否制定数据脱敏相关操作规程,操作规程中是否明确了脱敏规则、方法以及脱敏数据的使用期限限制。
	b) 需要进行数据脱敏处理的应用场景、处理流程及操作记录情况；	人员访谈 文档查验	1) 人员访谈,是否明确了数据脱敏处理应用场景、数据脱敏处理流程、涉及部门及人员职责分工等情况； 2) 文档查验,查验相关操作记录,查看是否按照制度要求,对数据进行了脱敏处理。
	c) 静态数据脱敏和动态数据脱敏技	人员访谈 安全核查	1) 人员访谈,询问是否具备静态数据脱敏和动态数据脱敏能力,了解具体的实现方法。(静态数据脱敏是在数据存储或数据库中对数据进行脱敏处理,以保护

安全子类	识别要素	评估方法	判定依据
	术能力建设情况;		数据的隐私。脱敏后,数据保持在脱敏状态,不会再还原为原始数据。)、(动态数据脱敏是在数据访问时对数据进行实时脱敏处理,以确保只有经过授权的用户能够看到完整数据,而其他用户只能看到脱敏的数据)。
	d)开发测试、人员信息公示等应用场景的数据脱敏效果验证情况;	人员访谈 安全核查	1) 询问当前数据脱敏的使用场景(主要为开发测试和人员信息的展示场景),在相关场景中数据脱敏是否与其制定的脱敏规程一致。 2) 通过静态脱敏、动态脱敏场景的演示,证明现有静态数据脱敏和动态数据脱敏能力的有效性。
	e)对匿名化或去标识化处理的个人信息重新识别出个人信息主体的风险分析情况,是否采取相应的保护措施。	人员访谈	1) 询问相关人员,是否对匿名化或去标识化处理的个人信息重新识别出个人信息主体的可能性及风险进行分析,针对可能重新识别的情况,是否采取了相应的保护措施。

表2-12 数据防泄漏评估表

安全子类	识别要素	评估方法	判定依据
数据防泄漏	a)数据防泄漏技术手段部署情况,能否对网络、邮	人员访谈 安全核查	1) 询问相关人员,是否部署了相关安全设备或软件,能够有效防范数据泄漏。 2) 安全核查,核查相关安全设备的配置及日志数据,是否能对网络、邮件、终端等关键环节进行监控并报告

安全子类	识别要素	评估方法	判定依据
	件、终端等关键环节进行监控并报告敏感信息的外发行为；		敏感信息的外发行为。
	b) 市场上售卖组织业务数据的情况，查看是否能够通过公开渠道、开源网站查询到组织业务信息，如代码、数据库信息等；	人员访谈 安全核查	1) 人员访问，了解是否曾出现业务数据黑市公开售卖的情况。 2) 通过暗网、搜索引擎、github 等方式查看是否能查询到组织业务信息，如代码、数据库信息等。
	c) 数据防泄漏技术措施有效性。	人员访谈 安全核查	1) 人员访谈，是否通过现有数据防泄漏技术监测处置过数据泄露预警事件，以及相关处理情况； 2) 在可行的情况下，要求人员配置进行数据防泄漏技术的验证。

表2-13 数据备份恢复评估表

安全子类	识别要素	评估方法	判定依据
数据备份恢复	a) 数据备份恢复策略和操作规程的建设落实情况；	人员访谈 文档查验 安全核查	1) 访谈相关人员，询问是否建立了数据备份恢复策略和操作规程，查验数据备份恢复策略和操作规程，明确定义数据备份和恢复的范围、频率、工具、过程、日志记录、数据保存时长等内容。 2) 查验相关备份策略及操作记录，是否与文档规定的策略一致。

	b) 数据备份的方式、频次、保存期限、存储介质等情况;	人员访谈 安全核查	1) 访谈相关人员, 询问了解是否针对数据备份方式、频次、保持期限制定了相关安全策略, 是否对存储介质制定了介质管理制度; 2) 安全核查, 相关措施是否与安全策略及制度措施匹配。
	c) 提供本地或异地数据灾备功能情况;	人员访谈 安全核查	1) 访谈相关人员, 是否提供本地或异地数据备份功能, 通过何种方式实现的备份。 2) 安全核查, 访谈数据库管理员, 并且查看数据本地备份策略和异地备份策略配置。
	d) 定期开展数据备份恢复工作情况;	人员访谈 文档查验	1) 访谈相关人员, 询问并核查相关制度和记录, 是否定期开展数据备份恢复测试, 以确保备份恢复机制有效。
	e) 备份和归档数据访问控制措施的有效性;	人员访谈 安全核查	1) 访谈相关人员, 询问是否对备份和归档数据进行了访问控制措施, 确保该数据不会被非授权访问; 2) 技术测试, 测试相关措施是否有效, 是否存在旁路等情况。
	f) 定期采取必要的技术措施查验备份和归档数据完整性和可用性情况;	人员访谈 文档查验	1) 访谈相关人员, 询问并核查相关制度和记录, 采取何种技术手段验证备份和归档数据的完整性和可用性(如恢复测试)。
	g) 定期开展灾难恢复演练情况。	人员访谈 文档查验	1) 人员访谈、文档查验, 询问并核查相关制度和记录, 是否定期开展针对数据丢失、破坏、恢复等的灾难演练。

表2-14 安全审计评估表

安全子类	识别要素	评估方法	判定依据
审计执行	a) 审计的实施情况;	人员访谈 文档查验	1) 人员访谈、文档查验, 询问安全管理员是否制定安全审计制度, 要求对数据生存周期各阶段的数据访问

安全子类	识别要素	评估方法	判定依据
			和操作进行涉及，并保留审计记录和分析报告等文件。
	b) 审计策略和要求的合理性、有效性；	人员访谈 文档查验	1) 人员访谈、文档查验，询问安全管理员是否制定安全审计策略和要求，是否覆盖数据处理活动、网络事件、重要用户行为等。
	c) 对数据的访问权限和实际访问控制情况进行定期审计的情况，审核用户实际使用权限与审批时的目的是否保持一致，并及时清理已过期的账号和授权；	人员访谈 文档查验 安全核查	1) 询问安全管理员是否定期对数据的访问权限和实际访问控制情况进行审计，要求提供权限一致性审计报告，查看相关审计记录或报告。 2) 安全核查，查看是否及时清理已过期的账号和授权。
	d) 特权用户安全审计情况。	人员访谈 文档查验 安全核查	1) 询问安全管理员是否定期对特权用户的授权、操作等进行审计，查看审计记录或报告。 2) 查看特权用户的审计日志，看是通过业务应用系统记录还是数据库保存日志记录。
日志留存记录	a) 对数据授权访问、收集、批量复制、提供、公开、销毁、数据接口调用、下载、导出等	人员访谈 文档查验 安全核查	1) 访谈相关人员，询问数据操作重要环节的日志留存管理情况，查看安全审计管理制度，是否明确对上述操作日志进行留存。 2) 查看数据操作重要环境日志留存所采用的技术实现措施。现场安全检查日志的留存情况和内容，查看是否记录数据授权访问日志、数据采集日志、数据批量复制或者下载、导出操作日志、数据共享日志、数据销毁

安全子类	识别要素	评估方法	判定依据
	重点环节进行日志留存管理情况；		日志、数据接口调用操作日志。
	b) 日志记录内容, 是否包括执行时间、操作账号、处理方式、授权情况、IP 地址、登录信息等；	安全核查	1) 安全核查, 检查审计记录内容是否包括执行时间、操作账号、处理方式、授权情况、IP 地址、登录信息等信息。
	c) 日志记录是否能够对识别和追溯数据操作和访问行为提供支撑；	安全核查	1) 安全核查, 检查审计记录内容是否包括主客体信息、操作事件、事件类型以及事件成功与否的关键要素。
	d) 是否定期对日志进行备份, 防止数据安全事件导致日志被删除；	人员访谈 安全核查	1) 人员访谈, 询问是否对日志进行备份, 了解其备份策略。 2) 查看日志备份情况和备份文件。
	e) 日志保存期限是否符合法律法规要求, 如网络日志是否保存六个月以	人员访谈 安全核查	1) 人员访谈, 询问是否对日志留存的期限。 2) 检查最早日志备份情况, 查看是否满足至少 6 个月以上的要求。

安全子类	识别要素	评估方法	判定依据
	上。		
行为审计	a) 对网络运维管理活动、用户行为、网络异常行为、网络安全事件等审计情况;	人员访谈 文档查验	1) 人员访谈、文档查验, 询问安全管理员是否定期对网络运维管理活动、用户行为、网络异常行为、网络安全事件进行安全审计, 并提供审计报告。
	b) 对数据库、数据接口的访问和操作行为审计情况;	人员访谈 文档查验	1) 人员访谈、文档查验, 询问安全管理员是否定期对数据库、数据接口的访问和操作行为进行安全审计, 并提供审计报告。
	c) 对数据批量复制、下载、导出、修改、删除等高风险行为的审计情况;	人员访谈 文档查验	1) 人员访谈、文档查验, 询问安全管理员是否定期对数据批量复制、下载、导出、修改、删除等高风险行为进行安全审计, 并提供审计报告。
	d) 对个人信息处理活动的合规审计情况。	人员访谈 文档查验	1) 询问安全管理员是否定期对个人信息处理活动(如收集使用、存储合规、功效合规等活动)进行安全审计, 并提供审计报告, 查看审计记录或报告。

附录 2.1.3 个人信息保护评估表

表2-15 个人信息处理基本原则评估表

安全子类	识别要素	评估方法	判定依据
合法、诚信原则	a) 通过误导、欺诈、胁迫等方式处理个人信息的情况;	人员访谈 文档查验 技术测试	1) 访谈相关人员, 询问是否制定包含处理个人信息规则的隐私政策; 2) 通过技术测试, 结合隐私政策内容分析, 检测是否按照知情同意、最小必要原则处理个人信息。 3) 重点检测是否存在如下行为: A、App 提示用户打开通讯录权限以参与红包、金币、抽奖等活动。事实上, 通讯录权限与上述活动之间毫无关联, App 诱骗用户打开通讯录权限后, 立即上传用户通讯录信息, 并将该类信息用于发送商业广告或其它目的; B、欺骗误导用户提供个人信息。非服务所必需或无合理场景, 通过积分、奖励、优惠、红包等方式欺骗误导用户提供与业务无关个人信息。C、强制收集非必要个人信息, 否则不提供任何服务。
	b) 非法收集、使用、加工、存储、传输个人信息的情况;	人员访谈 文档查验 技术测试	1) 访谈相关人员, 了解个人信息处理场景的情况; 2) 通过技术测试, 检查是否存在未经用户同意非法收集个人信息、过度收集个人信息的情况; 3) 检查个人信息使用和加工相关场景, 检查是否存在未经用户同意非法使用和加工个人信息; 4) 检查个人信息存储相关场景, 检查是否存在非法留存个人信息的情况, 例如非法留存用户银行卡支付类信息; 5) 检查个人信息传输场景, 检查是否存在未经用户同意非法传输个人信息的情况。
	c) 非法买卖、提供或者公开他人个人	人员访谈 文档查验	1) 访谈相关人员, 了解个人信息处理场景的情况, 检查是否存在非法买卖、使用及出境的情况; 2) 若存在从第三方间接获取个人信息的情况, 核查

安全子类	识别要素	评估方法	判定依据
	信息的情况;		相关合作协议, 检查是否包含数据来源合法性、用户知情同意等方面的要求; 3) 若存在向他人提供其处理的个人信息的情况, 检查是否获得用户单独同意; 4) 若存在公开其处理的个人的情况, 检查是否获得用户单独同意; 5) 若存在个人信息(达到一定数量条件)出境的情况, 是否按照网信部门要求申报数据出境安全评估、订立个人信息出境标准合同、通过个人信息保护认证。
	d) 是否从事危害国家安全、公共利益的个人信息处理活动;	人员访谈	1) 访谈相关人员, 了解个人信息处理场景的情况, 检查是否存在从事危害国家安全、公共利益的个人信息处理活动。
	e) 个人信息处理活动是否具备《个人信息保护法》规定的合法性事由;	人员访谈 文档查验 技术测试	1) 访谈相关人员, 了解个人信息处理场景的情况, 检查是否取得个人同意或单独同意。 2) 通过文档查验、技术测试, 检查是否存在合作协议、同意书或其他形式的同意方式。
	f) 是否存在隐瞒产品或服务所收集个人信息功能的情况;	文档查验 技术测试	1) 通过文档查验、技术测试, 检查 App 是否存在隐瞒收集个人信息的功能或业务功能隐瞒收集个人信息的情形。例如, 存在实际收集个人信息的业务功能多于个人信息保护政策或用户协议等告知范围、隐私政策中无 SDK 相关权限索取的说明。
	g) 移动互联网应用(如 App、SDK、小	人员访谈	1) 访谈相关人员, 询问是否包含 App、SDK、小程序等移动互联网应用; 2) 通过技术测试, 检查移动互联网应用是否存在未

安全子类	识别要素	评估方法	判定依据
	程序等)是否存在违法违规收集使用个人信息或侵害用户权益行为。		公开收集使用规则的行为,如登录/注册/首次启动无隐私政策、隐私政策难以阅读; 3) 通过技术测试,检查移动互联网应用是否存在未经用户同意收集使用个人信息的行为,如征得用户同意前就开始收集个人信息、频繁征求用户同意、干扰用户正常使用、以默认选择同意隐私政策等非明示方式征求用户同意、未提供非定向推送信息的选项; 4) 通过技术测试,检查移动互联网应用是否存在收集与其提供的服务无关的个人信息的行为,如收集个人信息权限与现有业务功能无关、强制收集非必要个人信息、收集个人信息的频度等超出业务功能实际需要; 5) 通过技术测试,检查移动互联网应用是否提供个人信息更正、删除以及账号注销的功能。
正当、必要原则	a) 处理个人信息是否具有明确、合理的目的;	人员访谈	1) 访谈相关人员,了解个人信息处理场景的情况,检查是否具有明确、合理的目的的说明。
	b) 处理个人信息是否与处理目的直接相关,是否采取对个人权益影响最小的方式;	人员访谈 技术测试	1) 访谈相关人员,了解个人信息处理场景的情况,检查是否存在处理的个人信息类型与处理目的无直接关联的情况; 2) 通过技术测试,检查是否存在超范围收集、超范围使用、超频率收集使用的情况。
	c) 收集个人信息是否限于实现处理目的的最小	技术测试	1) 通过技术测试,检查应用系统收集必要信息是否符合《常见类型移动互联网应用程序必要个人信息范围规定》及行业主管部门的要求; 2) 通过技术测试,检查应用系统是否存在频繁收集

安全子类	识别要素	评估方法	判定依据
	范围，如最少类型、最低频次等；是否存在过度收集个人信息行为；		个人信息的情况，如频繁收集定位信息。
	d) 是否以个人不同意处理其个人信息或者撤回同意为由，拒绝提供产品或者服务，或者干扰个人正常使用服务，处理个人信息属于提供产品或者服务所必需的除外。	技术测试	1) 通过技术测试，检查业务系统是否存在强制收集非必要个人信息的情况，否则无法使用其服务； 2) 若移动应用提供游客模式，检查是否存在不同意隐私政策即无法使用的情况。

表2-16 个人信息告知评估表

安全子类	识别要素	评估方法	判定依据
个人信息告知	a) 在处理个人信息前，是否以显著方式、清晰易懂的语言真实、	人员访谈 文档查验	1) 访谈相关人员，询问是否制定包含处理个人信息规则的隐私政策，并检查是否公开渠道发布； 2) 检查隐私政策，查看是否存在收集使用规则的内容晦涩难懂、冗长繁琐，用户难以理解，如使用大量专业术语等情况；

安全子类	识别要素	评估方法	判定依据
	准确、完整地公开个人信息处理规则；		3) 通过文档查验、技术测试，检查 App 是否存在完整说明了个人信息处理规则，至少包含逐一系列出各业务功能收集使用个人信息的目的、方式、范围，个人信息存储、个人信息使用、个人权利行使、投诉反馈等内容。
	b) 是否告知个人信息处理者的名称或姓名、联系方式，有法律、行政法规规定应当保密或者不需要告知的情形除外；	文档查验	1) 检查隐私政策，查看是否包含个人信息处理者的名称或姓名、联系方式； 2) 若未告知相关信息，检查是否有法律、行政法规规定的支持。
	c) 个人信息处理规则是否告知个人信息处理目的、处理方式，处理的个人信息种类、保存期限；	文档查验	1) 检查隐私政策，查看是否包含个人信息处理目的、处理方式，处理的个人信息种类、保存期限等要素。
	d) 个人信息处理规则是否告知个人行使《个人信息保护法》规定权利的方	文档查验	1) 检查隐私政策，查看是否包含个人信息主体的权利和实现机制，如查询方法、更正方法、删除方法、注销账户的方法、撤回授权同意的的方法、获取个人信息副本的方法、对信息系统自动决策结果进行投诉的方法等。

安全子类	识别要素	评估方法	判定依据
	式和程序;		
	e) 告知事项发生变更的, 是否将变更部分告知个人;	文档查验	1) 检查隐私政策, 查看是否包含隐私政策发生变化时告知个人的描述和实现机制。
	f) 个人信息处理规则是否便于查阅和保存;	人员访谈 技术测试	1) 访谈相关人员, 了解隐私政策的发布渠道; 2) 检查隐私政策是否在网站主页、移动互联网应用程序安装页、或系统交互界面或设计等显著位置设置链接。
	g) 紧急情况下为保护自然人的生命健康和财产安全无法及时向个人告知的, 个人信息处理者是否在紧急情况消除后及时告知。	人员访谈 文档查验	1) 访谈相关人员, 查看是否存在类似紧急情况, 并查看相关处理记录; 2) 检查隐私政策、管理制度, 查看是否包含相关情况的描述。

表2-17 个人信息同意评估表

安全子类	识别要素	评估方法	判定依据
个人信息同意	a) 处理个人信息前是否取得个人同意, 同意是否	人员访谈 技术测试	1) 访谈相关人员, 了解处理个人信息获取个人同意的方式方法; 2) 通过技术测试, 检查隐私政策是否提供用户主动勾选同意。

安全子类	识别要素	评估方法	判定依据
	由个人在充分知情的前提下自愿、明确作出，法律规定的例外情形除外；		
	b) 基于个人同意处理个人信息的，个人信息处理者是否提供便捷的撤回同意的方式，个人是否有权撤回其同意，个人撤回同意是否不影响撤回前基于个人同意已进行的个人信息处理活动的效力；	文档查验 技术测试	1) 检查隐私政策，查看是否包含撤回同意的方式； 2) 通过技术测试，查看撤回同意的方式是否有效。如撤回系统权限，是否影响正常使用。
	c) 个人信息的处理目的、处理方式和处理的个人信息种类发生变更的，是	人员访谈 技术测试	1) 访谈相关人员，了解处理个人信息规则发生变更时，是否重新取得个人同意； 2) 通过技术测试，验证相关方式是否真实有效。

安全子类	识别要素	评估方法	判定依据
	否重新取得个人同意。		

表2-18 个人信息处理评估表

安全子类	识别要素	评估方法	判定依据
个人信息保存	a) 个人信息的保存期限是否为实现处理目的所必要的最短时间, 法律、行政法规另有规定除外;	人员访谈 安全核查	1) 访谈相关人员, 了解个人信息保存的相关要求, 检查是否为实现处理目的所必要的最短时间。
	b) 是否将个人生物识别信息与个人身份信息分开存储。	人员访谈 安全核查	1) 访谈相关人员, 询问是否收集个人生物识别信息, 如个人基因、指纹、声纹、掌纹、耳廓、虹膜、面部识别特征等; 2) 检查存储系统, 查看是否将个人生物识别信息与个人身份信息分开存储。
个人信息共同处理	a) 是否约定各自的权利和义务, 约定是否不影响个人向任一个个人信息处理者行使权利。	人员访谈 文档查验	1) 访谈相关人员, 询问相关人员是否存在个人信息共同处理场景, 是否与共同处理者签订相关合同及协议; 2) 查看合同或协议内容是否约定了各自的权力和义务, 查看约定是否包含豁免任一方响应个人信息主体行使权力的内容。
个人信息	a) 是否与受托人约定委	人员访谈 文档查验	1) 访谈相关人员, 询问是否存在个人信息委托处理的情况;

安全子类	识别要素	评估方法	判定依据
委托处理	托处理的目 的、期限、处 理方式、个人 信息的种类、 保护措施以 及双方的权 利和义务等， 是否对受托 人的个人信 息处理活动 进行监督；		2) 查看相关委托协议，查看是否包含约定委托处理的目的、期限、处理方式、个人信息的种类、保护措施以及双方的权利和义务等内容。 3) 访谈相关人员，是否对受托人的个人信息处理活动进行监督，如对受托人开展审计。检查相关佐证材料。
	b) 个人信息 受托人是否 按照约定处 理个人信息， 是否超出约 定的处理目 的、处理方式 等处理个人 信息；	人员访谈 文档查验	1) 访谈相关人员，是否对记录和存储委托处理个人信息的情况。 2) 检查相关佐证材料，查看是否符合约定的处理目的、处理方式等要求。
	c) 委托合同 不生效、无 效、被撤销或 者终止的，受 托人是否将 个人信息返 还个人信息 处理者或者 予以删除，是	人员访谈 文档查验	1) 访谈相关人员，询问是否存在个人信息委托处理的情况； 2) 检查相关委托协议，查看是否包含合同不生效、无效、被撤销或者终止的情况下，受托人需将个人信息返还个人信息处理者或者予以删除的条款； 3) 访谈相关人员，询问是否存在委托合同不生效、无效、被撤销或者终止的情况； 4) 查看相关处理记录，检查是否包含数据返还接收或监督受托人删除数据的记录。

安全子类	识别要素	评估方法	判定依据
	否违规保留个人信息；		
	d) 未经个人信息处理者同意，受托人是否转委托他人处理个人信息。	人员访谈 文档查验	1) 访谈相关人员，询问是否存在个人信息委托处理的情况； 2) 检查相关委托协议，查看是否包含转委托他人处理个人信息需经个人信息控制者同意的条款； 3) 若存在转委托的情况，则查看是否提供相关转委托协议记录。
向他人提供个人信息	a) 是否向个人告知接收方的名称或者姓名、联系方式、处理目的、处理方式和个人信息的种类；	人员访谈	1) 访谈相关人员，是否针对向他人提供个人信息制定相关管理要求，其中是否包含告知接收方信息、处理个人信息的类型、方式和目的的描述； 2) 若存在相关情况，检查相关隐私政策或告知书中是否说明了接收方的名称或者姓名、联系方式、处理目的、处理方式和个人信息的种类。
	b) 是否取得个人的单独同意；	人员访谈 文档查验	1) 访谈相关人员，是否针对向他人提供个人信息制定相关管理要求，其中是否包含取得个人的单独同意的要求，并进一步了解实现的形式； 2) 检查是否保存个人单独同意的记录。
	c) 接收方是否在上述处理目的、处理方式和个人信息的种类等范围内处理个人信息；如接收方变更原先的处	人员访谈 文档查验	1) 访谈相关人员，是否记录和存储个人信息的共享、转让情况，包括共享、转让的日期、规模、目的，以及数据接收方基本情况等； 2) 访问相关人员，是否对数据接收方开展监督，确保其在处理目的、处理方式和个人信息的种类等范围内处理个人信息。 3) 检查是否通过合同等方式规定接收方变更原先的处理目的、处理方式的，需重提前告知个人信息控制者，并经个人信息控制者同意确认。

安全子类	识别要素	评估方法	判定依据
	理目的、处理方式的,是否重新取得个人同意。		4) 检查在接收方变更原先的处理目的、处理方式时,个人信息控制者是否重新获取个人同意。 5) 检查相关佐证文档。
自动化决策	a) 是否保证决策的透明度和结果公平、公正,是否对个人实行不合理的差别待遇;	人员访谈	1) 访谈相关人员,确认相关业务场景中应用的算法(参考《互联网信息服务算法推荐管理规定》中提及的排序精选类、调度决策类等)是否已完成互联网信息服务算法备案,并按要求开展了算法安全评估; 2) 检查相关备案记录和评估报告。
	b) 通过自动化决策方式向个人进行信息推送、商业营销等,是否同时提供不针对其个人特征的选项,或者向个人提供便捷的拒绝方式;	人员访谈 安全核查	1) 访谈相关人员,询问是否具有通过自动化决策方式向个人进行信息推送、商业营销等情况; 2) 若存在,则检查是否提供不针对其个人特征的选项,或者向个人提供便捷的拒绝方式。
	c) 对应用算法推荐技术提供互联网信息服务的情形,是否以显著方式告知用户其提	人员访谈 安全核查	1) 访谈相关人员,是否存在应用算法推荐技术提供互联网信息服务的情形; 2) 检查相关信息系统,查看是否以显著方式告知用户其提供算法推荐服务的情况,并以适当方式公示算法推荐服务的基本原理、目的意图和主要运行机制等。

安全子类	识别要素	评估方法	判定依据
	供算法推荐服务的情况，并以适当方式公示算法推荐服务的基本原理、目的意图和主要运行机制等。		

表2-19 敏感个人信息处理评估表

安全子类	识别要素	评估方法	判定依据
通用规则	a) 敏感个人信息处理是否具有特定的目的和充分的必要性，是否对敏感个人信息采取严格保护措施；	人员访谈 安全核查 技术测试	1) 访谈相关人员，了解处理的敏感个人信息的类型、处理目的，以及保护措施； 2) 依据相关法律法规管理规定，检查敏感个人信息处理是否充分的必要性； 3) 检查是否对敏感个人信息采取传输加密、存储加密、展示脱敏等保护措施。
	b) 处理敏感个人信息是否取得个人的单独同意；	技术测试	1) 检查相关业务应用系统、移动应用或小程序，查看在收集使用个人信息时是否取得个人单独同意。
	c) 法律、行政法规规定处理敏感个人	人员访谈 文档查验	1) 访谈相关人员，了解所在行业规定是否存在法律、行政法规规定处理敏感个人信息应取得书面同意的情况；

安全子类	识别要素	评估方法	判定依据
	信息应取得书面同意的，是否取得个人的书面同意；		2) 检查相关签章、签名记录文档。
	d) 处理敏感个人信息是否向个人告知处理敏感个人信息的必要性以及对个人权益的影响；	技术测试	1) 检查相关业务应用系统、移动应用或小程序，查看在收集使用个人信息时是否向个人告知处理敏感个人信息的必要性以及对个人权益的影响
	e) 处理不满 14 周岁未成年人个人信息的，是否取得未成年人的父母或者其他监护人的同意，是否制定专门的未成年人个人信息处理规则；	人员访谈 文档查验	1) 访谈相关人员，询问是否处理不满 14 周岁未成年人个人信息； 2) 检查是否制定未成年人个人信息处理规则； 3) 检查是否取得未成年人的父母或者其他监护人的同意，验证其征求同意的方式是否有效。
	f) 是否遵守法律、行政法规对处理敏感个人信息	人员访谈 文档查验	1) 访谈相关人员，了解所在行业规定是否存在法律、行政法规规定对处理敏感个人信息的规定； 2) 检查是否遵守相关规定。

安全子类	识别要素	评估方法	判定依据
	规定。		
生物特征识别信息安全	a) 在公共场所安装图像采集、个人身份识别设备, 是否为维护公共安全所必需, 是否遵守国家有关规定, 并设置显著的提示标识;	安全核查	1) 访谈相关人员, 询问是否存在通过在公共场所安装图像采集、个人身份识别设备的情况, ; 2) 了解其安装目的, 是否为维护公共安全所必需且通过所属地市级以上网信部门备案。 3) 检查设备安装环境, 是否设置显著的提示标识。
	b) 所收集的图像、个人身份识别信息, 是否只用于维护公共安全的目的, 未用于其他目的, 取得个人单独同意的除外;	人员访谈 文档查验	1) 访谈相关人员, 询问是否存在通过在公共场所安装图像采集、个人身份识别设备收集个人图像、身份识别信息, 了解其收集目的, 是否只用于维护公共安全目的; 2) 若存在其他使用目的, 检查是否获得个人单独同意。
	c) 开展业务活动时是否限定使用人脸识别技术作为身份鉴别的唯一方式, 并且当用	人员访谈 安全核查	1) 访谈相关人员, 询问是否存在使用人脸识别技术的场景; 2) 检查相关系统, 查看是否提供人脸识别方式和非人脸识别方式, 并由自然人选择使用; 3) 若将人脸识别技术作为唯一方式的, 检查是否符合法律法规规定场景、保护公共利益或个人重大利益场景。

安全子类	识别要素	评估方法	判定依据
	户拒绝人脸识别方式时，是否频繁申请授权干扰用户正常使用；		
	d) 完成身份鉴别后，应及时删除身份鉴别过程中收集、使用的人脸相关数据，仅用于比对的生物特征模板或法律法规另有规定的除外；	人员访谈 安全核查	1) 访谈相关人员，询问是否在完成身份鉴别后，直接删除身份鉴别过程中收集、使用的人脸原始数据； 2) 检查相关存储空间，查看是否存留人脸识别原始数据。
	e) 是否满足人脸识别有关政策规定。	人员访谈 文档查验	1) 询问相关人员，处理人脸识别数据前，是否开展个人信息保护影响评估； 2) 检查相关评估报告，是否覆盖目的、必要性、法律法规、安全保护等方面的内容。

表2-20 个人信息主体权利评估表

安全子类	识别要素	评估方法	判定依据
个人信息的查阅、	a) 个人信息处理者是否为用户提供查阅其个人	人员访谈 安全核查	1) 询问相关人员，是否为用户提供查询其个人信息的途径； 2) 检查查阅个人信息的途径是否便捷有效，且在三十天内或法律法规规定的期限内作出答复。

安全子类	识别要素	评估方法	判定依据
复制、可携带	信息的途径，是否可及时提供个人信息查阅；		
	b) 是否为个人提供复制其个人信息的途径，是否可及时提供个人信息复制；	人员访谈 安全核查	1) 询问相关人员，是否为个人提供复制其个人信息的途径； 2) 检查复制个人信息的途径，查看是否有效且且在三十天内或法律法规规定的期限内作出答复。。
	c) 个人请求将个人信息转移至其指定的个人信息处理者，符合国家网信部门规定条件的，个人信息处理者是否提供转移的方法。	人员访谈 安全核查	1) 询问相关人员，是否在符合国家网信部门规定条件下，为个人提供个人信息转移的方法； 2) 检查相关方法是否有效。
个人信息的更正、补充	a) 个人信息处理者是否个人提供请求个人信息更正、补充的途径；	人员访谈 安全核查	1) 询问相关人员，是否为个人提供请求个人信息更正、补充的途径； 2) 检查相关途径是否有效。
	b) 个人请求	人员访谈	1) 询问相关人员，当个人请求更正、补充其个人信

安全子类	识别要素	评估方法	判定依据
	更正、补充其个人信息的，个人信息处理者是否对其个人信息予以核实，是否及时更正、补充。	安全核查 技术测试	息时，是否对其个人信息予以核实； 2) 检查是否为更正个人信息或注销用户账号设置不必要或不合理条件； 3) 检查响应是否在承诺时限（承诺时限不得超过 15 个工作日，无承诺时限的，以 15 个工作日为限）内完成； 4) 检查更正、删除个人信息或注销用户账号等用户操作已执行完毕后，后台是否仍保留数据。
个人信息的删除	a) 个人信息处理目的已实现、无法实现或者为实现处理目的不再必要时；	人员访谈 文档查验 安全核查	1) 检查相关管理制度和规程，查看是否包含个人信息处理目的已实现、无法实现或者为实现处理目的不再必要时的个人信息删除条款及操作规程。 2) 访谈相关人员，是否存在个人信息处理目的已实现、无法实现或者为实现处理目的不再必要时的个人信息场景，检查个人信息是否进行删除处理。
	b) 个人信息处理者停止提供产品或者服务，或者保存期限已届满；	人员访谈 文档查验 安全核查	1) 检查相关管理制度和规程，查看是否包含停止提供产品或者服务，或者保存期限已届满时的个人信息删除条款及操作规程。 2) 访谈相关人员，是否存在停止产品或者服务，或者保存期限已满的情况，检查个人信息是否进行删除处理。
	c) 个人撤回同意；	人员访谈 文档查验 安全核查	1) 检查相关管理制度和规程，查看是否包含个人撤回同意时的个人信息删除条款及操作规程。 2) 访谈相关人员，是否个人撤回同意（包含账号注销）的情况，检查个人信息是否进行删除处理。
	d) 个人信息处理者违反法律、行政法规或者违反约定处理个	人员访谈 安全核查	1) 访谈相关个人人员，是否存在违反法律、行政法规或者违反约定处理个人信息的情况； 2) 出现上述情况后，是否开展个人删除工作，并检查相关删除记录。

安全子类	识别要素	评估方法	判定依据
	人信息。		
其他个人信息权利	a) 个人信息处理者是否对个人提供对其个人信息处理规则进行解释说明的途径；	人员访谈 安全核查	1) 访谈相关人员，是否对个人提供对其个人信息处理规则进行解释说明的途径； 2) 检查相关途径是否有效。
	b) 自然人死亡的，其近亲属为了自身的合法、正当利益，是否可对死者相关个人信息进行查阅、复制、更正、删除等，死者生前另有安排的除外；	人员访谈 安全核查	1) 访谈相关人员是否在自然人死亡时，为近亲属提供可对死者相关个人信息进行查阅、复制、更正、删除等渠道； 2) 检查相关渠道是否有效。
	c) 是否建立便捷的个人行使权利的申请受理和处理机制，拒绝个人行使权利请求的，是否说明理由。	人员访谈 安全核查	1) 访谈相关人员，询问是否建立便捷的个人行使权利的申请受理和处理机制； 2) 查看相关机制是否有效； 3) 检查处理记录，在拒绝个人行使权利的请求时，是否给出了充分合理的理由，并向个人提供投诉的途径。

表2-21 个人信息安全义务评估表

安全子类	识别要素	评估方法	判定依据
个人信息保护措施	a) 个人信息保护内部管理制度和操作规程的建设落实情况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否制定个人信息保护内部管理制度和操作规程; 2) 检查个人信息保护内部管理制度和操作规程, 是否涵盖个人信息全生命周期、用户权益保障、应急响应、安全事件处置等方面。
	b) 对个人信息分类管理实施情况及效果;	人员访谈 文档查验 安全核查	1) 检查分级分类管理制度, 是否包含个人信息分类管理分级保护的情况; 2) 检查相关落实情况。
	c) 加密、去标识化等安全技术措施应用情况;	安全核查	1) 检查是否对个人信息采用加密、去标识化等安全技术。
	d) 是否合理确定个人信息处理的操作权限;	文档查验	1) 检查是否制定个人信息操作权限规程, 合理分配个人信息的操作权。
	e) 个人信息安全事件应急预案制定及组织实施情况;	人员访谈 文档查验	1) 访谈相关人员, 是否制定个人信息安全事件应急预案; 2) 查看是否存在应急演练、应急处置相关记录。
	f) 是否在展示、公开等环节, 对个人信息直接标识符进行去标识化处理;	安全核查	1) 检查在个人信息展示、公开等环节, 是否对个人信息直接标识符 (参见 GB/T 37964-2019) 进行去标识化处理。
	g) 是否定期对	人员访谈	1) 访谈相关人员, 是否定期对其处理个人信息遵守

安全子类	识别要素	评估方法	判定依据
	其处理个人信息遵守法律、行政法规的情况进行合规审计。	文档查验	法律、行政法规的情况进行合规审计； 2) 查看个人信息保护合规审计报告。
个人信息保护负责人	a) 处理个人信息达到国家网信部门规定数量的个人信息处理者的个人信息保护负责人设置情况，能否负责对个人信息处理活动以及采取的保护措施等进行监督；	人员访谈 文档查验	1) 当处理个人信息达到国家网信部门规定数量时，检查是否设备个人信息保护负责人； 2) 检查相关负责人职责中是否包含对个人信息处理活动以及采取的保护措施等进行监督的要求。
	b) 是否公开个人信息保护负责人的联系方式，是否将个人信息保护负责人的姓名、联系方式等报送网信部门。	人员访谈 文档查验	1) 当处理个人信息达到国家网信部门规定数量时，是否公开个人信息保护负责人的联系方式，查看其公开途径； 2) 询问是否将个人信息保护负责人的姓名、联系方式等报送履行个人信息保护职责的部门。
个人信息保护影响	a) 是否在处理敏感个人信息、利用个人信息进行自动	人员访谈 文档查验	1) 访谈相关人员，询问是否制定个人信息安全影响评估制度，评估并处置个人信息处理活动存在的安全风险； 2) 查看相关制度和报告，检查是否覆盖处理敏感个

安全子类	识别要素	评估方法	判定依据
评估	化决策、委托处理个人信息、向其他个人信息处理者提供个人信息、公开个人信息、向境外提供个人信息前进行个人信息保护影响评估；		人信息、利用个人信息进行自动化决策、委托处理个人信息、向其他个人信息处理者提供个人信息、公开个人信息、向境外提供个人信息等场景。
	b) 个人信息保护影响评估内容是否符合《个人信息保护法》第 56 条要求；	人员访谈 文档查验	1) 检查个人信息保护影响评估报告，查看是否包含个人信息的处理目的、处理方式等是否合法、正当、必要，对个人权益的影响及安全风险以及所采取的保护措施是否合法、有效并与风险程度相适应等方面的内容。
	c) 是否对个人信息处理情况进行记录，个人信息保护影响评估报告和处理情况记录是否至少保存三年。	人员访谈 文档查验	1) 访谈相关人员，是否对个人信息处理情况进行记录，了解个人信息保护影响评估报告和处理情况记录的保存情况； 2) 相关报告和记录是否至少能够保存三年。
个人信息安全应急	a) 个人信息安全事件应急预案制定及组织实施情况；	人员访谈 文档查验	1) 访谈相关人员，是否制定个人信息安全事件应急预案； 2) 查看是否存在应急演练、应急处置相关记录。

安全子类	识别要素	评估方法	判定依据
	b) 发生或者可能发生个人信息泄露、篡改、丢失时，是否立即采取补救措施；	文档查验	1) 检查个人信息安全事件应急预案，查看当发生个人信息泄露、篡改、丢失时，是否制定了补救措施； 2) 若发生过相关安全事件，查看补救措施是否及时有效。
	c) 个人信息安全事件是否通知所涉及个人并报告有关部门，事件通知是否包含信息种类、原因、可能造成的危害、补救措施、个人信息处理者联系方式等。	文档查验	1) 检查个人信息安全事件应急预案，查看是否包含通知所涉及个人并报告有关部门的流程，以及通知的内容是否包含信息种类、原因、可能造成的危害、补救措施、个人信息处理者联系方式等； 2) 若实际发生过安全事件则检查相关处置记录是否完整。

表2-22 个人信息投诉举报评估表

安全子类	识别要素	评估方法	判定依据
个人信息 投诉 举报 投诉	a) 对违反个人信息保护相关规定行为的投诉举报渠道建设情况，包括是否建设便捷的投诉举报渠	人员访谈 安全核查	1) 询问相关人员，是否建立投诉管理机制和投诉跟踪流程； 2) 检查相关投诉举报渠道是否正常可用； 3) 检查相关处置记录是否在规定的时限内（承诺时限不得超过15个工作日，无承诺时限的，以15个工作日为限）受理并处理。

安全子类	识别要素	评估方法	判定依据
	道，是否及时受理、处置相关投诉举报；		
	b) 是否公布接受投诉、举报的联系方式；	安全核查	1) 检查是否在公开渠道公布接受投诉、举报的联系方式。
	c) 用户投诉、举报后，是否在承诺时限内受理并处理。	人员访谈 安全核查	1) 检查相关处置记录是否在规定的时限内（承诺时限不得超过 15 个工作日，无承诺时限的，以 15 个工作日为限）受理并处理。

附录 2.2 预训练数据和优化训练数据风险识别表

附录 2.2.1 数据安全管理制度评估表

表2-23 安全管理制度评估表

安全子类	识别要素	评估方法	判定依据
数据安全制度体系	a) 人工智能预训练和优化训练数据的安全管理制度制定情况,包含对预训练数据和优化训练数据的保护组织、分类分级规则、数据处理活动安全、数据安全事件应急响应等;	人员访谈 文档查验	1) 访谈相关人员,询问是否制定了针对预训练和优化训练数据的安全管理制度,是否包含数据保护组织、分类分级规则、数据处理活动安全、应急响应等内容。 2) 查看相关策略文档,确认是否覆盖预训练和优化训练数据的全生命周期安全管理要求。

表2-24 安全组织机构评估表

安全子类	识别要素	评估方法	判定依据
数据安全组织架构	a) 预训练和优化训练数据安全管理制度团队及监督	人员访谈 文档查验	1) 访谈相关人员,询问是否设立专门的数据安全管理团队或监督职能部门,负责预训练和优化训练数据的安全管理。 2) 查看组织架构图、岗位职责说明等文档,确认团队

安全子类	识别要素	评估方法	判定依据
	职能部门 的设置情况。		设置和职责分工。

表2-25 人员安全管理评估表

安全子类	识别要素	评估方法	判定依据
数据安全 培训	a) 对涉及预训练和优化训练数据处理的关键岗位的定期培训和考核情况。	人员访谈 文档查验	1) 访谈相关人员，询问是否对涉及预训练和优化训练数据处理的关键岗位人员开展定期培训和考核。 2) 查看培训计划、培训记录、考核记录等材料。

附录 2.2.2 数据处理活动评估表

附录 2.2.2.1 预训练数据处理活动评估表

表2-26 数据收集评估表

安全子类	识别要素	评估方法	判定依据
数据收集合法性	a) 对自行收集的预训练数据, 不应采集他人已明确不可采集的数据;	人员访谈 文档查验 安全核查	1) 访谈数据收集负责人, 询问数据收集的来源渠道, 并了解是否有机制或流程用于识别和规避“不可采集的数据”(如 robots 协议禁止爬取、网站声明禁止收集、涉及国家安全或商业秘密的数据等)。 2) 查看数据收集流程文档或管理制度, 查验是否明确禁止采集此类数据的要求。 3) 抽样检查实际采集的数据集, 核查是否包含明显属于“不可采集”范围的数据。
	b) 收集开源数据集时, 应遵循该数据集的开源许可协议或取得使用授权文件。	人员访谈 文档查验	1) 访谈数据管理人员, 询问收集开源数据集时, 是否检查并遵循其开源许可协议(如 GPL、Apache、MIT 等)。 2) 查看开源数据集的使用记录, 核查是否保存了对应的开源许可协议文本或授权文件。 3) 核查数据使用场景是否与许可协议的要求(如署名、开源衍生作品等)相符。
	c) 对从外部数据源收集的预训练数据, 应记录数据收集所涉及的数据来源(数据来源为互联网网	人员访谈 文档查验	1) 访谈数据收集人员, 了解从外部数据源收集数据的流程, 并询问是否建立了数据来源记录机制。 2) 查看数据资产台账或来源记录文件, 查验记录内容是否完整, 包括: - 互联网网站来源: 是否记录 URL; - 外部组织/个人来源: 是否记录数据集名称、来源组织, 并保存合同、协议或授权文件; - 服务使用者来源: 是否保存授权记录, 并记录服务名

安全子类	识别要素	评估方法	判定依据
	站的，记录网站的统一资源定位符；数据来源为外部组织或个人的，记录数据集名称、来源组织，保存具备法律效力的交易合同、合作协议、许可协议或相关授权文件等；数据来源为服务使用者的，具有服务使用者的授权记录，并记录服务名称、服务使用者的标识。)		称和用户标识。 3) 抽样核对来源记录与保存的证明文件是否匹配一致。
	d) 所采集数据涉及个人信息的，应取得对应个人的同意或符合法律、行政法规规定的	人员访谈 文档查验	1) 访谈数据合规负责人，询问如何识别数据中是否包含个人信息/敏感个人信息，以及对应的合规处理流程。 2) 查看隐私政策、用户协议等文件，确认其中是否明确告知了个人信息收集使用的目的、方式等。 3) 查验涉及个人信息（尤其是敏感个人信息）的数据收集活动，是否留存了有效的同意记录（如勾选同意日志、授权签字文件等）或符合法定豁免情形的评估记

安全子类	识别要素	评估方法	判定依据
	其他情形；所采集数据涉及敏感个人信息的，应取得对应个人的单独同意或符合法律、行政法规规定的其他情形；		录。
	e) 涉及数据跨境收集时，应符合相关数据跨境安全法规和标准要求。	人员访谈 文档查验	1) 访谈相关人员，询问是否存在数据跨境收集活动（如从境外服务器直接采集数据至境内）。 2) 若存在，查验是否按照国家网信部门规定，通过了数据出境安全评估、签订了标准合同或通过了个人信息保护认证。 3) 查看相关申报材料、评估报告、标准合同或认证证书。
通过第三方收集数据	a) 通过交易或合作等方式从其他组织或个人收集数据时，应对交易方或合作方所提供的数据、承诺以及相关证明材料进行审核。	人员访谈 文档查验	1) 访谈数据合作负责人，询问是否建立对数据供应方的审核机制及流程。 2) 查看数据合作方管理制度，查验是否明确审核要求。 3) 抽查数据交易/合作合同及对供应方资质、授权文件等证明材料的审核记录。

表2-27 数据预处理评估表

安全子类	识别要素	评估方法	判定依据
数据预处理安全性	a) 应确保预处理环境的安全性,进行数据处理的平台和工具安全性应与数据等级对应。	人员访谈 文档查验	1) 访谈运维或数据平台负责人,询问数据预处理环境(如开发测试平台、数据标注平台)的安全配置情况,是否依据数据分类分级结果设定不同的安全基线。 2) 查看预处理环境的安全配置文档或核查实际环境,验证其网络隔离、访问控制、漏洞修复等安全措施是否与所处理数据的最高级别相匹配。
	b) 宜定期对数据处理活动中涉及的平台和工具进行安全测试,防范安全风险和漏洞。	人员访谈 文档查验	1) 访谈安全管理人员,询问是否定期对数据预处理平台、工具及依赖组件进行安全测试(如漏洞扫描、渗透测试)。 2) 查看近期的安全测试报告、漏洞修复记录,验证测试周期和发现问题的整改情况。
	c) 应采用安全的传输、存储技术保障数据预处理活动安全。	人员访谈 安全核查	1) 访谈技术人员,了解数据在预处理各环节(如采集后传输至预处理平台、平台内流转、预处理后存储)是否采用加密等安全技术。 2) 核查网络传输配置(如 TLS/SSL)和存储系统配置(如存储加密),验证安全措施的有效性。
	d) 对预处理活动中涉及的个人信息,宜采取去标识化处理,并将可用于恢复识别个人	人员访谈 文档查验 安全核查	1) 访谈数据开发人员,询问对预处理中的个人信息是否进行去标识化处理,并了解密钥或映射表的管理方式。 2) 查看数据存储架构和访问权限设置,验证去标识化后的数据与原始标识信息或映射表是否物理或逻辑隔离,并查验访问权限是否遵循最小授权原则。

安全子类	识别要素	评估方法	判定依据
	的信息与去标识化后的信息隔离存储并加强访问和使用的权限管理。		
数据预处理的知识产权风险	a) 对训练数据中的主要知识产权侵权风险进行识别和管理： 1) 应制定和完善训练数据知识产权管理策略和规则，并明确负责人； 2) 数据用于训练前，发现存在知识产权侵权等问题的，不应使用相关数据进行训练； 3) 应建立针对知识产权问题的投诉举报渠道，并及时根据国	人员访谈 文档查验	1) 访谈知识产权或法务负责人，询问是否制定训练数据知识产权管理策略，并明确管理职责和流程。 2) 查看知识产权管理策略文档，检查是否包含风险识别、数据筛查、投诉处理、策略更新等要求。 3) 查看数据入库或训练前的筛查记录，验证是否存在对疑似侵权数据的识别和处置流程。 4) 检查公开的投诉举报渠道（如官网邮箱、电话）及近期的投诉处理记录。 5) 查看用户服务协议或生成内容使用条款，核实是否包含知识产权风险提示和责任约定。

安全子类	识别要素	评估方法	判定依据
	家政策以及 第三方投诉 情况更新知 识产权相关 策略; 4) 应在用户 服务协议中, 向使用者告 知使用生成 内容的知识 产权相关风 险, 并与使用 者约定相关 责任与义务。		

附录 2.2.2.2 优化训练数据处理活动评估表

表2-28 数据收集评估表

安全子类	识别要素	评估方法	判定依据
数据收集合法性	a) 对自行收集的优化训练数据, 不应采集他人已明确不可采集的数据;	人员访谈 文档查验	1) 访谈数据收集负责人, 询问数据收集的来源渠道, 并了解是否有机制或流程用于识别和规避“不可采集的数据”(如 robots 协议禁止爬取、网站声明禁止收集、涉及国家安全或商业秘密的数据等)。 2) 查看数据收集流程文档或管理制度, 查验是否明确禁止采集此类数据的要求。 3) 抽样检查实际采集的数据集, 核查是否包含明显属于“不可采集”范围的数据。
	b) 收集开源数据集时, 应遵循该数据集的开源许可协议或取得使用授权文件。	人员访谈 文档查验	1) 访谈数据管理人员, 询问收集开源数据集时, 是否检查并遵循其开源许可协议(如 GPL、Apache、MIT 等)。 2) 查看开源数据集的使用记录, 核查是否保存了对应的开源许可协议文本或授权文件。 3) 核查数据使用场景是否与许可协议的要求(如署名、开源衍生作品等)相符。
	c) 对从外部数据源收集的优化训练数据, 应记录数据收集所涉及的数据来源(数据来源为互联网网站的, 记录网站的统一	人员访谈 文档查验	1) 访谈数据收集人员, 了解从外部数据源收集数据的流程, 并询问是否建立了数据来源记录机制。 2) 查看数据资产台账或来源记录文件, 查验记录内容是否完整, 包括: - 互联网网站来源: 是否记录 URL; - 外部组织/个人来源: 是否记录数据集名称、来源组织, 并保存合同、协议或授权文件; - 服务使用者来源: 是否保存授权记录, 并记录服务名称和用户标识。 3) 抽样核对来源记录与保存的证明文件是否匹配一

安全子类	识别要素	评估方法	判定依据
	资源定位符；数据来源为外部组织或个人的，记录数据集名称、来源组织，保存具备法律效力的交易合同、合作协议、许可协议或相关授权文件等；数据来源为服务使用者的，具有服务使用者的授权记录，并记录服务名称、服务使用者的标识。）		致。
	d) 所采集数据涉及个人信息的，应取得对应个人的同意或符合法律、行政法规规定的其他情形；所采集数据涉	人员访谈 文档查验	1) 访谈数据合规负责人，询问如何识别数据中是否包含个人信息/敏感个人信息，以及对应的合规处理流程。 2) 查看隐私政策、用户协议等文件，确认其中是否明确告知了个人信息收集使用的目的、方式等。 3) 查验涉及个人信息（尤其是敏感个人信息）的数据收集活动，是否留存了有效的同意记录（如勾选同意日志、授权签字文件等）或符合法定豁免情形的评估记录。

安全子类	识别要素	评估方法	判定依据
	及敏感个人信息的,应取得对应个人的单独同意或符合法律、行政法规规定的其他情形;		
	e) 涉及数据跨境收集时,应符合相关数据跨境安全法规和标准要求;	人员访谈 文档查验	1) 访谈相关人员,询问是否存在数据跨境收集活动(如从境外服务器直接采集数据至境内)。 2) 若存在,查验是否按照国家网信部门规定,通过了数据出境安全评估、签订了标准合同或通过了个人信息保护认证。 3) 查看相关申报材料、评估报告、标准合同或认证证书。
	f) 收集垂直领域的优化训练数据时,应符合垂直领域的行业规定。	人员访谈 文档查验 安全核查	1) 访谈数据合规或业务负责人,询问收集特定垂直领域(如金融、医疗、教育等)数据时,是否识别并遵循了相关行业监管规定(如行业数据分类分级指南、安全管理要求等)。 2) 查看数据收集方案或合规评估记录,查验是否针对垂直领域行业规定进行了符合性分析。 3) 抽查垂直领域优化训练数据样本,核查其处理活动(如收集的个人信息类型、数据使用范围等)是否符合对应行业规定。
通过 第三 方收 集数	a) 通过交易或合作等方式从其他组织或个人收集数据时,应	人员访谈 文档查验	1) 访谈数据合作负责人,询问是否建立对数据供应方的审核机制及流程。 2) 查看数据合作方管理制度,查验是否明确审核要求。 3) 抽查数据交易/合作合同及对供应方资质、授权文件等证明材料的审核记录。

安全子类	识别要素	评估方法	判定依据
据	对交易方或合作方所提供的数据、承诺以及相关证明材料进行审核。		

表2-29 数据预处理评估表

安全子类	识别要素	评估方法	判定依据
数据预处理安全性	a) 应确保预处理环境的安全性，进行数据处理的平台和工具安全性应与数据等级对应。	人员访谈 文档查验	1) 访谈运维或数据平台负责人，询问数据预处理环境（如开发测试平台、数据标注平台）的安全配置情况，是否依据数据分类分级结果设定不同的安全基线。 2) 查看预处理环境的安全配置文档或核查实际环境，验证其网络隔离、访问控制、漏洞修复等安全措施是否与所处理数据的最高级别相匹配。
	b) 宜定期对数据处理活动中涉及的平台和工具进行安全测试，防范安全风险和漏洞。	人员访谈 文档查验	1) 访谈安全管理人员，询问是否定期对数据预处理平台、工具及依赖组件进行安全测试（如漏洞扫描、渗透测试）。 2) 查看近期的安全测试报告、漏洞修复记录，验证测试周期和发现问题的整改情况。
	c) 应采用安全的传输、存储技术保障数据预处理活动安全。	人员访谈 安全核查	1) 访谈技术人员，了解数据在预处理各环节（如采集后传输至预处理平台、平台内流转、预处理后存储）是否采用加密等安全技术。 2) 核查网络传输配置（如 TLS/SSL）和存储系统配置（如存储加密），验证安全措施的有效性。

安全子类	识别要素	评估方法	判定依据
	d) 对预处理活动中涉及的个人信息的，宜采取去标识化处理，并将可用于恢复识别个人的信息与去标识化后的信息隔离存储并加强访问和使用的权限管理。	人员访谈 文档查验 安全核查	1) 访谈数据开发人员，询问对预处理中的个人信息是否进行去标识化处理，并了解密钥或映射表的管理方式。 2) 查看数据存储架构和访问权限设置，验证去标识化后的数据与原始标识信息或映射表是否物理或逻辑隔离，并查验访问权限是否遵循最小授权原则。
数据预处理的知识产权风险	a) 对训练数据中的主要知识产权侵权风险进行识别和管理： 1) 应制定和完善训练数据知识产权管理策略和规则，并明确负责人； 2) 数据用于训练前，发现存在知识产权侵权等问题的，不应使用相关数据进行	人员访谈 文档查验	1) 访谈知识产权或法务负责人，询问是否制定训练数据知识产权管理策略，并明确管理职责和流程。 2) 查看知识产权管理策略文档，检查是否包含风险识别、数据筛查、投诉处理、策略更新等要求。 3) 查看数据入库或训练前的筛查记录，验证是否存在对疑似侵权数据的识别和处置流程。 4) 检查公开的投诉举报渠道（如官网邮箱、电话）及近期的投诉处理记录。 5) 查看用户服务协议或生成内容使用条款，核实是否包含知识产权风险提示和责任约定。

安全子类	识别要素	评估方法	判定依据
	训练; 3) 应建立针对知识产权问题的投诉举报渠道,并及时根据国家政策以及第三方投诉情况更新知识产权相关策略; 4) 应在用户服务协议中,向使用者告知使用生成内容的知识产权相关风险,并与使用者约定相关责任与义务。		

附录 2.2.3 数据安全技术评估表

表2-30 训练数据安全技术评估表

安全子类	识别要素	评估方法	判定依据
训练数据安全技术	a) 训练阶段的数据应按照每批次进行安全隔离并在批次间建立数据标识, 保证训练数据内容的可追溯性;	人员访谈 文档查验 安全核查	1) 访谈算法平台负责人, 询问训练任务的数据调度机制, 是否实现不同批次数据的隔离(如独立存储路径、容器环境)。 2) 查看训练任务日志或元数据管理记录, 检查是否包含批次 ID、数据版本、来源等唯一标识信息。
	b) 对开展训练和优化训练数据处理活动的系统或平台满足等级保护的情况;	人员访谈 文档查验	1) 访谈安全负责人, 询问训练平台是否定级并完成网络安全等级保护测评。 2) 查验该系统的等级保护备案证明及最近一次的测评报告。
	c) 涉及行业数据的, 应按照行业相关规定及行业标准要求采取相应的保护措施;	人员访谈 文档查验	1) 访谈数据合规负责人, 询问是否识别训练数据中涉及的行业数据(如金融、医疗), 并了解对应的行业监管要求。 2) 查看数据保护措施记录, 核查是否针对行业数据实施了超越通用要求的特定保护(如医疗数据的匿名化、金融数据的加密强度)。
	d) 宜对预训练和优化训练数据进行安全检测, 修复或过滤被投毒数	人员访谈 文档查验	1) 访谈数据安全或算法团队人员, 询问是否建立数据投毒检测机制(如异常样本检测、数据质量监控)。 2) 查看数据安全检测规程、检测报告或相关日志, 验证是否对投毒数据进行了识别与处置。

安全子类	识别要素	评估方法	判定依据
	据，包括但不限于以下情况： 1) 攻击者以降低算法模型整体表现为目的，置入大量标注错误或与设计开发目的无关的投毒数据； 2) 攻击者以使算法模型对特定数据给出错误输出为目的，置入部分具备特定特征的投毒数据；		
	e) 数据存储时应建立冗余备份等安全防护措施；	人员访谈 文档查验	1) 访谈运维负责人，询问训练数据的存储方案，是否实现冗余备份（如多副本、异地备份）。 2) 查看存储架构图和备份策略文档，核查备份机制的有效性与恢复流程。
	f) 数据传输过程中，应采取数据加密等安全防护措施，防范数据在传输过程中被窃取。	人员访谈 安全核查	1) 访谈网络或平台运维人员，询问训练数据在节点间、组件间传输时是否启用加密（如 HTTPS, SSL/TLS）。 2) 核查网络传输配置或抓包验证，确认传输通道的加密措施已生效。

附录 2.3 生成内容风险识别表

附录 2.3.1 数据处理活动评估表

表2-31 数据传输评估表

安全子类	识别要素	评估方法	判定依据
传输链路安全性	a) 数据传输安全策略和操作规程的建设落实情况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否制定数据传输安全策略, 明确数据传输操作规程; 2) 查看相关制度文件、操作规程, 是否明确数据传输的安全性和可靠性等要求。
	b) 敏感个人信息和重要数据传输加密情况及加密措施有效性, 是否选用安全的密码算法;	人员访谈 安全核查	1) 访谈相关人员, 询问是否基于数据分类分级, 识别敏感个人信息和重要数据; 是否对敏感个人信息和重要数据传输采取加密措施; 是否选用安全的密码算法; 2) 核查敏感个人信息和重要数据传输实际加密情况, 如是否禁用了 MD5、DES-CBC、SHA1 等不安全的算法。
	c) 个人信息和重要数据传输进行完整性保护情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否基于数据分类分级, 识别个人信息和重要数据; 是否对个人信息和重要数据传输采取完整性保护措施。 2) 核查个人信息和重要数据传输实际完整性保护情况, 如通过截包、中间人劫持等技术手段验证完整性保护措施的有效性。
	d) 数据传输通道部署身份鉴别、安全配置、密码算法配置、密钥管理等防护措施情	人员访谈 技术测试	1) 访谈相关人员, 了解数据传输的场景, 询问是否根据合规要求明确需要加密传输通道的安全要求; 2) 检查现有的传输通道是否部署身份鉴别、数据加密 (如 TLS/SSL 方式) 的安全措施。 3) 涉及数据加密时, 通过技术手段进一步检查密码算法配置的情况。

安全子类	识别要素	评估方法	判定依据
	况;		
	e) 数据传输、接收的记录和安全审计情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否对数据传输、接收进行记录和安全审计; 2) 核查相关日志及审计报告。
	f) 采取安全传输协议等安全措施情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否采取数据加密、安全传输通道或安全传输协议进行数据传输; 2) 核查相关信息系统、传输链路, 是否采用 https 等协议。
	g) 数据异常传输检测发现及处置情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否具备对数据传输进行检测的能力和机制; 发现异常, 是否能够及时处置; 2) 核查相关监测预警技术措施, 是否能对数据异常传输进行发现和处置。
	h) 制定数据跨组织传输管理规则, 及跨组织数据传输安全技术措施建立情况。	人员访谈 文档查验 安全核查	1) 访谈相关人员, 询问是否涉及数据跨组织传输, 如数据传输至其他组织进行数据共享等; 是否制定数据跨组织传输管理规则; 2) 查看相关制度文件、操作规程, 是否明确数据跨组织传输的安全要求、技术措施等; 3) 核查相关技术手段是否满足安全要求。
传输链路可靠性	a) 网络传输链路的可用情况, 包括对关键网络传输链路、网络设备节点实行冗余建设, 建立容灾方案和宕机替代方案等情况;	人员访谈 文档查验	1) 访谈相关人员, 询问网络传输链路的可用情况, 包括对关键网络传输链路、网络设备节点实行冗余建设, 建立容灾方案和宕机替代方案等情况; 2) 查看相关设计、建设方案, 是否满足网络传输链路的可用性。

安全子类	识别要素	评估方法	判定依据
	b) 点对点传输中是否存在传输经过第三方、被第三方缓存情况。	人员访谈 文档查验	1) 访谈相关人员，询问点对点传输中是否存在传输经过第三方、被第三方缓存情况； 2) 查看相关设计、建设方案，结合网络拓扑，分析判断是否存在传输经过第三方、被第三方缓存情况。

表2-32 数据删除评估表

安全子类	识别要素	评估方法	判定依据
数据删除管理	a) 数据删除流程和审批机制的建设落实情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否建立数据删除流程和审批机制； 2) 查看相关制度文件、工作流程、审批记录，核实是否规范了删除流程，并落实了审批机制。
	b) 数据删除安全策略和操作规程，是否明确数据销毁对象、原因、销毁方式和销毁要求及对应操作规程；	文档查验	1) 查看相关数据删除安全策略和操作规程，如数据删除申请单等，核实是否明确数据销毁对象、原因、销毁方式和销毁要求及对应操作规程；
	c) 是否按照法律法规、合同约定、隐私政策等及时删除数据；	人员访谈 文档查验	1) 访谈相关人员，询问是否基于数据分类分级，明确数据存储期限，并于存储期限到期后及时删除数据； 2) 查看相关数据删除审批单、操作日志等，是否与法律法规、合同约定、隐私政策等要求相一致。
	d) 委托第三方进行数据处理的，是否在委	人员访谈 文档查验	1) 访谈相关人员，询问是否委托第三方进行数据处理；是否在委托结束后要求并监督第三方删除或返还数据。

安全子类	识别要素	评估方法	判定依据
	托结束后监督第三方删除或返还数据；		2) 查看相关合同约定、删除审批、返还记录等，核实是否在委托结束后监督第三方删除或返还数据。
	e) 数据删除有效性、彻底性验证情况，以及可能存在的多副本同步删除情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否采取技术措施，对数据删除有效性、彻底性进行验证，并对可能存在的多副本进行同步删除； 2) 查看相关数据删除操作规程、审批日志等，是否涵盖数据删除有效性、彻底性验证，是否对可能存在的多副本进行同步删除。
	f) 是否明确数据存储期限，并于存储期限到期后按期删除数据，明确不可删除数据的类型及原因；	人员访谈 文档查验	1) 访谈相关人员，询问是否明确各类数据存储期限，并于存储期限到期后按期删除数据，同时明确不可删除数据的类型及原因； 2) 查看相关数据安全管理制度、删除审批等，核实是否涵盖数据存储期限，是否在存储期限到期后按期删除数据，是否明确不可删除数据的类型及原因。
	g) 缓存数据、到期备份数据的删除情况。	人员访谈 文档查验	1) 访谈相关人员，询问是否对缓存数据、到期备份数据进行删除； 2) 查看相关数据安全管理制度、数据删除操作规程、审批日志等，是否涵盖对缓存数据、到期备份数据的删除要求。
存储介质销毁	a) 存储介质销毁管理制度和审批机制的建设落实情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否建立存储介质销毁管理制度和审批机制； 2) 查看相关制度文件、工作流程、审批记录等，核实是否覆盖存储介质销毁管理，并落实了审批机制。
	b) 介质销毁策略和操作规程，是否明确	文档查验	1) 查看相关介质销毁策略和操作规程，如介质销毁申请单等，核实是否明确各类介质的销毁流程、方式和要求，是否妥善处置销毁的存储介质；

安全子类	识别要素	评估方法	判定依据
	各类介质的销毁流程、方式和要求，是否妥善处置销毁的存储介质；		
	c) 存储介质销毁过程的监控、记录情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否对存储介质销毁过程进行安全监控和记录； 2) 查看相关管理制度、记录台账等，是否明确了对存储介质销毁过程进行监控和记录的要求，核查相关监控、记录台账。
	d) 软硬件资产维护、报废、销毁管理情况等；	人员访谈 文档查验	1) 访谈相关人员，询问是否建立软硬件资产维护、报废、销毁管理制度和操作规程； 2) 查看相关管理制度、记录台账等，核实软硬件资产维护、报废、销毁是否符合管理要求，如建立软硬件资产清单、明确维护人员的责任、维修和服务的审批、维修过程的监督控制等。
	e) 介质销毁措施有效性，是否对被销毁的存储介质进行数据恢复验证；	人员访谈 文档查验	1) 访谈相关人员，询问是否采取技术措施，对介质销毁有效性进行验证，并对被销毁的存储介质进行数据恢复验证； 2) 查看相关介质销毁操作规程、审批日志等，是否涵盖介质销毁有效性验证，是否对被销毁的存储介质进行数据恢复验证。
	f) 是否按照数据分类分级，明确不同级别数据适当的删除措施，核心数据删除是否采用存储介质	人员访谈 文档查验	1) 访谈相关人员，询问是否对数据进行分类分级，明确不同级别数据适当的删除措施，核心数据删除是否采用存储介质销毁方式； 2) 查看相关数据删除、介质销毁安全策略和操作规程，如数据删除申请单、介质销毁申请单等，核实是否根据不同数据级别进行相应的删除措施，核心数据删除是否采用存储介质销毁方式。

安全 子类	识别要素	评估方法	判定依据
	销毁方式。		

附录 2.3.2 数据安全技术评估表

表2-33 数据接口安全评估表

安全子类	识别要素	评估方法	判定依据
对外接口安全	a) 面向互联网及合作方数据接口的接口认证鉴权与安全监控能力建设情况, 是否能够限制违规接入, 是否能对接口调用进行必要的自动监控和处理;	人员访谈 安全核查	1) 访谈相关人员, 了解面向互联网及合作方数据接口是否进行了认证鉴权与安全监控的技术措施; 2) 安全检查, 查验相关技术措施及安全设备, 是否能够限制违规接入, 是否能对接口调用情况进行监控和处置。
	b) API 密钥及密钥安全存储措施设置情况, 能否避免密钥被恶意搜索或枚举;	人员访谈 安全核查	1) 访谈相关人员, 了解 API 密钥的生成方式以及其安全存储措施。 2) 通过测试, 检查 API 密钥是否具备足够的随机性。 3) 通过测试, 检查密钥是否可被恶意搜索, 如批量明文返回前端等。
	c) 不同安全等级系统间、不同区域间跨系统、跨区域数据流动的安全控制措施情况。	人员访谈 安全核查	1) 人员访谈, 询问是否存在不同安全等级系统间、不同区域间跨系统、跨区域数据流动的情况。 2) 进一步了解该情况下数据流动的安全控制措施的实施情况。
接口	a) 接口安全控	人员访谈	1) 查看数据接口设计文档, 看接口规范, 对接口名

安全子类	识别要素	评估方法	判定依据
安全控制	制策略设置情况，是否规定使用数据接口的安全限制和安全控制措施，明确包括接口名称、接口参数等内容的数据接口安全要求；	安全核查	称、接口参数的定义，询问相关技术人员有关数据接口采取的安全措施，如身份鉴别、访问控制、授权策略、签名、时间戳、安全协议等。 2) 核查业务应用系统或者代码，查看数据接口是否制定了接口安全控制策略，核查数据接口采用的安全限制和安全控制措施。
	b) 是否对涉及个人信息和重要数据的传输接口实施调用审批；	人员访谈 文档查验	1) 访谈相关人员、涉及个人信息和重要数据的传输接口是否明确规定实施调用审批制度； 2) 文档查验，检查相关制度文件及审批记录。
	c) 是否定期对接口（特别是对外数据接口）进行清查，清查不符合要求的接口是否立即关停；	人员访谈 文档查验	1) 访谈相关人员，是否制定了定期对接口（特别是对外数据接口）进行清查的相关制度； 2) 查验相关制度及清查记录，对于不符合要求的接口是否立即关停。
	d) 涉及敏感数据的接口调用是否具备安全通道、加密传输、时间戳等安全措施；	人员访谈 安全核查	1) 访谈技术人员，涉及敏感数据的接口调用是否具备安全通道、加密传输、时间戳等安全措施； 2) 技术测试，查验相关技术措施的实现。
	e) 数据接口部	人员访谈	1) 访谈技术人员，数据接口是否部署身份鉴别、访

安全子类	识别要素	评估方法	判定依据
	署身份鉴别、访问控制、授权策略、接口签名、安全传输协议等防护措施情况；	安全核查	问控制、授权策略、接口签名、安全传输协议等防护措施； 2) 技术测试，检验相关技术措施的实现。
	f)对接口类型、名称、参数等安全要求规范情况；	人员访谈 文档查验	1) 访谈技术开发人员，查验接口设计文档，查看是否制定了数据接口安全规范，规范内容包括接口名称、接口参数、接口安全要求等内容；此外针对接口不安全输入参数是否具备限制或过滤能力。
	g)与接口调用方是否明确数据的使用目的、供应方式、保密约定及数据安全责任等情况；	人员访谈 文档查验	1) 访谈相关人员，与接口调用方是否签署相关安全责任书或协议，责任书或协议中是否明确数据的使用目的、供应方式、保密约定及数据安全责任等内容； 2) 文档查验，检查相关协议文件。
	h)是否对接口访问做日志记录，同时对接口异常事件进行告警通知的情况。	人员访谈 文档查验	1) 人员访谈，是否对接口访问做日志记录，并有相关策略或方法能对接口异常事件进行告警通知。 2) 安全核查，查验相关策略和方法，查看事件告警处理记录。

附录 2.4 用户交互数据风险识别表

附录 2.4.1 数据处理活动评估表

表2-34 数据收集评估表

安全子类	识别要素	评估方法	判定依据
数据收集设备及环境安全	a) 客户端敏感信息留存风险，检测 App、Web 等客户端完成相关业务后，是否留存敏感个人信息或重要数据。	安全核查	1) 核查相关配置信息或系统设计文档，敏感数据所在的存储空间被释放或重新分配给其他用户前是否得到完全清除；

表2-35 数据传输评估表

安全子类	识别要素	评估方法	判定依据
传输链路安全性	a) 数据传输安全策略和操作规程的建设落实情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否制定数据传输安全策略，明确数据传输操作规程； 2) 查看相关制度文件、操作规程，是否明确数据传输的安全性和可靠性等要求。
	b) 敏感个人信息和重要数据传输加密情况及加密措施有效性，是否选用安全的密码算法；	人员访谈 安全核查	1) 访谈相关人员，询问是否基于数据分类分级，识别敏感个人信息和重要数据；是否对敏感个人信息和重要数据传输采取加密措施；是否选用安全的密码算法； 2) 核查敏感个人信息和重要数据传输实际加密情况，如是否禁用了 MD5、DES-CBC、SHA1 等不安全的算法。

安全子类	识别要素	评估方法	判定依据
	c) 个人信息和重要数据传输进行完整性保护情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否基于数据分类分级, 识别个人信息和重要数据; 是否对个人信息和重要数据传输采取完整性保护措施。 2) 核查个人信息和重要数据传输实际完整性保护情况, 如通过截包、中间人劫持等技术手段验证完整性保护措施的有效性。
	d) 数据传输通道部署身份鉴别、安全配置、密码算法配置、密钥管理等防护措施情况;	人员访谈 技术测试	1) 访谈相关人员, 了解数据传输的场景, 询问是否根据合规要求明确需要加密传输通道的安全要求; 2) 检查现有的传输通道是否部署身份鉴别、数据加密(如 TLS/SSL 方式)的安全措施。 3) 涉及数据加密时, 通过技术手段进一步检查密码算法配置的情况。
	e) 数据传输、接收的记录和安全审计情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否对数据传输、接收进行记录和安全审计; 2) 核查相关日志及审计报告。
	f) 采取安全传输协议等安全措施情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否采取数据加密、安全传输通道或安全传输协议进行数据传输; 2) 核查相关信息系统、传输链路, 是否采用 https 等协议。
	g) 数据异常传输检测发现及处置情况;	人员访谈 安全核查	1) 访谈相关人员, 询问是否具备对数据传输进行检测的能力和机制; 发现异常, 是否能够及时处置; 2) 核查相关监测预警技术措施, 是否能对数据异常传输进行发现和处置。
	h) 制定数据跨组织传输管理规则, 及跨组织数据传输安	人员访谈 文档查验 安全核查	1) 访谈相关人员, 询问是否涉及数据跨组织传输, 如数据传输至其他组织进行数据共享等; 是否制定数据跨组织传输管理规则; 2) 查看相关制度文件、操作规程, 是否明确数据跨

安全子类	识别要素	评估方法	判定依据
	全技术措施建立情况。		组织传输的安全要求、技术措施等； 3) 核查相关技术手段是否满足安全要求。
传输链路可靠性	a) 网络传输链路的可用情况，包括对关键网络传输链路、网络设备节点实行冗余建设，建立容灾方案和宕机替代方案等情况；	人员访谈 安全核查	1) 访谈相关人员，询问网络传输链路的可用情况，包括对关键网络传输链路、网络设备节点实行冗余建设，建立容灾方案和宕机替代方案等情况； 2) 查看相关设计、建设方案，是否满足网络传输链路的可用性。
	b) 点对点传输中是否存在传输经过第三方、被第三方缓存情况。	人员访谈 安全核查	1) 访谈相关人员，询问点对点传输中是否存在传输经过第三方、被第三方缓存情况； 2) 查看相关设计、建设方案，结合网络拓扑，分析判断是否存在传输经过第三方、被第三方缓存情况。

表2-36 数据删除评估表

安全子类	识别要素	评估方法	判定依据
数据删除管理	a) 数据删除流程和审批机制的建设落实情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否建立数据删除流程和审批机制； 2) 查看相关制度文件、工作流程、审批记录，核实是否规范了删除流程，并落实了审批机制。
	b) 数据删除安全策略和操作规程，是否明确数据销毁对	文档查验	1) 查看相关数据删除安全策略和操作规程，如数据删除申请单等，核实是否明确数据销毁对象、原因、销毁方式和销毁要求及对应操作规程；

安全子类	识别要素	评估方法	判定依据
	象、原因、销毁方式和销毁要求及对应操作规程；		
	c) 是否按照法律法规、合同约定、隐私政策等及时删除数据；	人员访谈 文档查验	1) 访谈相关人员，询问是否基于数据分类分级，明确数据存储期限，并于存储期限到期后及时删除数据； 2) 查看相关数据删除审批单、操作日志等，是否与法律法规、合同约定、隐私政策等要求相一致。
	d) 委托第三方进行数据处理的，是否在委托结束后监督第三方删除或返还数据；	人员访谈 文档查验	1) 访谈相关人员，询问是否委托第三方进行数据处理；是否在委托结束后要求并监督第三方删除或返还数据。 2) 查看相关合同约定、删除审批、返还记录等，核实是否在委托结束后监督第三方删除或返还数据。
	e) 数据删除有效性、彻底性验证情况，以及可能存在的多副本同步删除情况；	人员访谈 文档查验	1) 访谈相关人员，询问是否采取技术措施，对数据删除有效性、彻底性进行验证，并对可能存在的多副本进行同步删除； 2) 查看相关数据删除操作规程、审批日志等，是否涵盖数据删除有效性、彻底性验证，是否对可能存在的多副本进行同步删除。
	f) 是否明确数据存储期限，并于存储期限到期后按期删除数据，明确不可删除数据的类型及原因；	人员访谈 文档查验	1) 访谈相关人员，询问是否明确各类数据存储期限，并于存储期限到期后按期删除数据，同时明确不可删除数据的类型及原因； 2) 查看相关数据安全管理制度、删除审批等，核实是否涵盖数据存储期限，是否在存储期限到期后按期删除数据，是否明确不可删除数据的类型及原因。

安全子类	识别要素	评估方法	判定依据
	g) 缓存数据、到期备份数据的删除情况。	人员访谈 文档查验	1) 访谈相关人员, 询问是否对缓存数据、到期备份数据进行删除; 2) 查看相关数据安全管理制度、数据删除操作规程、审批日志等, 是否涵盖对缓存数据、到期备份数据的删除要求。
存储介质销毁	a) 存储介质销毁管理制度和审批机制的建设落实情况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否建立存储介质销毁管理制度和审批机制; 2) 查看相关制度文件、工作流程、审批记录等, 核实是否覆盖存储介质销毁管理, 并落实了审批机制。
	b) 介质销毁策略和操作规程, 是否明确各类介质的销毁流程、方式和要求, 是否妥善处置销毁的存储介质;	人员访谈 文档查验	1) 查看相关介质销毁策略和操作规程, 如介质销毁申请单等, 核实是否明确各类介质的销毁流程、方式和要求, 是否妥善处置销毁的存储介质;
	c) 存储介质销毁过程的监控、记录情况;	人员访谈 文档查验	1) 访谈相关人员, 询问是否对存储介质销毁过程进行安全监控和记录; 2) 查看相关管理制度、记录台账等, 是否明确了对存储介质销毁过程进行监控和记录的要求, 核查相关监控、记录台账。
	d) 软硬件资产维护、报废、销毁管理情况等;	人员访谈 文档查验	1) 访谈相关人员, 询问是否建立软硬件资产维护、报废、销毁管理制度和操作规程; 2) 查看相关管理制度、记录台账等, 核实软硬件资产维护、报废、销毁是否符合管理要求, 如建立软硬件资产清单、明确维护人员的责任、维修和服务的审批、维修过程的监督控制等。
	e) 介质销毁措施	人员访谈	1) 访谈相关人员, 询问是否采取技术措施, 对介质

安全子类	识别要素	评估方法	判定依据
	施有效性，是否对被销毁的存储介质进行数据恢复验证；	文档查验	销毁有效性进行验证，并对被销毁的存储介质进行数据恢复验证； 2) 查看相关介质销毁操作规程、审批日志等，是否涵盖介质销毁有效性验证，是否对被销毁的存储介质进行数据恢复验证。
	f) 是否按照数据分类分级，明确不同级别数据适当的删除措施，核心数据删除是否采用存储介质销毁方式。	人员访谈 文档查验	1) 访谈相关人员，询问是否对数据进行分类分级，明确不同级别数据适当的删除措施，核心数据删除是否采用存储介质销毁方式； 2) 查看相关数据删除、介质销毁安全策略和操作规程，如数据删除申请单、介质销毁申请单等，核实是否根据不同数据级别进行相应的删除措施，核心数据删除是否采用存储介质销毁方式。

附录 2.4.2 数据安全技术评估表

表2-37 身份鉴别与访问控制评估表

安全子类	识别要素	评估方法	判定依据
身份鉴别	a) 建立用户、设备、应用系统的身份鉴别机制情况，身份标识是否具有唯一性；	安全核查	1) 安全核查，主要涉及重要数据处理系统的服务器、关键网络设备、安全设备、数据库、应用系统等，检查用户在登录是否采用了身份鉴别措施，检查用户列表中用户身份标识是否具有唯一性。
	b) 身份鉴别信息是否具有复杂度要求并定期更换；	人员访谈 安全核查	1) 人员访谈、安全核查，主要涉及重要数据处理系统的服务器、关键网络设备、安全设备、数据库、应用系统等，检查身份鉴别信息是否具有复杂度要求并定期更换（要求至少 8 位以上，数字大小写字母特殊字符 3 种以上组合），更换日期不得长于 90 天；同时检查是否存在弱口令情况。
	c) 是否存在可绕过鉴别机制的访问方式；	安全核查	1) 通过手工渗透，主要涉及本次数据安全风险评估的业务应用系统，检查鉴别机制是否可以可绕过的风险，常见包括认证码爆破、前端绕过等。
	d) 登录失败时采取结束会话、限制非法登录次数、设置抑制时间和网络登录连接超时自动退出等措施的情况；	人员访谈 安全核查	1) 人员访谈、安全核查，检查关键服务器、关键网络设备、关键安全设备（例如核心防火墙等）、业务应用系统、数据库管理系统的登录失败处理机制，是否采取结束会话、限制非法登录次数、设置抑制时间和网络登录连接超时自动退出等措施。
	e) 当远程管理	人员访谈	1) 人员访谈，了解远程管理的方式，是否对本次数

安全子类	识别要素	评估方法	判定依据
	时，是否采取必要措施防止鉴别信息在网络传输中被窃听；	安全核查	据安全风险评估系统的关键服务器、关键网络设备、关键安全设备、业务应用系统、数据库管理系统等采用 HTTPS、SSL 等协议进行远程管理，确保鉴别信息等数据在网络中加密传输； 2) 技术测试，远程管理方式可查看是否采用 HTTPS 或、SSH 等协议，对未采用加密协议的远程管理方式可通过截包测试验证是否单独对鉴别信息加密后传输。
访问控制	a) 建立与数据类别级别相适应的访问控制机制情况，是否限定用户可访问数据范围；	安全核查	1) 应核查本次数据安全风险评估涉及业务应用系统是否采用动态口令、数字证书、生物技术和设备指纹等两种或两种以上组合的鉴别技术对用户身份进行鉴别； 2) 应核查其中一种鉴别技术是否使用密码技术来实现。
	b) 是否在数据访问前设置身份认证等措施，防止数据的非授权访问；	人员访谈 技术测试 安全核查	1) 人员访谈、文档查验，是否在根据分类分级制度，建立了与数据类别级别相适应的访问控制策略； 2) 安全核查、技术测试，检查是否按照策略要求对用户可访问的数据范围进行了限定，测试是否存在旁路等情况。
	c) 数据访问权限与访问者的身份关联情况；	人员访谈 安全核查	1) 访谈相关人员，针对重要数据资源的访问是否启用身份鉴别机制，限制仅授权人员可访问重要数据资源，防止数据的非授权访问； 2) 现场核查确认数据库、业务应用系统、重要数据资源的鉴别机制已有效落实，防止数据的非授权访问。
	d) 数据访问权限申请、审批	人员访谈 安全核查	1) 询问安全管理员并查看数据访问权限是否与访问者的身份进行关联，当发生人员离职、转岗等情况

安全子类	识别要素	评估方法	判定依据
	机制的建设落实情况；		时，及时调整对应账号权限。
	e) 是否以满足业务实际需要的最小化权限原则进行授权。	人员访谈 文档查验	1) 询问安全管理员，查验相关制度文件，是否对数据访问权限建立申请、审批流程制度，并检查相应的授权审批记录表。
授权管理	a) 数据权限授权审批流程建设落实情况，是否明确用户账号分配、开通、使用、变更、注销等安全保障要求，是否对数据权限申请和变更进行审核，是否严格控制管理员权限账号数量；	人员访谈 安全核查	1) 询问安全管理员，目前数据访问授权是否依据业务实际需要的最小化权限原则进行授权； 2) 现场核查现有数据库用户权限列表、业务应用系统权限列表，查看现有的用户和权限，并且访谈管理员用户的用途，配置管理员用户、普通用户、审计用户等，未仅设置管理员用户，根据业务实际需要进行赋权。
	b) 系统管理员、安全管理员、安全审计员等人员角色分离设置和权限管理情况；	人员访谈 文档查验 安全核查	1) 查看是否建立了数据权限审批制度，内容是否包含用户账号分配、开通、使用、变更、注销等安全保障要求。 2) 询问是否对数据权限申请和变更进行审核，并提供申请和变更记录。 3) 询问并查看当前数据库、本次数据安全风险评估涉及业务应用系统相关管理员账号的数量，是否设置了过多的管理员账户、是否分权设置用户。

安全子类	识别要素	评估方法	判定依据
	c) 系统权限分配表建设及更新情况, 用户账号实际权限是否满足最少够用、职权分离原则;	安全核查	1) 检查相关数据库系统、应用系统是否按照三权分立原则建立系统管理员、安全管理员、安全审计员等角色。
	d) 是否存在与权限申请审批结果不一致的情况;	文档查验 安全核查	1) 检查是否编制了系统权限分配表, 明确各用户的权限和用途, 是否及时更新用户权限列表, 对离岗、换岗的人员及时回收相应的权限; 2) 登录相关系统查看用户和权限, 询问用户的用途, 查看是否及时删除用户, 对用户的授权是否满足最少够用以及职权分离原则。
	e) 是否存在多余、重复、过期的账户和角色;	安全核查	1) 根据权限审批结果抽查用户账号, 并且与授权的权限进行匹配, 查看实际分配权限是否与申请权限一致。
	f) 是否存在共享账户和角色权限冲突的情况;	安全核查	1) 检查数据库、业务应用系统是否存在多余、重复或过期的账户或角色; 验证多余、重复或过期的账户或角色已被删除或停用。
	g) 是否存在离职人员账号未及时回收、沉默账号、权限违规变更等安全问题;	人员访谈 安全核查	1) 访谈数据库管理员、业务应用管理员, 提供用户权限列表, 检查管理员用户是否与账户一一对应; 2) 安全核查, 检查角色权限是否存在交叉的情况, 出现未严格执行三权分立的情况。
	h) 数据批量复制、下载、导	人员访谈 文档查验	1) 访谈相关人员, 询问了解离职人员账户回收、沉默账户(长期未使用)以及权限违规变更等问题的处

安全子类	识别要素	评估方法	判定依据
	出、修改、删除等数据敏感操作是否采取多人审批授权或操作监督，并进行日志审计。	安全核查	置策略； 2) 安全检查，对近期离职人员的账号在系统中进行抽查，查看账号是否存在、是否可以登录； 3) 进一步访谈了解账户权限一致性核查的周期以及相关记录，通过系统账户变更日志查看是否与权限变更审批保持一致。

表2-38 数据接口安全评估表

安全子类	识别要素	评估方法	判定依据
对外接口安全	a) 面向互联网及合作方数据接口的接口认证鉴权与安全监控能力建设情况，是否能够限制违规接入，是否能对接口调用进行必要的自动监控和处理；	人员访谈 安全核查	1) 访谈相关人员，了解面向互联网及合作方数据接口是否进行了认证鉴权与安全监控的技术措施； 2) 安全检查，查验相关技术措施及安全设备，是否能够限制违规接入，是否能对接口调用情况进行监控和处置。
	b) API 密钥及密钥安全存储措施设置情况，能否避免密钥被恶意搜索或枚举；	人员访谈 安全核查	1) 访谈相关人员，了解 API 密钥的生成方式以及其安全存储措施。 2) 通过测试，检查 API 密钥是否具备足够的随机性。 3) 通过测试，检查密钥是否可被恶意搜索，如批量明文返回前端等。
	c) 不同安全等	人员访谈	1) 人员访谈，询问是否存在不同安全等级系统间、

安全子类	识别要素	评估方法	判定依据
	级系统间、不同区域间跨系统、跨区域数据流动的安全控制措施情况。	安全核查	不同区域间跨系统、跨区域数据流动的情况。 2) 进一步了解该情况下数据流动的安全控制措施的实施情况。
接口安全控制	a) 接口安全控制策略设置情况，是否规定使用数据接口的安全限制和安全控制措施，明确包括接口名称、接口参数等内容的数据接口安全要求；	人员访谈 安全核查	1) 查看数据接口设计文档，看接口规范，对接口名称、接口参数的定义，询问相关技术人员有关数据接口采取的安全措施，如身份鉴别、访问控制、授权策略、签名、时间戳、安全协议等。 2) 核查业务应用系统或者代码，查看数据接口是否制定了接口安全控制策略，核查数据接口采用的安全限制和安全控制措施。
	b) 是否对涉及个人信息和重要数据的传输接口实施调用审批；	人员访谈 文档查验	1) 访谈相关人员、涉及个人信息和重要数据的传输接口是否明确规定实施调用审批制度； 2) 文档查验，检查相关制度文件及审批记录。
	c) 是否定期对接口（特别是对外数据接口）进行清查，清查不符合要求的接口是否立即关停；	人员访谈 文档查验	1) 访谈相关人员，是否制定了定期对接口（特别是对外数据接口）进行清查的相关制度； 2) 查验相关制度及清查记录，对于不符合要求的接口是否立即关停。

安全子类	识别要素	评估方法	判定依据
	d) 涉及敏感数据的接口调用是否具备安全通道、加密传输、时间戳等安全措施;	人员访谈 安全核查	1) 访谈技术人员, 涉及敏感数据的接口调用是否具备安全通道、加密传输、时间戳等安全措施; 2) 技术测试, 查验相关技术措施的实现。
	e) 数据接口部署身份鉴别、访问控制、授权策略、接口签名、安全传输协议等防护措施情况;	人员访谈 安全核查	1) 访谈技术人员, 数据接口是否部署身份鉴别、访问控制、授权策略、接口签名、安全传输协议等防护措施; 2) 技术测试, 检验相关技术措施的实现。
	f) 对接口类型、名称、参数等安全要求规范情况;	人员访谈 文档查验	1) 访谈技术人员, 查验接口设计文档, 查看是否制定了数据接口安全规范, 规范内容包括接口名称、接口参数、接口安全要求等内容; 此外针对接口不安全输入参数是否具备限制或过滤能力。
	g) 与接口调用方是否明确数据的使用目的、供应方式、保密约定及数据安全责任等情况;	人员访谈 文档查验	1) 访谈相关人员, 与接口调用方是否签署相关安全责任书或协议, 责任书或协议中是否明确数据的使用目的、供应方式、保密约定及数据安全责任等内容; 2) 文档查验, 检查相关协议文件。
	h) 是否对接口访问做日志记录, 同时对接口异常事件进行告警通知的	人员访谈 文档查验	1) 人员访谈, 是否对接口访问做日志记录, 并有相关策略或方法能对接口异常事件进行告警通知。 2) 安全核查, 查验相关策略和方法, 查看事件告警处理记录。

安全 子类	识别要素	评估方法	判定依据
	情况。		

附录 3 综合分析方法

附录 3.1 典型数据安全风险类型

表3-1 典型数据安全风险类型示例

序号	风险类型	描述
1	数据泄露风险	由于数据窃取、爬取、脱库、撞库等安全威胁，或者缺乏有效的安全措施、人员操作失误或有意盗取等，导致数据泄露、恶意窃取、未授权访问等影响数据保密性的风险
2	数据篡改风险	由于数据注入、中间人攻击等安全威胁，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据被未授权篡改等影响数据完整性的风险
3	数据破坏风险	由于拒绝服务攻击、自然灾害、嵌入恶意代码、数据污染、设备故障等安全威胁，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据被破坏、毁损、数据质量下降等影响数据可用性的风险
4	数据丢失风险	由于数据过载、软硬件故障、备份失效、链路过载等问题，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据丢失、难以恢复等安全风险
5	数据滥用风险	由于缺乏授权访问控制、权限管控等有效的安全管控措施、人员有意或无意操作等，导致数据被未授权或超出授权范围使用、加工的风险
6	数据伪造风险	由于数据源欺骗、深度伪造等安全威胁，或者缺乏有效的安全措施、人员有意或无意操作等，导致数据或数据源被伪造、数据主体被仿冒等安全风险
7	违法违规获取数据	违反法律、行政法规等有关规定，非法或违规获取、收集数据的风险 包含违法违规购买数据的情况
8	违法违规出售数据	违反法律、行政法规等有关规定，非法或违规向他人出售、交易数据的风险
9	违法违规保存数据	违反法律、行政法规等有关规定，非法或违规留存数据的风险，如逾期留存、违规境外存储等
10	违法违规利用数据	违反法律、行政法规等有关规定，非法或违规使用、加工、委托处理数据的风险
11	违法违规提供数据	违反法律、行政法规等有关规定，非法或违规向他人提供、共享、交换、转移数据的风险

序号	风险类型	描述
12	违法违规公开数据	违反法律、行政法规等有关规定，非法或违规公开数据的风险
13	违法违规购买数据	违反法律、行政法规等有关规定，非法或违规购买、收受数据的风险
14	违法违规出境数据	违反法律、行政法规等有关规定，非法或违规向境外提供数据的风险
15	超范围处理数据	数据处理活动违反必要性原则，超范围或过度收集使用个人信息或重要数据的风险
16	数据处理缺乏正当性	违反正当性原则，数据处理活动缺乏明确、合理的处理目的
17	未有效保障个人信息主体权利	由于未采取有效的个人信息保护措施、人员操作或外部威胁等，导致未能有效保障个人信息主体的知情权、决定权、限制或者拒绝个人信息处理等个人信息主体合法权利
18	App 违法违规收集使用个人信息	App 违反个人信息监管政策或标准规范，存在违法违规收集使用个人信息行为的风险
19	数据处理缺乏公平公正	由于缺乏安全管控措施、人员有意或无意操作等，导致数据处理违反公平公正、诚实守信原则，侵犯其他组织或个人合法权益的风险
20	数据处理抵赖风险	由于外部攻击威胁、缺乏有效安全管控措施、人员有意或无意操作等，导致处理者或第三方否认数据处理行为或绕过数据安全措施等风险
21	数据不可控风险	由于第三方数据安全能力不足、缺乏有效的第三方管控措施、合同协议缺失、外包人员操作等，导致委托处理或合作的第三方违反法律法规或合同协议约定处理数据，造成第三方超范围处理数据、逾期留存数据、违规再转移等数据不可控风险
22	数据推断风险	由于未考虑数据之间的关联关系，导致从公开数据可推断出核心数据、重要数据、未公开的个人数据等，包括但不限于面向人工智能模型的推理攻击、面向基础设施的跨域推断攻击等
23	其他风险	其他可能影响国家安全、公共利益或组织、个人合法权益的数据安全风险

附录 3.2 风险危害程度分析

风险危害程度分析，主要分析数据的价值、重要性、规模、种类，以及数据处理目的、方式、范围等要素，综合评估数据安全风险一旦发生，对国家安全、经济运行、社会秩序、公共利益或者个人、组织合法权益造成的危害程度。风险危害程度从低到高可分为低、中、较高、高、很高 5 个级别。风险危害程度分析遵循就高从严、整体分析原则，如果该风险涉及多个数据资产，应进行累加判断，将涉及数据的风险按照最高危害等级判断。风险危害程度评价，主要考虑数据价值、数据重要性、风险源严重程度三个因素，分析方法如下：

1、数据价值主要从数据资产的经济效益、业务效益、投入成本计量等方面分析。

2、数据重要性主要从数据分级角度衡量，数据级别越高代表数据重要性越高，数据安全级别可参考《信息安全技术 数据分类分级规则》确定。个人信息规模和数据敏感程度可以作为数据重要性判断的衡量因素。

3、风险源严重程度，主要考虑风险源对数据处理者带来的危害程度。

数据安全风险危害程度的判断标准和等级参考如下表所示。

表3-2 数据安全风险危害程度等级

等级	风险危害程度描述
很高	一旦发生数据安全风险，对国家安全、经济运行造成严重危害或特别严重危害，对社会稳定、公共利益造成特别严重危害
高	一旦发生数据安全风险，对国家安全和经济运行产生危害，对社会秩序和公共利益产生严重危害。对组织权益产生特别严重危害、对组织自身运营造成特别严重危害或对个人信息主体产生特别严重危害
较高	对国家安全和经济运行产生有限危害，对社会秩序和公共利益产生危害，对组织权益、组织自身运营产生严重危害，对个人信息主体合法权益产生严重危害
中	对国家安全和经济运行不产生危害，对社会秩序和公共利益产生一般危害，对组织权益、组织自身运营产生危害，对个人权益产生危害
低	对国家安全和经济运行、社会秩序和公共利益几乎不产生危害，对组织权益、组织自身运营、个人权益造成一般危害
数据处理者可根据数据对自身的价值、重要性，结合风险源严重程度，将仅影响组织权益、个人权益等的风险危害程度自行定为或调整为“很高”“高”等级别，及时进行风险处置。	

表3-3 数据安全风险危害程度等级参考

危害程度等级	影响对象	风险危害程度示例
很高	国家	1) 直接影响国家政治安全。 2) 直接影响涉及国家安全的行业、提供重要公共产品的行业、国家重大基础设施（如能源、电力）等关系国家经济命脉的行业的正常运行和发展，如大面积业务中断、大规模基础设施瘫痪等。 3) 可能导致我国重要设施暴露在高度威胁中或严重影响我国领土、主权完整。例如我国核心网络设施和信息系统的精确位置信息，带精确坐标的实景影像数据泄露。 4) 可能直接导致我国重大经济决策泄露，造成货币汇率、银行利率、物价水平、劳动就业总水平、失业率、进出口贸易总规模等发生巨大波动、GDP 显著下降等重大金融风险。例如引起全国整体 GDP 下降超 1%。

危害程度等级	影响对象	风险危害程度示例
高	公共利益	1) 直接导致特别重大突发事件、特别重大群体性事件、暴力恐怖活动等，引起大范围社会恐慌，比如造成重大人员伤亡、财产损失或环境污染等。 2) 直接导致一个或多个省（自治区、直辖市）大部分地区的社会公共资源供应长期、大面积瘫痪，大范围社会成员（如 1000 万人以上）无法使用公共设施、获取公开数据资源、接受公共服务。 3) 可能导致特别重大突发公共卫生事件（I级），造成社会公众健康特别严重损害的重大传染病疫情、群体性不明原因疾病、重大食物和职业中毒等严重影响公众健康的事件。 4) 可能直接影响人民群众重要民生保障的事项、物资、工程和项目等。可能导致发生特别重大突发事件、特别重大群体性事件、暴力恐怖活动等；可能引发社会性恐慌，对社会稳定、公共利益造成特别严重危害。例如发生影响全国范围内的重大舆情，引起全国范围内的群众恐慌、社会动荡。
	国家	1) 关系国家安全重点领域，或者对国土、经济、科技、文化、社会、生态、军事、网络、人工智能、核、生物、太空、深海、极地、海外利益等任一领域国家安全造成严重威胁。 2) 直接影响宏观经济运行状况和发展趋势，如社会总供给和总需求、国民经济总值和增长速度、国民经济主要比例关系、物价总水平、劳动就业总水平与失业率、货币发行总规模与增长速度、进出口贸易总规模与变动等。 3) 直接影响多个行业内多个企业、大规模用户，对行业发展、技术进步和产业生态等造成严重影响，或者直接影响行业领域核心竞争力、关键产业链、核心供应链等。 4) 可能导致我国重要设施受到较高威胁或影响我国领土、主权完整。例如我国重要网络设施和信息系统的精确位置信息，带精确坐标的实景影像数据被外方掌握。 5) 可能直接影响宏观经济运行，造成社会总供给和总需求、国民生产总值、货币汇率、银行利率、物价水平、劳动就业总水平、失业率、进出口贸易总规模等发生较大变动。例如引起 1 个及以上省、直辖市、自治区的 GDP 或某行业整体 GDP 下降超 1%。
	公共利益	1) 直接导致重大突发事件、重大群体性事件等，引起社会矛盾激化，对社会稳定造成严重危害，比如造成人员伤亡、财产损失或环境污染等。

危害程度等级	影响对象	风险危害程度示例
		2) 直接危害公共健康和安全, 如严重影响疫情防控、传染病的预防监控和治疗等。 3) 可能导致重大突发公共卫生事件(Ⅱ级), 造成社会公众健康严重损害的重大传染病疫情、群体性不明原因疾病、重大食物和职业中毒等严重影响公众健康的事件。 4) 可能导致一个或多个地市大部分地区的社会公共资源供应较长期中断, 较大范围社会成员(如 100 万人以上) 无法使用公共设施、获取公开数据资源、接受公共服务。 5) 可能导致发生重大突发事件、重大群体性事件等。可能严重影响人民群众的日常生活秩序; 可能严重影响各级党政机关履行公共管理和服务职能。可能严重影响法制和社会伦理道德。例如发生影响多个省、直辖市、自治区范围内的重大舆情, 引起多个省、直辖市、自治区范围内的群众恐慌、社会动荡。
	组织	1) 可能导致组织受到刑事处罚, 可能对组织造成重大经济或技术损失, 企业全面停业整顿, 企业面临破产。 2) 可能导致组织受到来自主管部门的行政处罚, 对机构构成严重影响(如某业务版块终止运行、吊销营业执照或吊销相关业务许可证等), 或重大经济损失, 直接或者间接损失合计在营业额 10% (含) 以上的。
	个人	个人信息主体可能会遭受重大的、不可消除的、可能无法克服的影响, 如遭受无法承担的债务、失去工作能力、导致长期的心理或生理疾病、导致死亡等。
较高	国家	1) 对国土、军事、经济、文化、社会、科技、电磁空间、网络、生态、资源、核、海外利益、太空、极地、深海、生物、人工智能等任一领域国家安全造成威胁。 2) 对单个行业领域发展、业务经营、技术进步、产业生态等造成危害。 3) 对单个行业领域的经济运行秩序造成一般危害, 如市场准入、市场行为、市场结构、商品销售、交换关系、生产经营秩序等。
	公共利益	1) 直接影响企事业单位、社会团体的生产秩序、经营秩序、教学科研秩序、医疗卫生秩序。 2) 直接影响公共场所的活动秩序、公共交通秩序, 如影响社会成员使用公共设施、获取公开数据资源、接受公共服务等。

危害程度等级	影响对象	风险危害程度示例
	组织	1) 可能导致组织受到来自主管部门或行政机关的行政处罚或整改要求, 对机构构成较大影响 (如某业务板块的临时关停处罚或定期整改处罚), 直接或者间接经济损失合计在营业额[10%,5‰) 以内的, 或造成较严重的声誉损失。 2) 组织业务数据和经营管理数据处理存在特别严重数据安全风险隐患, 存在超过 10 万个人信息违法违规收集使用行为等, 可能导致组织遭到监管部门处罚、安全事件或法律诉讼等, 企业面临破产等。或自然人遭受特别严重影响, 如: 失去工作、导致长期心理疾病, 导致死亡等。
	个人	个人信息主体可能会遭受较大影响, 如遭受诈骗且诈骗金额在个人财产的 10% 以上、资金被盗用且被盗用金额在个人财产的 10% 以上、被解雇、名誉严重受损、健康状况恶化等。 个人信息处理存在特别严重数据安全风险隐患, 存在超过 10 万个人信息违法违规收集使用行为等, 可能导致自然人遭受特别严重影响, 如: 失去工作、导致长期心理疾病, 导致死亡等。
中	公共利益	1) 可能影响企事业单位、社会团体的生产秩序、经营秩序、教学科研秩序、医疗卫生秩序。 2) 可能影响公共场所的活动秩序、公共交通秩序, 如影响小范围社会成员使用公共设施、获取公开数据资源、接受公共服务等。
	组织	1) 对组织造成轻微经济损失, 如直接或间接经济损失合计在营业额 5‰ 以内, 或造成一定声誉损失。 2) 组织业务数据和经营管理数据处理存在严重数据安全风险隐患。可能影响组织的业务生产经营, 破坏组织声誉、公信力等, 企业遭受经济损失。
	个人	1) 个人信息主体可能会遭受影响, 如信用评分受损、名誉受损、被法院传唤、导致较小疾病等。 2) 个人信息处理存在严重数据安全风险隐患、存在超过 1 万个人信息违法违规收集使用行为等。可能导致自然人遭受严重影响, 如: 遭受诈骗、资金被盗用、被银行列入黑名单、信用评分受损、名誉受损、造成歧视、被解雇、被法院传唤、健康状况恶化等。
低	组织	1) 对组织造成潜在经济与声誉损失。 2) 组织业务数据和经营管理数据处理存在一般数据安全风险隐患, 可能导致组织的经济利益、声誉等轻微受损。

危害程度等级	影响对象	风险危害程度示例
	个人	1) 个人信息主体可能会遭受困扰,但尚可以克服。如付出额外成本、无法使用应提供的服务、造成误解、产生害怕和紧张的情绪等。 2) 个人信息处理存在一般数据安全风险隐患、存在少部分个人信息违法违规收集使用行为等。可能导致自然人遭受一般影响,如:如付出额外成本、无法使用应提供的服务、造成误解、产生害怕和紧张的情绪、导致较小的生理疾病等。

附录 3.3 风险发生可能性分析

风险发生可能性分析，主要考虑风险源发生频率、安全措施有效性和完备性、风险源关联性等因素。分析方法如下：

1、风险源发生频率，可从被评估对象发生相关数据安全事件的次数及频率、同行业或业务模式相似的单位发生相关数据安全事件的次数及频率、相似数据安全事件发生次数及频率、轻微安全问题累计发生次数等方面，综合分析同类风险源发生可能性。一般风险源或安全事件发生频率越高，风险发生可能性越高。

2、安全措施有效性、完备性，主要通过识别数据安全措施应对风险源的有效性、全面性等。核心数据、重要数据及相关数据处理活动，需采取更严格的安全防护措施才能降低风险发生可能性。

3、风险源关联性，主要通过风险源清单关联分析，发现多个风险源组合后可能引发数据安全风险，则将其与其他风险源合并分析，综合判断风险发生可能性。

在综合分析风险源发生频率、安全措施有效性和完备性、风险源关联性的基础上，将数据安全风险发生的可能性从低到高分级为低、中、高 3 个级别，如下表所示。等级越高代表措施完备性、有效性越低，风险越可能发生。

表3-4 数据安全风险发生可能性等级

等级	风险发生可能性描述
高	涉及违法违规行为、数据安全措施明显不足或安全措施有效性较弱，被评估方已经发生或在通常条件下会发生。本单位、国内相同或相似业务模式的单位多次高频发生同类安全事件，或容易与其他风险源结合引发风险，风险隐患发生可能性高（例如出现频率高、在大多数情况下几乎不可避免、可以证实经常发生过）
中	数据安全风险事件发生的可能性一般。或有一定数据安全措施，但有效性不足，被评估对象在一定条件下会发生，本单位、国内相同或相似业务模式的单位发生相关风险源，或有一定概率与其他风险源结合引发风险，风险隐患发生可能性一般（例如出现频率中等，在某种情况下可能发生，或被证实曾经发生）
低	数据安全措施完备、有效，被评估对象或同类组织很少或在较苛刻条件下才会发生相关风险事件，或很难与其他风险源结合引发风险，风险隐患发生可能性低（例如几乎不可能发生，或仅可能在非常罕见和例外的情况下发生）

表3-5 数据安全风险发生可能性等级参考

等级	风险发生可能性示例
高	风险源发生频率：在该行业领域的数据安全防护中，在多数情况下会发生的风险，发生频率高（或≥ 1次/月）或可证实多次发生过。 安全措施有效性和完备性：缺少数据安全防护措施或具有少量的数据安全防护措施，无法或难以抵御大部分数据安全破坏行为。 风险源关联性：通过风险源清单关联分析，易与其他风险源进行关联或能够关联的风险源超过已识别风险源清单的 60%，导致数据安全事件或引发新的数据安全风险。
中	风险源发生频率：在该行业领域的数据安全防护中，在特定条件下可能会发生的威胁，发生频率中等（或≥ 1次/半年）或被证实曾经发生过。 安全措施有效性和完备性：具有相应的数据安全防护措施，能抵御初级数据安全破坏行为，但无法抵御有组织的数据安全破坏行为。 风险源关联性：通过风险源清单关联分析，会与其他风险源进行关联或能关联的风险源超过已识别风险源清单的 20%，导致数据安全事件或引发新的数据安全风险。
低	风险源发生频率：在该行业领域的数据安全防护中，一般不太容易发生的或在很罕见和例外的情况下发生的威胁，发生频率低、没有被证实发生过或几乎不可能发

等级	风险发生可能性示例
	生。 安全措施有效性和完备性：具有较为完善的数据安全防护措施，能抵御数据安全破坏行为。 风险源关联性：通过风险源清单关联分析，几乎不可能与其他风险源进行关联，导致数据安全事件或引发新的数据安全风险。

附录 3.4 风险评价

风险评价一般结合评估对象实际情况，基于附录 3.1 和 3.2 的分析结果，综合风险危害程度及风险发生可能性对安全风险进行综合评价。

数据安全风险评估结果包括：

- 1、重大安全风险：一般指可能直接影响国家安全的数据安全风险。
- 2、高安全风险：一般指可能直接影响经济运行、社会稳定、公共健康安全，以及较为广泛的公众权益，或对国家安全造成间接影响的数据安全风险。
- 3、中安全风险：一般指可能直接对企业合法权益造成较为严重的影响，或直接对自然人的人格尊严受到严重侵害或者人身、财产安全受到严重危害，或对经济运行、社会稳定、公众利益造成较为严重间接影响的数据安全风险。
- 4、低安全风险：一般指可能直接对企业合法权益造成一般影响，或直接对自然人的人格尊严受到侵害或者人身、财产安全受到危害，或对社会、公众权益有一定或较小影响的数据安全风险。
- 5、轻微安全风险：一般指可能直接对企业合法权益造成一般或较小影响，或对自然人人格尊严、人身安全、财产安全不造

成侵害或仅产生较轻微的危害，或对小范围的组织或公民个体权益造成影响的数据安全风险。

数据安全风险评估矩阵见下表。

表3-6 数据安全风险评估矩阵

危害程度 可能性	很高	高	较高	中	低
高	重大安全风险	重大安全风险	中安全风险	低安全风险	轻微安全风险
中	重大安全风险	高安全风险	低安全风险	低安全风险	轻微安全风险
低	中安全风险	中安全风险	轻微安全风险	轻微安全风险	轻微安全风险

附录 4 评估总结模板

网络数据安全风险评估报告

（模板）

评估单位：_____（加盖单位公章）

报告时间：_____年_____月_____日

网络数据安全风险评估报告基本信息表

被评估方				
单位名称			统一社会信用代码	
单位地址			邮政编码	
评估对象				
联系人	姓名		职务	
	联系方式		所属部门	
真实性声明	被评估方承诺： 提供的材料准确、真实、合法、有效，并愿为此承担相关法律责任。			
数据安全负责人				
评估队伍单位信息				
单位名称				
单位地址			邮政编码	
联系人	姓名		联系方式	

审核批准	评估组长		日期	
	审核人		日期	

【注】如没有第三方评估队伍，可不填写评估队伍单位信息。

一、评估概述

1.1 评估目的

（根据对网络数据安全风险评估工作的理解以及评估实际开展的情况，明确本次开展网络数据安全风险评估的目的）

1.2 评估依据

（明确开展本次网络数据安全风险评估的依据，包括但不限于《数据安全法 数据安全风险评估方法》）

1.3 评估对象和范围

（说明评估对象的选择原则，从业务、系统、数据、数据处理活动等维度，准确描述评估对象和评估范围）

1.4 评估结论概要

（总结说明本次工作开展情况、评估对象的数据和数据处理活动的概要情况、评估结果概要情况，包括发现的安全问题和风险隐患数量，主要的高、中风险问题等）

二、评估工作开展情况

2.1 评估人员情况

（说明评估工作组织和评估团队人员情况，被评估方参与人员情况）

2.2 评估时间安排情况

（说明本次评估工作的时间进度安排，描述各阶段完成的任务、工作成果和时间节点等内容）

2.3 评估工具和环境情况

（说明使用的评估工具，接入的网络或系统环境、技术测试内容等情况）

三、信息调研情况

3.1 数据处理者基本情况

（说明数据处理者的机构实体基本情况）

3.2 业务和信息系统情况

（说明主营业务、信息系统、App 和网络拓扑等情况）

3.3 数据资产情况

（说明数据资产、数据分类分级、涉及个人信息、敏感个人信息情况）

3.4 数据处理活动情况

（说明数据收集、数据存储、数据使用、数据加工、数据传输、数据提供、数据公开、数据删除、数据出境情况。针对评估对象结合实际情况画出数据流转图）

3.5 安全防护措施情况

（说明已开展的安全测评认证和核实情况，数据安全管理机构、人员及制度情况，网络和数据安全主要措施）

四、数据安全风险识别

4.1 生成式人工智能服务基础风险识别

（应依据附录 2.1 进行数据安全管理和数据安全技术及个人信息保护风险识别，说明各评估对象的风险隐患或安全问题）

4.2 预训练数据和优化训练数据风险识别

（应依据附录 2.2 进行数据安全管理和数据处理活动、数据安全技术的风险识别，说明各评估对象的风险隐患或安全问题）

4.3 生成内容风险识别

（应依据附录 2.3 进行数据处理活动、数据安全技术的风险识别，说明各评估对象的风险隐患或安全问题）

4.4 用户交互数据风险识别

（应依据附录 2.4 进行数据处理活动、数据安全技术风险识别，说明各评估对象的风险隐患或安全问题）

五、综合分析

5.1 风险分析

（针对发现的风险隐患或安全问题，分析并描述可能造成的数据安全风险）

问题编号	问题类别	问题子类	问题描述	风险类型	风险描述	涉及的评估对象

5.2 风险评价

（针对每项数据安全风险开展风险危害程度分析、风险发生可能性分析和数据安全风险评价，形成数据安全风险清单）

编号	风险类型	风险描述	风险危害程度	风险发生的可能性	风险等级	涉及的安全问题	涉及的评估对象

5.3 整改建议

（针对发现的问题隐患和风险分析、评价结果，提出整改建议）

附录

（附录可给出完整的数据安全风险源清单，根据实际需要提供评估底稿，或者补充相应的证据材料等）